



October 31, 2023

Office of the National Cyber Director

Via [regulations.gov](https://www.regulations.gov)

Re: *Request for Information on Cyber Regulatory Harmonization; Request for Information: Opportunities For and Obstacles To Harmonizing Cybersecurity Regulations*

To whom it may concern,

CTIA¹ is pleased to provide these comments on the Office of the National Cyber Director's ("ONCD") Request for Information on Cybersecurity Regulatory Harmonization ("RFI"),² which advances the Administration's National Cybersecurity Strategy ("Strategy")³ and subsequent Implementation Plan.⁴ CTIA submits these comments in its capacity as the representative of the U.S. wireless communications industry.

CTIA supports the goal of ONCD and the Administration to harmonize cybersecurity requirements and regulations. A growing patchwork of cybersecurity laws across the states and at the federal level creates duplicative, inconsistent, or contradictory regulatory frameworks. This fragmentation presents real risks to businesses, consumers, and the overall goals of cybersecurity policy. For example, fragmentation exacerbates regulatory and compliance burdens for business, which, among other things, increases costs to consumers and the risk of consumer confusion. Further, a fragmented and over-regulatory approach could encourage a "check-the-box" compliance mindset instead of a dynamic and risk-based approach to cybersecurity. As ONCD describes it, duplicative regulation "leads to companies focusing more on compliance than on security[.]"⁵ Accordingly, CTIA generally supports the Administration and ONCD's effort to harmonize existing cybersecurity regulations and requirements. This is an effort that is aligned with other congressional and federal agency efforts aimed towards harmonization, such as Congress's establishment of the intergovernmental Cyber Incident Reporting Council ("CIRC") within the Department of Homeland Security ("DHS") to "coordinate, deconflict, and harmonize Federal incident reporting requirements, including those issued through regulations,"⁶ as well as the Federal Communications Commission's ("FCC") actions to relaunch the Cybersecurity Forum for Independent and Executive Branch Regulators ("Cybersecurity Forum") to enhance communication among regulatory entities.⁷

Unfortunately, not all agencies are on the same page. CTIA sees burgeoning overlaps and conflicts across federal and state governments, including at the Securities and Exchange Commission ("SEC"), DHS, the FCC, and the Federal Acquisition Regulatory Council ("FAR Council"), among others. The recently released regulations from the FAR Council are a good illustration: even while this RFI is pending, the FAR Council has published for public comment two sets of sweeping regulations that will impose serious burdens on federal contractors that are not harmonized with other obligations.⁸

To help ONCD address these challenges, CTIA offers several observations and recommendations that account for the experience and perspective of the wireless industry. In particular, ONCD should:

- Note that the wireless industry is an integral part of the U.S. economy and has been a key collaborator and leader on cybersecurity;
- Recognize important sector differences that require a flexible process to reduce risks and respond



quickly to emerging threats;

- Take a broad view of the harmonization opportunity, which involves more than addressing “conflicting, mutually exclusive, or inconsistent regulations,”⁹ and also focus on duplicative and burdensome regulations as well as oversight burdens;
- Champion the use of common and voluntary guidelines and consensus standards, such as the National Institute of Standards and Technology’s (“NIST”) Cybersecurity Framework (“CSF”), and avoid applying frameworks developed for specific contexts to all sectors;
- Avoid using the harmonization effort to transform existing flexible standards and frameworks into rigid requirements;
- Promote creative solutions, especially for the Communications Sector, including safe harbors and regulatory reciprocity;
- Champion preemption of state, local, Tribal, and territorial (“SLTT”) cyber regulations for meaningful harmonization and deconfliction;
- Promote international coordination without moving U.S. policy towards prescriptive regulation; and
- Defer regulation of cloud and other service providers because they are regulated by customers and federal contracting requirements.

Overall, CTIA urges ONCD to embrace its mission to support meaningful harmonization of cybersecurity regulations across government by urging all federal agencies to prioritize harmonization and avoid promoting additional regulations. CTIA also includes the following appendices: **Appendix A:** RFI Questions Answered in CTIA Comments, **Appendix B:** Wireless Provider Cybersecurity Practices, **Appendix C:** Burgeoning Cybersecurity Obligations and Oversight Affecting Organizations in the United States, and **Appendix D:** Compliance Offerings of Cloud Service Providers.

I. THE WIRELESS INDUSTRY IS AN INTEGRAL PART OF THE U.S. ECONOMY AND HAS BEEN A KEY COLLABORATOR AND LEADER ON CYBERSECURITY.

A. The Wireless Industry Is a Key Part of National Connectivity, Economic Growth, and Innovation.

The Communications Sector is an integral component of the U.S. economy, underlying the operations of all businesses, public safety organizations, and government.¹⁰ Over the last 25 years, the sector has evolved from predominantly a provider of voice services into a diverse, competitive, and interconnected industry using terrestrial, satellite, and wireless transmission systems.¹¹ The Communications Sector, including wireless, supports numerous other critical infrastructure sectors, many parts of the U.S. economy, and the mobile ecosystem generally.

B. The Wireless Industry Has Consistently Worked with DHS and Other Agencies on Collaborative Efforts to Improve Security and Resilience in the Face of Dynamic Threats.

The Communications Sector, and the wireless industry in particular, has a history of working with DHS voluntarily and collaboratively to improve security and resilience. A few examples demonstrate the breadth of engagement on frameworks, baselines, and best practices.



- CTIA and its members partner with the Cybersecurity and Infrastructure Security Agency (“CISA”) and have worked with DHS since before CISA was formed in 2018.¹²
- CTIA also has collaborated with NIST throughout the development of each version of the CSF. Shortly after the President issued Executive Order 13636, *Improving Critical Infrastructure Cybersecurity*, and Presidential Policy Directive 21, *Critical Infrastructure Security and Resilience* (“PPD-21”), CTIA submitted comments on developing the CSF to improve critical infrastructure cybersecurity.¹³ And CTIA has been engaged with NIST at every stage of the development of the CSF, from its first work in 2014 to the pending update for CSF 2.0.¹⁴
- CTIA was a key player in the collaborative process that led to the National Infrastructure Protection Plan 2013: Partnering for Critical Infrastructure Security and Resilience (“NIPP 2013”), which was updated as required by PPD-21.¹⁵
- CTIA was similarly involved in the 2015 Communications Sector-Specific Plan: An Annex to the NIPP 2013,¹⁶ which emphasized how successfully the Communications Sector already partnered with the government and other private companies to achieve the shared mission of security and resilience.¹⁷
- CTIA provided significant feedback on CISA’s Cybersecurity Performance Goals (“CPGs”).¹⁸
- CTIA has collaborated with CISA on other workstreams, such as zero trust (“ZT”) and developing rules pursuant to the Cyber Incident Reporting for Critical Infrastructure Act of 2022 (“CIRCA”).¹⁹

CTIA and its members are also key participants in critical public-private cyber partnerships. For example:

- The Communications Sector Coordinating Council (“CSCC”) is a vital link between the public and private sectors. The CSCC was chartered in 2005 to help coordinate initiatives to improve the physical and cybersecurity of sector assets and to ease the flow of information within the sector, across sectors, and with designated federal agencies.²⁰
- CTIA and its members are part of the FCC’s Communications Security, Reliability, and Interoperability Council (“CSRIC”), which provides recommendations to the Commission.²¹ Notably, CTIA and its members worked through CSRIC to provide guidance on applying the NIST CSF to the Communications Sector.²² Additionally, in 2021, FCC Chairwoman Jessica Rosenworcel added DHS to CSRIC leadership to promote better coordination between the agencies on communications security issues.²³ Important workstreams related to communications and Internet security are underway in the current CSRIC.
- CTIA members participate in the President’s National Security Telecommunications Advisory Committee (“NSTAC”), which brings together industry chief executives to provide the President with “collaborative advice and expertise, as well as robust reviews and recommendations.”²⁴ The current NSTAC committees will review the use of baselines and frameworks, and how to measure use.
- DHS’s Information and Communications Technology (“ICT”) Supply Chain Risk Management Task Force was spearheaded by CTIA and members to address cyber threats to ICT supply chains.²⁵

C. The Wireless Industry Has a Long History of Investing in Cybersecurity to Protect Networks, Customers, and the Public.

CTIA has engaged in several initiatives to promote and adopt cybersecurity best practices. CTIA’s



Cybersecurity Working Group (“CSWG”) works to get ahead of cybersecurity threats through research, innovation, and collaboration. Through the CSWG, CTIA and its members frequently provide expert input to federal partners, including the FCC, DHS, and NIST, among others. The CSWG also helps CTIA to spearhead cutting edge work on cyber issues. For example, CTIA recently launched a 5G Security Test Bed, which brings together “wireless providers, equipment manufacturers, cybersecurity experts, academia, and government agencies to demonstrate and validate how 5G security will work, using real 5G networks.”²⁶ CTIA has also established an Internet of Things (“IoT”) Cybersecurity Certification Program, which establishes a baseline for device security on wireless networks and uses widely adopted standards from NIST, among others.²⁷ And earlier this year, CTIA published a white paper on ZT describing how ZT principles and their implementation advance network security and summarizes ZT’s existing implementation and continued evolution in the wireless ecosystem through proactive industry efforts and partnerships.²⁸

CTIA members prioritize cybersecurity. Good cybersecurity practices are not just good policy; they are also good for business. The wireless industry must maintain consumer trust and confidence to sustain continued growth in the mobile ecosystem. Security breaches can undermine these efforts and are costly, both in terms of short-term impacts and long-term reputational harms. Thus, wireless providers are committed to securing consumer data, building protections into their networks, and constantly innovating and enhancing these capabilities to stay ahead of the risks, including ensuring that 5G is the most secure generation of wireless technology. Indeed, CTIA members are leaders in implementing a variety of cybersecurity control-based standards while assessing risks and substantially investing in preventative measures to protect privacy and the security of their customers’ information. Appendix B provides examples of the best-practice standards and third-party frameworks, such as the NIST CSF, that CTIA members utilize in their cybersecurity policies and practices.

D. The Communications Sector Champions Collaboration on Standards and Best Practices, Which Are Inherently Superior to Static Mandates in an Area as Dynamic, Complex, and Frequently Changing as Cybersecurity.

The Communications Sector, including the wireless segment, was an early adopter of cybersecurity risk management, working on industry initiatives and with the federal government to mitigate cybersecurity risks and operate secure networks.²⁹ The Communications Sector’s standards bodies have been engaged on cybersecurity for decades on security standards, protocols, and requirements. For example, the 3rd Generation Partnership Project (“3GPP”) is engaged on 5G security standards issues through its SA3 working group.³⁰ The Alliance for Telecommunications Industry Solutions (“ATIS”) develops standards, solutions, and frameworks for mitigating cybersecurity risks.³¹ The International Organization for Standardization (“ISO”) and the International Electrotechnical Commission’s (“IEC”) JTC 1/SC 27 develops “standards, technical specifications and reports, best practices and related documents in the field of information security, cybersecurity and privacy protection.”³² For example, this committee published ISO/IEC 27001, a security standard for information security management systems.³³ The Internet Engineering Task Force (“IETF”) has Security Area Working Groups.³⁴

Standards and frameworks can more readily adjust to the ever-changing cybersecurity landscape than regulatory mandates, which often tend to reflect the technology and threats at the time they are promulgated. Standards and frameworks are created by industry to address current or expected threats to communications networks and infrastructure. Because of the rapid pace of technological development, work on best practices and standards is continuously evolving and adapting to new



threats contemporaneously to ensure that networks, infrastructure, and devices are protected. Government mandates, conversely, are often slow to respond to changes in the threat environment and/or can quickly become outdated. As a prior FCC Chairman observed, “the pace of innovation on the Internet is much, much faster than the pace of a notice-and-comment rulemaking.”³⁵ He and other policymakers have lauded the NIST CSF because “[i]t is not a static checklist. The [NIST] Framework’s success will rely on proactive risk management, not reactive compliance with a cybersecurity to-do list.”³⁶ That remains the case today, as the CSF enters its third iteration in version 2.0, and collaboration on standards and frameworks that raise the bar remains preferable to prescriptive regulation.

II. ONCD SHOULD RECOGNIZE IMPORTANT SECTOR DIFFERENCES THAT REQUIRE A FLEXIBLE PROCESS TO REDUCE RISKS AND RESPOND QUICKLY TO EMERGING THREATS.

ONCD has stated that cybersecurity is similar between different sectors, noting that “the cybersecurity of one sector is inherently similar to the cybersecurity of other sectors.”³⁷ While there certainly are similarities between sectors, important differences remain, which the Administration’s overall approach recognizes. For example, CISA’s forthcoming Sector-Specific Performance Goals and the federal government’s longstanding emphasis on flexibility are intended to ensure that vastly different organizations can address their own networks, interdependencies, and risks.³⁸

Different sectors have different levels of cybersecurity maturity and preparedness that can influence their risk profiles. Certain threat actors prioritize sectors differently, often according to ease of access. For example, access brokers are threat actors who acquire access to organizations and provide or sell this access to other bad actors, including ransomware operators.³⁹ The number one target for access brokers in 2022 was academia, followed by technology, industrials, manufacturing, professional services, financial services, telecommunications, government, healthcare, and retail.⁴⁰ In this top-ten list, telecommunications ranked seventh. Additionally, the Federal Bureau of Investigation (“FBI”) has noted important differences between companies and institutions.⁴¹

While nation state actors have become more aggressive in threatening U.S. critical infrastructure, not all sectors face the same risks. China has greatly expanded its cyberespionage operations over the course of the last year, but the risk to the Communications Sector has remained relatively small.⁴² The Communications Sector tracks and addresses risks to its infrastructure and customers and has done so for years as part of a mature approach to cybersecurity. Only 2% of the Communications Sector is targeted by nation state actors according to recent reports by Microsoft.⁴³ By contrast, think tanks, non-governmental organizations (“NGOs”), universities, and government agencies are frequent targets for nation state actors.⁴⁴ This is not to say that the Communications Sector is free from threats and attacks, but the nature of threats can vary across sectors and over time.

CTIA urges ONCD to recognize different threats facing different sectors as reflected in, for example, CISA’s directive to create Sector-Specific Performance Goals, which is preferable to a one-size-fits-all approach. The pursuit of harmonization should not lead ONCD to conclude that additional regulations are appropriate for critical infrastructure sectors. The Communications Sector, for example, does an exemplary job of investing in cybersecurity, setting security standards, and sharing relevant investigative or threat information.



III. THE GOVERNMENT MUST TAKE A BROAD VIEW OF THE HARMONIZATION OPPORTUNITY, WHICH INVOLVES MORE THAN ADDRESSING “CONFLICTING, MUTUALLY EXCLUSIVE, OR INCONSISTENT REGULATIONS.”

A. ONCD Should Consider Oversight Obligations in Addition to Laws and Regulations.

Importantly, ONCD should not just look to laws and regulations, but it should also consider oversight burdens as well.⁴⁵ Companies are frequently subject to overlapping investigations and enforcement, both at the state and federal levels. Such enforcement should be coordinated and deconflicted. Data breaches and incidents can generate burdensome investigations by up to 50 states. Multiple federal and state agencies demand information—often overlapping, but usually slightly different—from companies about their cyber programs, risk management, or about compliance. This results in companies frequently being asked to provide law enforcement with information or respond to regulators while they are trying to contain and remediate a cyberattack.

For example, there is overlap with states like New York and Virginia as well as state Attorneys General (“AGs”) who push ahead with their own “oversight.”⁴⁶ Duplication occurs at the federal level too. For example, FCC and Federal Trade Commission (“FTC”) FTC enforcement can overlap. The FCC’s authority under Sections 201 and 222 of the Communications Act overlaps with FTC Section 5 authority, allowing the agencies to look at the same activities. This is evident in comments on the FCC’s proposal to expand customer proprietary network information (“CPNI”) obligations. DHS’s CPGs, in addition to substantive pieces of the CIRCIA rulemaking that are not only about reporting, also create overlap. Likewise, SEC investigations have been controversial because they add complexity and highlight the dangers of an overly aggressive enforcement approach.⁴⁷ The Department of Defense Cyber Crime Center (“DC3”) and the Defense Contract Management Agency (“DCMA”) oversee federal contractors working with the Department of Defense (“DoD”). Thus, government contractors often face overlapping or duplicative cybersecurity requirements. FBI and DHS already work cooperatively with companies who experience a cybersecurity event, and these agencies should be able to investigate and respond without interference from regulators or overlapping overseers.

Litigation compounds these complexities, since class actions for incidents and claims of negligence and faulty disclosures can function as yet another form of oversight. Unfortunately, CISA’s Cybersecurity Advisory Committee has provided recommendations that seem to encourage the use of class actions to police cybersecurity programs.⁴⁸

Burdensome and overlapping incident reporting requirements exacerbate this problem, as well. As an example, significant burdens arise where laws require reporting to one regulator simply because an organization was required to make a report to another regulator. For example, the New York Department of Financial Services (“NYDFS”) cyber rules present compliance burdens because they reach an array of institutions and require reporting whenever a regulated entity reports something to any other regulator.⁴⁹ This can result in multiple burdensome and overlapping investigations, because the required notification to the second regulator often elicits follow-up inquiries and investigations, even if the underlying event would not otherwise be relevant for the second regulator’s purposes. While this portion of NYDFS’s rule applies to incident reporting, ONCD should discourage this approach, as it can result in multiple reports and contribute to overlapping investigations.

The RFI asks for solutions,⁵⁰ and CTIA urges ONCD to lead in burden reduction and deconfliction of oversight and enforcement at the federal and state levels.



B. ONCD Should Target Duplicative and Overlapping Regulations and Oversight for Removal, Recission, or Deconfliction.

ONCD's focus on "conflicting, mutually exclusive, or inconsistent" federal and SLTT regulations is too narrow.⁵¹ By contrast, the Fact Sheet that accompanied the RFI rightly took a broader approach, noting the costs of "duplicative regulation" on consumers and others.⁵² ONCD should follow the broader approach of the Fact Sheet, focusing not just on cybersecurity approaches that conflict, are mutually exclusive, or are inconsistent, but also on those that are duplicative, burdensome, and redundant.⁵³

Indeed, cyber and data security obligations are often duplicative and burdensome rather than truly mutually exclusive. For example, companies in the wireless segment are subject to multiple regulatory demands regarding cyber risk management, data use, and security at the federal and state level—many of which are expanding. CTIA includes such regulatory demands in Appendix C. New obligations are emerging as agencies proliferate requirements rather than streamline them, as the private sector has urged the President.⁵⁴ Requirements and assurance programs are increasing domestically and internationally, diverting resources from improving security to proving compliance to overlapping, redundant, and/or inconsistent requirements, particularly for foundational ICT products that support multiple regulated sectors.⁵⁵ Additionally, the Communications Sector is presently grappling with the application of still-evolving "voluntary" guidance that may or may not shape government expectations and regulations in the future. Finally, several agencies engage in "shadow rulemaking" to circumvent the public notice and comment period by using consent decrees, reports and orders, or task forces to set standards or expectations for Communications Sector entities.⁵⁶

The FCC. The FCC has authority over CPNI⁵⁷ and is exploring new cybersecurity mandates in several rulemakings and in its administration of federal funding—all of which take a more regulatory approach. These efforts unfortunately do not seem to promote harmonization but instead promise to create a patchwork within the Communications Sector. In its clearest exercise of delegated authority, the FCC requires telecommunications carriers to safeguard CPNI and to report customers' CPNI breaches to the FBI and United States Secret Service within seven business days of a reasonable determination of a breach.⁵⁸ The FCC has rules that govern CPNI obligations, but has used a few inconsistent enforcement proceedings over the past decade to signal coming expansions of regulatory obligations. And earlier this year, the FCC initiated a proceeding to update its CPNI rules to expand its regulations.⁵⁹ Additional FCC cyber proceedings include:

- The Commission released a Notice of Proposed Rulemaking ("NPRM") seeking comment on requiring Emergency Alert System ("EAS") participants and Commercial Mobile Service providers to annually certify that they have implemented cybersecurity risk management plans, among other proposed requirements.⁶⁰
- The FCC's NPRM on international Section 214 authorization holders sought comment on facilities cybersecurity certifications.⁶¹ Specifically, the NPRM sought comment on requiring applicants for international Section 214 authority and modification, assignment, transfer of control, and renewal to certify in the application that they will undertake to implement and adhere to baseline cybersecurity standards, such as the CPGs or the NIST CSF.⁶²
- The Commission adopted a Report and Order ("R&O"), NPRM, and Notice of Inquiry ("NOI") in its Enhanced Alternative Connect America Cost Model ("A-CAM") proceeding,⁶³ requiring Enhanced A-CAM carriers to implement a cybersecurity risk management plan that "reflects" the NIST CSF and



either “an established set of cybersecurity best practices, such as the standards and controls set forth in the [CPGs] or the Center for Internet Security Critical Security Controls.”⁶⁴ Additionally, carriers must implement a supply chain risk management plan.⁶⁵ In this proceeding, the inclusion of the CPGs was not proposed or put out for public comment.

- The FCC proposed cybersecurity requirements for 5G Fund support recipients in a Further Notice of Proposed Rulemaking (“FNPRM”).⁶⁶ Mandates purport to be similar to those in the A-CAM proceeding, although the 5G Fund proceeding is presently subject to a petition for review.⁶⁷
- The FCC is proposing a new IoT security labeling program.⁶⁸ This effort adds yet more complexity to the cyber landscape for manufacturers of connected devices, and could affect network operators’ third party and supply chain risk management.
- The FCC launched a Task Force to address privacy and data security and is taking aggressive investigative and enforcement actions that may generate new “common law” guidance like the FTC’s history of consent decrees.
- The FCC’s Title II NPRM seeks comment on whether reclassifying broadband service under Title II of the Communications Act would give the FCC significantly broader cybersecurity authority.⁶⁹ Among other cyber-related questions, the FCC asks whether reclassification would “strengthen the Commission’s ability to establish rules mandating that service providers implement cybersecurity practices and risk management plans.”⁷⁰ The NPRM telegraphs a marked desire to follow up reclassification with specific mandates, greatly expanding the role of the FCC as a cyber regulator.⁷¹

Simply put, there is a flurry of activity at the FCC that is moving away from harmonization.

NTIA. The National Telecommunications and Information Administration (“NTIA”) is requiring cybersecurity certifications in grant programs. In NTIA’s 2022 Broadband Equity, Access, and Deployment (“BEAD”) Program Notice of Funding Opportunity (“NOFO”), applicants were required to ensure that subgrantees have cybersecurity risk management plans that “reflect” the NST CSF and “the standards and controls set forth in Executive Order 14028.”⁷² In NTIA’s 2023 Wireless Innovation Fund NOFO, applicants were required to certify that they “employ appropriate cybersecurity practices within their enterprise” and to “describe measures taken to ensure that practices are consistent with current industry best practices for cybersecurity, such as the [NIST CSF] and [the CPGs].”⁷³

The FTC. The FTC is taking a particularly aggressive approach to cybersecurity, both in terms of guidance and rulemaking, but also in its investigations and enforcement work. Section 5 of the FTC Act, as interpreted by the FTC and applied in enforcement actions, sets standards of care for data security and cyber risk management. A pending commercial surveillance and data security rulemaking initiative would overlap with several existing cyber regulatory and governance regimes.⁷⁴ Further, the FTC’s Safeguards Rule requires covered non-bank financial institutions to develop, implement, and maintain information security programs that protect consumer financial information.⁷⁵ These extensive programs include risk assessments, testing, incident response, and defined security controls.⁷⁶

In addition to regulations, ONCD should consider the FTC’s “common law” that the agency treats as precedent: consent decrees and guidance that the FTC intends to shape private sector behavior. These documents are not always informed by public comment as substantive expectations that an *entire industry* will follow. Companies thus have to contend with an array of signals that shape their substantive behavior and cybersecurity programs, but which have not been subjected to scrutiny or



cost-benefit analysis. This is compounded by the FTC’s increasingly aggressive and formalistic approach to substantive settlement terms, which the FTC itself views as setting expectations for the industry. Additionally, FTC staff has provided guidance on certain technical controls outside of specific settlements that, while not strictly binding, is clearly meant to influence industry behavior.⁷⁷ The FTC’s approach complicates companies’ cyber compliance by imposing costs to review programs and forcing companies to expend resources to consider whether they meet the agency’s shifting expectations. ONCD should specifically review the FTC’s “common law” practices and its substantive cybersecurity requirements.

Federal Contracting Requirements. Many wireless companies are government contractors who face substantive requirements by contract with the government, such as through the Federal Acquisition Regulation (“FAR”) or the Defense Federal Acquisition Regulation Supplement (“DFARS”). These obligations require careful consideration of network segmentation, protection of various types of data, and operational steps that duplicate or would be in parallel with other regimes. Contractors may have to spend significant time assessing compliance with evolving Controlled Unclassified Information (“CUI”) and other obligations, alongside the other regimes discussed herein.

These contractual requirements are in flux, as the FAR Council has proposed a pair of major new rules to update the FAR.⁷⁸ These new rules take a markedly more aggressive approach both to mandates and to their scope, and propose several disappointing and sweeping new obligations that differ dramatically from other existing and proposed cyber requirements. ONCD should immediately work with the General Services Administration (“GSA”) and the FAR Council to correct this misdirection. The first proposed rule in FAR Case No. 2021-0017 would likely create new, unharmonized rules relating to incident reporting and update timelines; logging and data retention; software bill of materials (“SBOM”) requirements; and granting CISA, the FBI, and the contracting agency access to systems for threat hunting and incident response. The second proposed rule in FAR Case No. 2021-0019 primarily addresses standardization and would apply cybersecurity requirements to unclassified Federal Information Systems (“FIS”), such as annual vulnerability and independent assessments of FIS systems, implementation of security and privacy controls based on NIST guidance, and other related requirements. Moreover, the FAR Council has signaled through these two sets of proposed rules that companies may be subject to False Claims Act litigation for noncompliance with highly technical proposed rules that will often involve the application of voluntary guidance documents from NIST.⁷⁹ This creates the potential for yet another overlapping enforcement mechanism. The substance and tone of the FAR proposals are surprising given the Administration’s emphasis on harmonization. CTIA urges ONCD to promote harmonization and redirect the FAR Council to more practical and productive efforts on cybersecurity.

The SEC. SEC governance expectations overlap with the FCC, the FTC, and others. On July 26, 2023, the SEC voted to adopt new cybersecurity rules, which became effective on August 4, 2023.⁸⁰ Among other things, the SEC’s controversial new rules require registrants to describe material information about their cybersecurity risk management, strategy, and governance, with an eye toward shifting behaviors. The SEC received substantial pushback from industry about how its approach is flatly at odds with the goals of Congress and the Administration. The SEC itself found a conflict with its proposal and the FCC’s CPNI rules, though it dismissed arguments about conflict with its approach and multiple other regulatory obligations.⁸¹ The SEC’s rule is under considerable scrutiny from senators and may face a potential Congressional Review Act challenge.⁸²

States. State-level cyber obligations and privacy laws are proliferating. Multiple states are adding cyber



requirements, such as California, New York, and Virginia.⁸³ For example, NYDFS's Cybersecurity Requirements set out numerous prescriptive mandates for companies to adopt specific technical controls, and establish particular duties and requirements for corporate governance.⁸⁴ These requirements are not consistent with federal rules covering the same set of companies,⁸⁵ and NYDFS has indicated that it does not intend to further harmonize requirements.⁸⁶ In light of increasing state fragmentation on cyber, it is troubling that the President sent a letter to state AGs encouraging additional cyber regulation of utilities and others subject to state oversight.⁸⁷

Emerging Technologies, Such as AI. In addition to various cybersecurity obligations, RFI Question 7(g) asks commenters to "identify any specific Critical or Emerging Technologies that are subject to conflicting, mutually exclusive, or inconsistent regulation related to cybersecurity." The government has taken various actions that are relevant to critical and emerging technologies that are used and made by entities in the Communications Sector.⁸⁸ Other state and federal initiatives are beginning to regulate and provide guidance for artificial intelligence ("AI").⁸⁹ Such overlapping workstreams and emerging requirements impose significant costs for compliance and in responding to varied oversight inquiries.

The CPGs. On top of these mandates, DHS and NIST have been developing various overlapping guidance and other documents, such as CISA's CPGs, which are intended to shape expectations for critical infrastructure. While the CPGs are voluntary, they add to a cacophony of expectations that do not always fit comfortably with current and evolving legal mandates. CTIA and others urged DHS to make some key changes to the CPGs; an earlier version failed almost entirely to map to the NIST CSF, while subsequent versions retained objectionable and unworkable prescriptive expectations.⁹⁰ Worse, despite DHS's emphasis on voluntary use, in some instances, there are explicit efforts to turn these voluntary frameworks into requirements—such as in the FCC and NTIA efforts noted above. Further, the CISA Cybersecurity Advisory Committee's recently released Draft Report to the CISA Director recommends that CISA, the White House, and the SEC should consider whether corporations should be required to adopt the CPGs as the cybersecurity risk management framework for reporting.⁹¹ Additionally, the Strategy has advocated for cybersecurity regulations to leverage the CPGs.⁹² ONCD should review the use of the CPGs by regulators like the FCC, and encourage agencies to refrain from converting voluntary goals and guidelines into regulatory mandates. ONCD also should work with DHS to help develop a risk-based approach to any Sector-Specific Goals, and urge DHS to work more closely with the private sector in refining any future performance goals.

Incident Reporting. Incident reporting obligations complicate the patchwork of state and federal laws. CTIA recognizes that ONCD will not address incident reporting through this RFI. However, because disparate regimes affect substantive planning and compliance, they affect substantive regulatory compliance. Accordingly, they are briefly noted here. All 50 states, the District of Columbia, Guam, Puerto Rico, and the Virgin Islands all enforce data breach notification laws, with their own varying triggers, requirements, and notice timelines.⁹³ As noted, the FCC, FTC, and SEC require incident reporting, and these rules are in flux. Additionally, the Health Insurance Portability and Accountability Act ("HIPAA") requires HIPAA-covered entities and their business associates to provide notification following a breach of unsecured protected health information.⁹⁴ The FTC's Health Breach Notification Rule ("HBNR") requires vendors and related entities not covered by HIPAA to notify individuals and the FTC of a breach of unsecured personally identifiable health data.⁹⁵ This year, the FTC issued an NPRM seeking to expand the HBNR's definition of "breach."⁹⁶ In March 2022, Congress passed CIRCIA, significantly changing the landscape of national cybersecurity regulation.⁹⁷ Once new CIRCIA rules are



finalized, they will require critical infrastructure companies to report significant cyber incidents and ransomware payments to DHS CISA within short, specified deadlines. This remains an area of substantial inconsistency.

C. Redundancies and Overlap Create Costly Compliance Burdens on the Private Sector.

ONCD is right to focus on and ask questions about costs and burdens of conflicting or redundant cyber expectations.⁹⁸ The regulatory environment is leading to substantial burdens on companies, but many agencies do not themselves engage in cost-benefit analysis before promulgating cyber regulations, expanding guidance and expectations, or initiating new task forces. ONCD should work with Office of Management and Budget (“OMB”) to require more rigor from agencies before they create varied cyber obligations. As noted in Section III.B. above, the FCC is one example, having offered several variations across at least three specific proceedings without engaging in meaningful cost-benefit analysis in light of the duplication and balkanization of mandating separate cyber programs. Likewise, the FTC has initiated several programs on data security and made recommendations about encryption and other approaches without apparently considering costs of varied approaches preferred by the agency’s technologists.⁹⁹ The SEC’s cyber rulemaking had scant cost-benefit analysis, and what it did provide was speculative at best.¹⁰⁰

While cyber compliance costs are hard to quantify because formal mandates are more recent, and it is difficult to quantify the specific additional “costs” from overlapping regulation on top of companies’ robust compliance, technology, and risk management programs, what is clear is that the burdens are substantial. Generally, compliance costs for U.S. businesses are high and continue to increase. A 2022 study found that, on average from 2002 to 2014, regulatory costs accounted for 1.34% to 3.33% of a firm’s wage bill, ranging from a conservative estimate of \$79 billion to a broader estimate of \$239 billion.¹⁰¹ Similarly, a 2016 cross-sector study found that regulatory growth from 1980 to 2012 cost GDP \$4 trillion.¹⁰² As regulations have grown more numerous since the 2010s, these costs are almost certainly higher.

In the context of state-level privacy requirements, for example, there have been enormous compliance costs. In California, the California Attorney General’s office had estimated that the total cost of initial compliance with the California Consumer Privacy Act (“CCPA”) was approximately \$55 billion,¹⁰³ and commenters have noted that the California Privacy Protection Agency (“CPPA”) may have severely underestimated the costs of California Privacy Rights Act (“CPRA”) regulations.¹⁰⁴ For state privacy laws more generally, one study has found that the patchwork of state privacy laws could impose costs between \$98 billion and \$112 billion annually.¹⁰⁵ While these studies and analyses focused on omnibus privacy laws and regulations, these frameworks have cybersecurity aspects that contribute to the major costs at play. Indeed, the cybersecurity audit regulations that the CPPA is contemplating, if adopted, will only compound these costs, especially because they would require covered companies to conduct annual audits, which effectively means that a companies would be in a constant state of audit given the time and complexity that audits require.

Cybersecurity obligations in government contracting can also result in high costs. For example, as companies begin to prepare for Cybersecurity Maturity Model Certification (“CMMC”) compliance, some risk assessment firms estimate that companies can expect to spend between \$35,000 to \$230,000 in consulting, auditing, and compliance remediation.¹⁰⁶ Some accreditation service providers have



estimated that Federal Risk and Authorization Management Program (“FedRAMP”) accreditation may range between \$250,000 and \$3 million.¹⁰⁷

Moreover, cybersecurity is already an expensive endeavor. CTIA members make enormous investments in cyber—both in capital and operating expenses. Large carriers invest hundreds of millions of dollars annually in their cyber teams, both technical and operational, using third parties and internal resources. CTIA members also have vast cyber risk management approaches. These include aspects of compliance but also keeping pace with shifting expectations and government priorities, as well as inquiries about their practices. CTIA has stressed that cost estimates for changing cybersecurity controls are often severely underestimated.¹⁰⁸ Others have raised similar concerns.¹⁰⁹ CTIA’s members invest in compliance teams that work alongside security teams and various business units. Compliance duties may relate to product development, privacy reviews, cybersecurity gap assessments, vendor management, software development, and more. Organizations may have hundreds of employees that are part of or affected by cyber risk management programs and emerging regulatory models, including teams to verify compliance with third party certifications and requirements, like the Payment Card Industry Data Security Standard (“PCI-DSS”), health information security, ISO certifications, and more. In this context, CTIA and its members note that the following areas are facing increased costs driven by shifting obligations:

- Audits, assessments, and gap analyses to different frameworks and standards, which compound when foundational documents change, like NIST 800-53, 800-171, or the NIST CSF;¹¹⁰
- ISO and other third-party certifications require time and money;
- Internal processes to answer and certify attestations, such as for CPNI programs, national security/covered lists, SEC disclosures, state disclosures, and contractual oversight;
- Contract management systems and review to keep commercial contracts up to date with the latest obligations and expectations;
- Increased costs to negotiate contracts with vendors, suppliers, and customers;
- Internal and outside counsel at the federal and state levels (for example, to assess compliance with NYDFS, Gramm-Leach-Bliley Act (“GLBA”) safeguards, PCI-DSS, CPNI, and other regimes);
- Third-party consultants, particularly in light of regulators’ evolving preference for “independent” audits and reviews (as in FTC consent orders);
- Product teams and lawyers (e.g., for IoT and software assurance efforts); and
- HR and training efforts abound, as government expectations for training are ever-increasing, which can include third party and internal training. The cost to deploy varied and evolving training across employee bases is substantial, often in the tens of thousands.

In addition, companies face ongoing costs for maintaining cybersecurity programs. These expenditures are not static, one-time investments, but recurring costs to maintain compliance and meet new demands, as well as address changing business models and services.

Increased compliance burdens result in significant unintended consequences for consumers, as raising costs can affect pricing. These unintended consequences can include consumer confusion, as consumers may not understand that cybersecurity expectations vary based on arbitrary location and



service designations. Additionally, regulatory burdens can unintentionally create negative impacts on overall cybersecurity outcomes. For example, companies will have to navigate and check the box on the complex patchwork of regulations, which divert resources away from companies' ability to dynamically respond to sophisticated bad actors and an ever-changing threat landscape.

D. ONCD Should Aggressively Champion the Harmonization of Cybersecurity Requirements and Expectations Across the Government to Reduce Redundancy, Champion Simplicity and Burden Reduction, and Lead by Example.

Industry supported the creation of ONCD to promote consistency and strategic vision for public-private collaboration. ONCD is in an ideal position to encourage better communication on duplicative and overlapping obligations because of its statutory mandate to coordinate the streamlining of federal policies and guidelines and, as appropriate, federal regulations.¹¹¹ Specifically, ONCD should:

- Champion non-regulatory approaches that preserve collaboration and information sharing, in the spirit of models like the Cybersecurity Information Sharing Act of 2015 and the ISAO Information Sharing and Analysis Centers;¹¹²
- Work to encourage independent agencies to consider harmonization and overlap, as well as conducting meaningful cost-benefit analysis and participating in interagency coordination;
- Promote agency expertise on cyber regulation across sectors;¹¹³
- Create resources that regulators can use to more easily develop cybersecurity requirements that leverage consensus standards where possible;¹¹⁴ and
- Identify and facilitate technical assistance to regulators during the rulemaking process.¹¹⁵

Additionally, ONCD can coordinate with NIST to publish a report that catalogs existing cybersecurity requirements across sectors, analyzes how they align or diverge from consensus standards down to the control level, and identifies opportunities to drive harmonization.¹¹⁶

ONCD can help foster coordination on cyber between agencies. Agencies do not always communicate with one another when developing and implementing processes, requirements, and regulations, creating silos which can result in disparate requirements, guidance, and programs without coordination across the government and industry.¹¹⁷ ONCD should foster a climate of interagency coordination on cyber policies, guidelines, and regulations, as applicable.

To facilitate coordination among federal departments and agencies, ONCD should champion harmonization and partnership in existing federal workstreams that aim to reconcile and deconflict cybersecurity requirements. ONCD should coordinate with FCC Chairwoman Rosenworcel, who serves as the Chair of the relaunched Cybersecurity Forum,¹¹⁸ on specific efforts to harmonize cybersecurity requirements in and outside of the Communications Sector. Notably, the Implementation Plan explains that ONCD and OMB will work with the Cybersecurity Forum in the harmonization effort.¹¹⁹

ONCD should create policies and processes to encourage federal government cybersecurity requirement harmonization and drive consensus standards development.¹²⁰ For example, if an agency issues a cybersecurity requirement that diverges from existing consensus standards, it should be required to create and execute a strategy for developing a consensus standard in consultation with NIST.¹²¹ Agencies issuing federal government cybersecurity requirements should be mandated to review them—and then reaffirm, update, or rescind—at least every five years.¹²² If a requirement does not align to



consensus standards when issued, the agency should conduct this review at least every two years.¹²³

E. ONCD Should Take a Broad Approach to Harmonization and Recommend that No New Regulations Be Proposed Until Substantial Progress Is Made on Harmonization.

ONCD should take a broad and creative approach to harmonization that accounts for all of the workstreams above, prioritizes voluntary and flexible approaches, and seeks to help the private sector invest in cybersecurity rather than burden the private sector with costly overlapping regulations. ONCD should also, at minimum, coordinate with federal agencies to pause further cyber regulatory efforts until the harmonization work is more mature. Promulgating further cybersecurity requirements, such as a potential CPG-based reporting baseline, may hinder ONCD's efforts to harmonize the already vast cybersecurity regulatory landscape. As a vital cyber advisor and coordinator for the White House and executive branch, it is incumbent on ONCD to exercise its leadership role, to promote better communication and awareness across agencies to avoid duplication and premature regulation. ONCD should caution against the promulgation of further regulations and focus instead on harmonization. For example, the RFI asks questions about how "future regulations" could address cybersecurity costs.¹²⁴ Given the vast amount of existing cybersecurity regulations, ONCD should focus on harmonizing existing regulations rather than promoting the creation of additional rules. Additionally, the harmonization effort should be expedited and should not become an indefinite project.¹²⁵

New regulations should only be introduced after ONCD, OMB, and the White House have created an interagency process to ensure that any new cyber regulations proposed by a federal department or agency have been reviewed for and have received the concurrence of ONCD before being published in the Federal Register. Based on the authority provided pursuant to the National Defense Authorization Act for Fiscal Year 2021 that established ONCD, the Director should lead a review process. Such a review process should include, at a minimum, representatives from the Department of Justice, CISA, the Office of the Director of National Intelligence ("ODNI"), and OMB, in addition to other departments and agencies with equities whenever a federal department or agency proposes new cyber regulations to fulfill the statutory mandate to streamline regulations relating to cybersecurity.¹²⁶

ONCD and the White House should leverage the National Security Council ("NSC") System renewed by National Security Memorandum ("NSM")-2, given the cross-cutting nature of critical national security issues—such as cybersecurity—to facilitate interagency coordination on cyber policies, guidelines, and regulations, as appropriate.¹²⁷ Greater utilization of the Interagency Policy Committees ("IPCs") as the main interagency fora for consideration of cyber policy issues would facilitate transparency, coordination, and deconfliction.¹²⁸

IV. ONCD SHOULD CHAMPION THE USE OF COMMON AND VOLUNTARY GUIDELINES AND CONSENSUS STANDARDS; HOWEVER, IT SHOULD NOT ATTEMPT TO APPLY FRAMEWORKS DEVELOPED FOR SPECIFIC CONTEXTS TO ALL SECTORS.

A. ONCD Should Ensure that Standards and Frameworks Remain Voluntary and Flexible and Are the Touchstone for Federal Cybersecurity Oversight.

1. The Communications Sector Uses Existing Standards and Third-Party Frameworks, Which Should Continue to Drive Agency Work on Cybersecurity.



The wireless industry supports the use of guidelines, such as those identified by CSRIC, NIST, and others. ONCD should consider that the Communications Sector already uses several existing voluntary and flexible standards. In Questions 3 and 4 of the RFI, ONCD asks several questions about the use of existing standards, frameworks, and third-party frameworks for mitigating cybersecurity risks. For example, as detailed in Appendix B, CTIA's members implement cybersecurity programs that utilize and align with the NIST CSF and ISO/IEC 27001, among other cybersecurity best practices and standards. These flexible standards and frameworks allow companies to adopt cybersecurity measures and processes that are tailored to their own unique risk profiles and contexts to mitigate cyber risks.

For example, the NIST CSF is a particularly valuable tool for addressing and mitigating cybersecurity risk. Flexibility and voluntariness are key to the NIST CSF's widespread adoption and longevity. The CSF's "risk-based approach enables an organization to gauge the resources needed (e.g., staffing, funding) to achieve cybersecurity goals in a cost-effective, prioritized manner."¹²⁹ NIST explains that the Framework Core is "a set of cybersecurity activities, desired outcomes, and applicable references that are common across critical infrastructure sectors."¹³⁰ NIST makes clear that the document "is not a checklist of actions to perform," but rather that "[i]t presents key cybersecurity outcomes identified by stakeholders as helpful in managing cybersecurity risk."¹³¹ Additionally, the CSF also defines steps for establishing or improving a cybersecurity program, which include conducting a risk assessment.¹³² As ONCD consults and draws on the CSF's guidance during the harmonization process, it should recognize that voluntariness and flexibility are its defining attributes.

2. Consensus Standards Are Critical to Harmonization.

ONCD should seek to leverage ICT standards that are largely developed through industry-driven, voluntary, consensus-based standards bodies ("consensus standards"),¹³³ as alignment with consensus standards strengthens efforts to deconflict, simplify, and align compliance solutions across sectors.¹³⁴ Consistent with NSTAC guidance, ICT standards for security requirements and assurance approaches developed with industry, regulators, and other experts collaborating across sectors and regions are reflective of global best practices.¹³⁵ As NSTAC explains, "outcome-focused requirements provide assurance that a security goal is achieved without specifying the precise mechanisms used to achieve it, enabling practitioners to implement traditional or innovative techniques and technologies."¹³⁶ Outcome-focused requirements can also adjust to evolving threats. For example, if a new threat compromises a mechanism used to satisfy a requirement, an alternative can be employed without changing the underlying requirement.¹³⁷ ONCD should proactively support moving towards a more effective and efficient system that is focused on cross-sector and outcome-based security requirements, while still allowing for use of consensus standards.¹³⁸

B. Frameworks Developed for Specific Sectors Are Not Necessarily Suitable for Application Across All Critical Infrastructure Sectors.

Frameworks developed for specific sectors—such as the Federal Financial Institutions Examination Council ("FFIEC") Model,¹³⁹ or financial service sector approaches generally—are not a good fit for other sectors like the Communications Sector or wireless in particular. The FFIEC reflects a fundamentally regulatory model that was built to standardize financial institution reviews for specific purposes related to supervision of financial institutions, which pose complex systemic risks beyond cyber.

RFI Question 2 asks several questions about the FFIEC's model for information security. The FFIEC is "a formal interagency body empowered to prescribe uniform principles, standards, and report forms for



the federal examination of financial institutions . . . and to make recommendations to promote uniformity in the supervision of financial institutions.”¹⁴⁰ The FFIEC model is tailored for a specific sector and does not fit the unique posture of the Communications Sector.

The FFIEC is a regulatory body, and its function is to support a multi-tiered approach that relies on audits, supervisors, and regulators with different mandates than those applicable to most critical infrastructure sectors.¹⁴¹ Standards and frameworks may be appropriate for different sectors, but the RFI’s questions on the FFIEC model suggest that ONCD is open to a far more prescriptive and regulatory approach that is not yet developed for other sectors and would not be appropriate. Instead of gravitating towards the FFIEC’s uniform principles, ONCD should embrace the voluntary framework established by the NIST CSF and the longstanding coordination efforts in the wireless industry. CTIA does not support extending models built for particular sectors onto other critical infrastructure sectors. This is especially worrisome when a model is built on prescriptive regulatory burdens uniquely applicable to one sector.

V. ONCD SHOULD BE CAREFUL NOT TO LET THE MISSION OF HARMONIZATION TRANSFORM EXISTING FLEXIBLE STANDARDS AND FRAMEWORKS INTO RIGID REQUIREMENTS.

A. Existing Standards Should Not Become Inflexible Regulatory Mandates.

The RFI asks if standards or frameworks have been adopted into regulation, and “[w]hat, if any, additional opportunities exist to align requirements to existing standards or frameworks . . . ?”¹⁴² CTIA notes that, under the National Technology Transfer and Advancement Act of 1995, it is longstanding U.S. policy to champion voluntary consensus standards with respect to technology.¹⁴³ However, voluntary and advisory guidance is often unsuitable for incorporation into mandatory regulations. Guidance documents often use voluntary “should” or “may” advisory language. When agencies *require* compliance with guidance that includes such language, this can create difficulties for enforcement.¹⁴⁴ Accordingly, while existing standards and frameworks should remain available for use, these frameworks are inappropriate for direct incorporation by reference into regulatory mandates.

ONCD should refrain from incorporating evolving cybersecurity guidance and approaches into regulations. For example, in certain contexts noted above, both the FCC and NTIA have begun requiring certifications of compliance with the NIST CSF and CISA’s CPGs (e.g., in the A-CAM rules and the BEAD and Innovation Fund NOFOs), or are considering doing so in other contexts (e.g., the FCC’s Section 214 NPRM). Currently, requiring compliance with the NIST CSF at this time is inadvisable, as NIST released a draft version 2.0 of the CSF for public comment on August 8, 2023.¹⁴⁵ In any case, the CSF is a process-based, flexible framework, so requiring *compliance* with it is fraught, even when its substance is not in flux.¹⁴⁶ Additionally, the CPGs are still subject to change, and CISA’s Sector-Specific Goals are still under development.¹⁴⁷ CTIA has repeatedly engaged both NIST and CISA on their respective workstreams to make adjustments to reflect the realities of the Communications Sector, but the impact of these efforts on communications companies is still yet to be determined.¹⁴⁸ In addition to the general problems with incorporating voluntary guidance by reference noted above, requiring compliance with *developing* guidance will compound difficulties in compliance by making a moving target the regulatory goal.

B. ONCD Should Neither Pursue nor Promote Audit Requirements During the Harmonization Effort.

ONCD should neither pursue nor promote cybersecurity audit requirements as part of its harmonization efforts. RFI Questions 3(b) and 6(g) ask questions related to auditing of cybersecurity compliance. CTIA



urges ONCD to avoid promulgating auditing rules.

Audits and third-party assessments are costly and burdensome, in terms of engagement fees and the demands placed on internal resources to manage and support audits. SOC 2 audits and assessments are expensive, with some industry estimates identifying tens or hundreds of thousands in fees and substantial opportunity cost.¹⁴⁹ ISO 27001 certifications can be costly as well. One industry commenter estimated that “organizations with 10 or fewer employees might spend around \$10,000 on an audit that lasts about five days. For companies under 425 employees, the process can span at least 15 days and cost around \$30,000.”¹⁵⁰ This anecdotal observation misses the mark. It does not address preparatory work by a company seeking certification, and it does not account for larger companies of the sort that constitute many critical infrastructure sectors, for whom an ISO certification can take far longer. Further, gap assessments can be in the hundreds of thousands of dollars when companies work with consulting companies. Penetration testing and tabletop exercises vary considerably, but it is common for engagements to include consultancies and legal, running in to the tens and hundreds of thousands of dollars. This is why agency efforts—such as at the SEC and FTC—to prioritize “independent” audits and oversight are problematic. By commanding the retention of third parties, government would increase demand for those services and drive up the costs in a market already subject to scarcity and workforce limits.¹⁵¹

Moreover, cybersecurity audits can siphon resources and personnel from addressing cybersecurity risk management and incidents. During an audit process, cybersecurity experts must take time to address audit-related requests, and, in some cases, may be unable to devote their time to operational issues. Other opportunity costs can result from an audit’s disruption of ordinary company activities.

The purpose of harmonization is to de-duplicate and streamline existing cybersecurity requirements, not to impose further regulations or rules. ONCD’s questions about auditing suggest that it may envision *further* auditing or verification requirements. If it merely seeks to consider whether current auditing requirements could be considered for reciprocity, then CTIA supports such an effort.

But, as part of its broader harmonization goal, ONCD should discourage policymakers from adding to the plethora of existing and proposed auditing requirements and regulations. For example, in California, the CPPA has released draft cybersecurity audit regulations.¹⁵² Although the CPPA has not begun formal rulemaking, the draft regulations would require *annual* cybersecurity audits for certain businesses.¹⁵³ The audits would need to meet many proposed requirements. The expense and burden of this proposal is immense; regulated entities have been trying to educate the California government that this is unrealistic and unduly burdensome, because it promises to keep regulated entities in a near-constant state of auditing, with external teams generating costs and internal teams focused more on managing the audit than addressing security. This is a classic opportunity cost that promises to divert resources from substantive security to compliance and box-checking. In New York, NYDFS has also proposed requiring annual cybersecurity audits for certain companies, although the audit requirements would be less burdensome than those proposed in California.¹⁵⁴ Still, any annual audit cadence would create significant burdens for regulated entities, as they would result in constant and perpetual audits.

Federal cyber audits are multiplying. The FTC frequently requires third-party security assessments in its orders regarding cybersecurity practices.¹⁵⁵ The SEC and the Commodity Futures Trading Commission (“CFTC”) have required audits for insufficient risk management and information systems security, among other rule violations.¹⁵⁶ The Transportation Security Administration’s (“TSA”) updated pipeline



and rail security directives permit the agency to inspect a wide array of documentation to establish compliance.¹⁵⁷ And, while the FCC has not required specific cyber audits, it has in at least one case required certain support recipients to file network security reports that explain the effectiveness of features of implemented network security controls.¹⁵⁸

Additionally, companies rely on self-assessments, internal audits, and external auditing, choosing to pursue one or more methods depending on their unique cybersecurity needs. This is consistent with the CSF, which explains that “the cybersecurity outcomes of the Framework Core support self-assessment of investment effectiveness and cybersecurity activities,” and that organizations should “innovate and customize how they incorporate measurements into their application of the Framework with a full appreciation of their usefulness and limitations.”¹⁵⁹

Ultimately, a major telecommunications carrier already may have dozens of discrete audit and certification obligations that apply to the organization and its varied business units. ONCD accordingly should not use the harmonization effort to create novel auditing requirements and add to the complexity of existing assessment obligations. Instead, ONCD should take the opportunity to encourage states and federal agencies to cease creating new and discrete audit and related obligations, which only add to compliance burdens and consumer costs without a clear benefit.

If ONCD addresses auditing in the harmonization proceeding, it should discourage the proliferation of more obligations—such as those at the state level. In addition, ONCD should promote reciprocity among regulatory regimes to enable companies to rely on existing assessments and certifications to comply with requirements. For example, an ISO 27001 certification should be sufficient for many or most regulators.

C. ONCD Should Promote Self-Assessments on a Voluntary Basis.

ONCD asks whether companies use self-assessment tools and whether a common self-assessment tool would assist entities in meeting regulatory requirements.¹⁶⁰ Many companies, however, already have mature cybersecurity programs that address self-assessments. While the creation of a *voluntary* common self-assessment form may be helpful for small- and medium-sized businesses, such forms would likely be duplicative or unnecessary for many Communications Sector companies. Small businesses often lack the operations and staff that larger firms utilize for cybersecurity, and a common form may be useful guidance for smaller companies. Any such guidance, however, should not reduce cybersecurity to a checklist of best practices. Accordingly, ONCD could recommend the creation of a voluntary common form but should not require its use.

Additionally, ONCD should allow companies to utilize internal and third-party assessments to satisfy any compliance obligations. In RFI Question 6(l), ONCD asks about “models of third-party assessments of cybersecurity compliance that may be effective at reducing burdens and harmonizing processes.” In the Communications Sector, companies use varied approaches to validate their cyber programs. Some conduct regular internal reviews and audits of systems, complemented by outside review when appropriate. Many companies have robust and mature internal expertise that renders resources less helpful. Outside reviews may be most helpful when they target specific areas, systems, or risks. However, outside reviews can create additional risks and burdens that must be managed to reduce the risk of unintended consequences. Many companies obtain SOC 2 or ISO certifications, and DoD contractors rely on CMMC Third Party Assessment Organizations (“3PAOs”) to conduct assessments. ONCD should promote ways for companies to flexibly rely on both internal and third-party assessments,



as appropriate, to reduce burdens.

D. ONCD Should Work with Agencies that Consider Additional Cybersecurity Expectations to Promote Flexibility, Which May Include Tiered Approaches, but Should Not Include New Regulatory Mandates.

ONCD should not consider any sort of new tiered regulatory model, as its questions appear to prejudice the utility of regulation. RFI Questions 5(a) and 5(b) ask about the applicability of a tiered model of regulation for cybersecurity requirements. ONCD should not promote new regulation to solve harmonization through the creation of additional but similar regulatory regimes. ONCD should avoid creating several tiers of regulatory baselines, as the proliferation of *more* requirements would disrupt attempts at regulatory harmonization. Instead, tiering should be promoted as part of a voluntary, flexible approach, where companies address risks based on their own unique risk profiles and contexts.

VI. AS ONCD FOCUSES ON OVERLAPPING AND BURDENSOME CYBERSECURITY REQUIREMENTS, IT SHOULD PROMOTE CREATIVE SOLUTIONS, ESPECIALLY FOR THE COMMUNICATIONS SECTOR.

A. ONCD Should Promote Creative Solutions, Such as Safe Harbors, to Deconflict.

As discussed above, there are enormous costs and burdens from duplicative oversight efforts, which ONCD should address. And ONCD should look for creative ways to discourage and deconflict any duplication it may find. For example, ONCD could promote safe harbors for compliance with standards and guidelines, such as the NIST CSF, and explicitly encourage agencies and Congress to preclude private rights of action. Safe harbors can encourage healthy cybersecurity practices, promote predictability, and enable new technical and legal requirements to evolve over time. In the cybersecurity context, safe harbors can provide an additional incentive to take important actions to secure their systems, even if, after instituting such practices, the entity is still subject to a cyber incident.

The RFI asks for “examples where SLTT cybersecurity regulations are effectively harmonized or aligned with Federal regulations.”¹⁶¹ Several states use safe harbors for compliance with cybersecurity standards, helping to promote harmonization. For example, Ohio’s safe harbor provides an affirmative defense to companies that can demonstrate that their data security policies follow an approved framework.¹⁶² Utah similarly created a cybersecurity safe harbor, which provides an affirmative defense to a company whose cyber program reasonably conforms with an approved framework and has an appropriate scale and scope based on several factors.¹⁶³

ONCD should consider other types of safe harbors. For example, ONCD should promote safe harbors for delays in reporting if the company or law enforcement determines that disclosure would hinder a law enforcement investigation. Many state breach laws permit delays in disclosure if law enforcement agencies determine that notice will impede an investigation.¹⁶⁴ Similarly, ONCD should promote safe harbors for reasonable delays in reporting to allow companies to determine the scope of the breach and restore the reasonable integrity of the affected system. This would be consistent with other state reporting regimes.¹⁶⁵ These safe harbors protect companies acting in good faith from substantial litigation and/or enforcement risks.

B. ONCD Should Promote Regulatory Reciprocity Among Federal Agencies that Share Cybersecurity Oversight.

The RFI asks about agency efforts to coordinate oversight and engage in regulatory reciprocity.¹⁶⁶ CTIA



supports regulatory reciprocity, as oversight coordination is currently very limited. For example, ONCD should urge the FCC and the FTC to deconflict their investigations and stress the importance of regulatory reciprocity. The agencies previously signed Memorandums of Understanding (“MOU”) to cooperate on consumer protection matters.¹⁶⁷ ONCD could promote the use of channels created by the MOUs as vehicles for regulatory reciprocity between the FCC and the FTC. Additionally, ONCD could use its position to advocate for a focus on regulatory reciprocity at the newly relaunched Cybersecurity Forum.

C. ONCD Should Recognize the Communications Sector’s Unique Context in Certain Harmonization Proposals in the RFI.

The RFI asks: “What, if any, obstacles or inefficiencies have [commenters] experienced with regard to cybersecurity oversight, examination or enforcement related to OT components, systems, or data?”¹⁶⁸ One issue that consistently arises for the Communications Sector is the distinction between operational technology (“OT”) and information technology (“IT”)—and in particular, the different security approaches required for each. ONCD, in its harmonization efforts, should aim to ensure that existing cybersecurity requirements distinguish between IT and OT. Although it is true that IT and OT have been converging, it is important to recognize that these systems retain important key differences. This issue is particularly acute in the wireless context. There are fundamental differences in securing an enterprise—the focus of IT—and securing a service network—the focus of wireless industry OT. Compromises to cellular network OT can result in the loss of service to a very large number of devices. This loss of service, rather than confidentiality, is of greater importance given the uniqueness of the cellular network control structure. Cybersecurity requirements’ conflation of IT and OT will continue to be a challenge for the private sector. Given these distinctions, ONCD should recognize that—where appropriate—certain requirements should focus primarily on OT. For example, CTIA has urged CISA, during its development of the CPGs, to focus its efforts on critical OT.¹⁶⁹

ONCD should ensure that OT requirements for the Communications Sector are prioritized over IT requirements, and also carefully consider the distinctions between IT and OT systems as it begins harmonization.

VII. FOR HARMONIZATION AND DECONFLICTION TO BE MEANINGFUL, ONCD SHOULD CHAMPION PREEMPTION OF STATE, LOCAL, TRIBAL, AND TERRITORIAL CYBER REGULATIONS.

The RFI asks about cybersecurity harmonization across SLTT agencies.¹⁷⁰ As described above, proliferation of SLTT cybersecurity obligations is a major contributor to the problematic trend of fragmentation. ONCD should take steps to promote uniformity in the legal landscape, fulfill federal cybersecurity interests, and stop the proliferation of unnecessary, duplicative, and burdensome SLTT regulations. Those efforts should incorporate preemption as well as federal leadership and coordination.

ONCD should act quickly, because the threat of duplicative and overlapping requirements is not merely theoretical. For example, as ONCD notes, California has, among other cyber rules, established cybersecurity requirements for manufacturers of IoT devices to equip IoT devices with a “reasonable security feature or features.”¹⁷¹

As ONCD also highlights, NYDFS has established cybersecurity requirements, which it is currently updating.¹⁷² NYDFS’s Cybersecurity Requirements already conflict and overlap with federal expectations, and its Revised Proposed Amendments promise even more challenges for regulated



companies. NYDFS seeks to require regulated entities to adopt specified information security controls that are more prescriptive than comparable federal guidance, such as multifactor authentication for all users accessing all information systems,¹⁷³ privileged access management tools,¹⁷⁴ centralized logging, and endpoint detection and response capabilities.¹⁷⁵ NYDFS has proposed requiring these capabilities across covered companies' networks and systems, rather than adopting a flexible and risk-based approach.

NYDFS received an outpouring of concern from the private sector, including objections that the rules reach beyond any legitimate interest in New York-regulated financial operations and data.¹⁷⁶ As CTIA has explained, NYDFS should "tailor and clarify the reach of its regulations, including by tying all regulations clearly and only to systems that support financial services directly regulated by DFS."¹⁷⁷ NYDFS rejected these concerns, and its investigations and enforcement actions reveal a willingness to reach beyond New York to regulate companies that operate on an interstate basis.¹⁷⁸ This is not a sensible way to regulate cybersecurity of companies with inherently interstate systems and operations.

As discussed above, this patchwork of state regulations is onerous for companies and bad for consumers. Companies are required to divert resources from their cybersecurity programs to "checking the box" for an array of divergent cybersecurity regulations, and varying requirements across jurisdictions leave consumers with unclear expectations about company cybersecurity practices. These consequences alone are grounds for a uniform federal approach that precludes state action in this area. But worse than that, a state-by-state patchwork is simply not a sensible way to regulate cybersecurity of companies with inherently interstate systems and operations. Indeed, "cybersecurity" is not a retail product or a discrete set of services, but a set of practices aimed at safeguarding the very channels of interstate commerce. Without adequate cybersecurity, an exploit or intrusion in one state can rapidly spread to other states, or can close off interstate commerce in particular sectors entirely. In this way, cybersecurity is akin to other areas, such as aviation and radiofrequency communications, where the inherently interstate nature of an instrumentality of commerce (the airspace and the airwaves) makes uniform federal regulation a necessity.¹⁷⁹ Moreover, given the role of state-sponsored cyber threats, the risks posed to cyber systems are increasingly international in character, and have a strong national security component. The interest in promoting adequate cybersecurity is inherently federal in nature.

ONCD should promote uniformity in the cybersecurity landscape. A key tool in this effort is federal preemption. Per the Supremacy Clause, federal law takes precedence over state law.¹⁸⁰ Preemption can be effectuated expressly—where a federal law states directly that state law in a certain area is forbidden—or impliedly. Implied preemption likewise can take two forms: field preemption, where federal regulation has so pervasively occupied an area that it leaves no room for state law, and conflict preemption, where a state enactment is invalid because it impermissibly conflicts with federal law.

ONCD should urge Congress to consider legislative enactments that would expressly preempt substantive SLTT cybersecurity regulations. But even absent legislation, federal agencies can use existing authorities to ensure that state law will not stand in the way of federal priorities. To this end, ONCD should encourage federal agencies to be clear and direct in stating the federal objectives that they are fulfilling in adopting cybersecurity-related regulations, and the trade-offs that those regulations seek to balance. Such statements help courts assess whether a state regulation is conflict-preempted.¹⁸¹ ONCD also should encourage federal agencies to consider where expressly preemptive statements may be appropriate in their regulations and/or accompanying orders.¹⁸²



In addition to encouraging the use of federal preemption, ONCD should use its role as a convenor of state and federal interests to pursue a more unified approach. In that capacity, ONCD should urge SLTTs to defer to federal efforts, including the promotion of the use of standards and best practices. The White House and ONCD in particular should urge states, corporate executives, and business leaders to follow the federal government’s recommended best practices to the extent practicable.¹⁸³ ONCD should encourage states like New York that have enacted contradictory obligations, to work on harmonization and to ensure that any regulation is narrowly drawn and reduces burdens. As noted in Section III.A. above, one method would be to encourage SLTT entities to disavow reporting mandates that require reporting anytime a regulated entity makes a report to any other government.

VIII. INTERNATIONAL COORDINATION IS IMPORTANT, AND GOVERNMENT MUST NOT LET THE GOAL OF HARMONIZATION MOVE U.S. POLICY TOWARD PRESCRIPTIVE REGULATION.

CTIA supports international harmonization on cybersecurity standards. That said, the United States should not seek to emulate more prescriptive overseas approaches; instead, ONCD should promote frameworks like the NIST CSF that have been adopted and adapted by other governments. As noted, international standards bodies, such as 3GPP, IETF, and the O-RAN Alliance already are engaged on security standards. International use of NIST and other documents, including global standards, is an ideal way for the United States to champion open markets and transparent standards. This is all the more vital in light of the President’s United States Government National Standards Strategy for Critical and Emerging Technology (“National Standards Strategy for CET”) and commands in federal law to promote U.S. standards abroad.¹⁸⁴

From 2021 to 2022, multiple jurisdictions worldwide responded to increased cyber risks by updating or creating new cybersecurity requirements.¹⁸⁵ At least eleven international jurisdictions developed, updated, or implemented cross-sector or sector-specific cybersecurity requirements, two advanced cyber incident reporting requirements, and nine advanced both.¹⁸⁶ Such an increase in restrictive cyber legislation threatens to disrupt rather than support commerce and harmonization.

Importantly, the White House issued the National Standards Strategy for CET in May 2023 to bolster U.S. engagement, including on issues related to communication and networking technology.¹⁸⁷ The National Standards Strategy for CET indicates that the United States will focus standards development on specific CET applications that will impact the U.S.’s impact on the global economy and national security. One of these applications is “Cybersecurity and Privacy,” which the Strategy notes are cross-cutting issues that are critical to enabling the development of emerging technologies and promoting the free flow of data and ideas with trust.¹⁸⁸ ONCD should ensure that efforts to implement the National Standards Strategy for CET also include international harmonization.

While the federal government should promote harmonized cyber practices internationally, the harmonization effort should not become an avenue for creating more burdensome cybersecurity regulations. For example, the breadth of existing global, federal government, and industry compliance programs for cloud providers is illustrative of the multiple international requirements affecting U.S. cloud providers—as seen in Appendix D.¹⁸⁹ ONCD should not promote further requirements.

In response to Questions 7(e), 9(c), and 9(d), numerous international initiatives are engaged in work on harmonizing or aligning cybersecurity requirements. These initiatives are generally relevant to the approach, recommended by CTIA above, to promote frameworks like the NIST CSF and to avoid prescriptive mandates that slow innovation and impede global progress. CTIA notes several



international initiatives that could be vehicles for such an approach:

- The Department of State and other federal agencies already participate in ongoing bilateral and multilateral engagements with counterparts. Some are structured around existing organizations that often develop Ministerial-level policy declarations and have expert working groups on cybersecurity. These include the Asia-Pacific Economic Cooperation (“APEC”),¹⁹⁰ the Association of Southeast Asian Nations (“ASEAN”),¹⁹¹ the US-EU Trade and Technology Council (“TTC”),¹⁹² the G7, and the G20. All play roles in shaping global norms and best practices.
- The U.S. government often has dialogues with international cybersecurity partners that drive harmonization through specific collaborative initiatives. For example, CISA, the National Security Agency (“NSA”), FBI, Australia, Canada, New Zealand, and the UK recently released a joint advisory on exploited vulnerabilities.¹⁹³
- The Organization for Economic Co-operation and Development (“OECD”), in which the United States is an active member, convenes intergovernmental dialogues supported by multistakeholder advisory groups—which include business, civil society, and labor—that promulgate policy recommendations applicable globally.¹⁹⁴ The OECD has organized its Global Forum on Digital Security for Prosperity in 2018-2023.¹⁹⁵ Additionally, the OECD has created policy frameworks for cybersecurity and privacy that have been followed globally, and its expert group on digital security released a series of recommendations in December 2022.¹⁹⁶
- The United Nations (“U.N.”) is engaged in dialogues regarding global cybersecurity norms in several ways. High-level discussions of overarching policy values and evolving norms are underway at the Open-Ended Working Group (“OEWG”) regarding the use of information and communications technologies and discussions of a cybercrime treaty.¹⁹⁷
- The Global Forum on Cyber Expertise (“GFCE”) is a multistakeholder platform for high-level discussions on ways and means to respond to emerging challenges in cyber capacity building.¹⁹⁸ As such, it gathers and promotes good cybersecurity practices and organizes events on capacity building.
- Additionally, the International Telecommunication Union’s (“ITU”) ITU-T Study Group 17 develops international security-related standards known as Recommendations.¹⁹⁹

ONCD should also recognize international efforts that are overly prescriptive, as well as governments that are developing a good cyber posture. RFI Question 9(b) asks, “Are there specific countries or sectors that should be prioritized in considering harmonizing cybersecurity requirements internationally?” The EU has been aggressive in promoting prescriptive regulation. The United States should work to encourage more flexibility in the EU’s approach and should promote the interests of U.S. business to be free from unduly burdensome domestic regulation overseas. Conversely, ONCD should note that the NIST CSF has seen support in adoption in Japan, as Japanese industry works to develop a common cybersecurity language and improve the nation’s cybersecurity posture.²⁰⁰ Japan’s success is another example of the effectiveness of the NIST CSF’s voluntary and flexible guidance. ONCD should use Japan as an example as it aims to harmonize cybersecurity efforts internationally.



IX. ANY TREATMENT OF CLOUD AND OTHER SERVICE PROVIDERS SHOULD BE DEFERRED AT THIS TIME, RECOGNIZING THAT THEY ARE REGULATED INDIRECTLY BY THEIR CUSTOMERS AND FEDERAL CONTRACTING REQUIREMENTS.

While federal contracting requirements affect cloud service, ONCD should note at the outset that the cloud is distinct from the 5G core network. Requirements for cloud-based services should not regulate the underlying 5G core network. In the RFI, ONCD asks several questions about cybersecurity requirements that are passed down to service providers, as well as inconsistent use of cloud.²⁰¹ Federal contracting standards are addressing cloud use directly and indirectly.

For example, DFARS and FedRAMP apply to DoD contractors, including communications companies. DFARS Subpart 239.76 requires contracting officers to only award contracts to acquire cloud computing services from a cloud service provider that has been granted provisional authorization to provide the relevant cloud computing services in accordance with the Cloud Computing Security Requirements Guide ("SRG").²⁰² DFARS Subpart 239.76 also requires the use of contractual clauses that govern cloud computing security requirements and incident reporting.²⁰³ FedRAMP addresses cloud security and should be sufficient for reliance by agencies and customers. FedRAMP is "the authoritative standardized approach to security assessment and authorization for cloud computing products and services that process unclassified federal information" for federal government contractors.²⁰⁴ Cloud service contractors cannot host federal data until they have obtained FedRAMP authorization. As the CMMC 2.0 rulemaking develops,²⁰⁵ it may indirectly affect cloud providers and the federal contractors that use cloud services. Likewise, the aforementioned new FAR proposals could impact cloud services used by government contractors, in as-yet uncertain ways.

Other efforts are looking at the cloud, both from a regulatory and standards perspective. Earlier this year, the FTC released an RFI seeking comment on several aspects of the security risks of cloud service providers, among other topics.²⁰⁶ Draft 2.0 of the NIST CSF has augmented supply chain and third-party risk management expectations, and CTIA expects commenters to urge NIST to do more. The Committee for the Assessment of Foreign Participation in the United States Telecommunications Services Sector (usually referred to as "Team Telecom") can impose requirements to mitigate national security concerns, which can create conditions on cloud and other data uses and storage, in National Security Agreements that become binding through the FCC licensing process. Appendix D—attached below—provides several compliance offerings of cloud service providers identified by NSTAC. This list is but one example of the many overlapping and duplicative requirements facing the Communications Sector, and the wireless industry in particular, that ONCD should seek to harmonize and deconflict without superimposing yet another set of burdensome federal requirements.

Several states also create cybersecurity requirements for service providers in omnibus privacy laws. Specifically, many omnibus state privacy laws require data processors to assist controllers to fulfill their security obligations, adopt security measures, and enter into contracts for the processing of data.²⁰⁷

X. CONCLUSION

CTIA appreciates the opportunity to collaborate with ONCD as it embarks on the vital effort to harmonize cybersecurity requirements. The Communications Sector, and the wireless segment in particular, are engaged on cybersecurity. ONCD should take a broad view of harmonization that focuses on duplicative and overly burdensome regulations, as well as oversight obligations. ONCD's harmonization work should also take into account the complexities unique to the Communications



Sector and promote flexible and voluntary guidance, such as the NIST CSF. Rather than promote any additional regulations, ONCD should refrain from recommending additional, novel rules and also discourage federal agencies and states from promulgating rules until harmonization efforts have borne fruit.

Respectfully submitted,

/s/ Thomas C. Power

Thomas C. Power
Senior Vice President and General Counsel

Scott K. Bergmann
Senior Vice President, Regulatory Affairs

David Valdez
Vice President, Privacy and Cybersecurity

John Marinho
Vice President, Cybersecurity & Technology

Justin Perkins
Manager, Cybersecurity & Policy

CTIA
1400 Sixteenth Street, N.W.
Suite 600
Washington, D.C. 20036
(202) 736-3220

October 31, 2023



¹ CTIA – The Wireless Association® (www.ctia.org) represents the U.S. wireless communications industry and the companies throughout the mobile ecosystem that enable Americans to lead a 21st-century connected life. The association’s members include wireless carriers, device manufacturers, suppliers as well as apps and content companies. CTIA vigorously advocates at all levels of government for policies that foster continued wireless innovation and investment. The association also coordinates the industry’s voluntary best practices, hosts educational events that promote the wireless industry, and co-produces the industry’s leading wireless tradeshow. CTIA was founded in 1984 and is based in Washington, D.C.

² Request For Information on Cybersecurity Regulatory Harmonization, ONCD (July 19, 2023), <https://www.whitehouse.gov/wp-content/uploads/2023/07/ONCD-Reg-Harm-RFI-Final-July-19-2023.pdf> (“RFI”).

³ National Cybersecurity Strategy, The White House (Mar. 2023), <https://www.whitehouse.gov/wp-content/uploads/2023/03/National-Cybersecurity-Strategy-2023.pdf> (“Cybersecurity Strategy”).

⁴ National Cybersecurity Strategy Implementation Plan, The White House (July 2023), https://www.whitehouse.gov/wp-content/uploads/2023/07/National-Cybersecurity-Strategy-Implementation-Plan-WH.gov_.pdf (“Implementation Plan”).

⁵ Fact Sheet: Office of the National Cyber Director Requests Public Comment on Harmonizing Cybersecurity Regulations, The White House (July 19, 2023), <https://www.whitehouse.gov/oncd/briefing-room/2023/07/19/fact-sheet-office-of-the-national-cyber-director-requests-public-comment-on-harmonizing-cybersecurity-regulations/> (“RFI Fact Sheet”).

⁶ Consolidated Appropriations Act, 2022, Pub. L. No. 117-103, Div. Y, 136 Stat. 49, 1038-59, <https://www.congress.gov/117/plaws/publ103/PLAW-117publ103.pdf> (“CIRCA”) (codified at 6 U.S.C. §§ 681-681g); *id.*, § 2246(a), codified at 6 U.S.C. § 681f. By statute, the Secretary of DHS is to lead the CIRC, in consultation with the Director of OMB, the Attorney General, the National Cyber Director, Sector Risk Management Agencies, and other appropriate Federal agencies. 6 U.S.C. § 681f(a). This provision does not provide “any additional regulatory authority to any Federal entity.” 6 U.S.C. § 681f(b). Notably, a recent DHS Report assessed 52 in-effect or proposed federal cyber incident reporting requirements and found that 45 requirements are in effect over 22 agencies. While CISA is addressing cyber incident reporting under CIRCA, DHS’s findings underscore the importance of harmonizing existing cyber requirements before promulgating new rules. Harmonization of Cyber Incident Reporting to the Federal Government, DHS, at 9 (Sept. 19, 2023), <https://www.dhs.gov/sites/default/files/2023-09/DHS%20Congressional%20Report%20-%20Harmonization%20of%20Cyber%20Incident%20Reporting%20to%20the%20Federal%20Government.pdf>.

⁷ Jessica Rosenworcel, Chairwoman, FCC, Remarks to the Cybersecurity Forum of Independent and Executive Branch Regulators (Apr. 8, 2022), <https://docs.fcc.gov/public/attachments/DOC-382215A1.pdf>.

⁸ *Federal Acquisition Regulation: Cyber Threat and Incident Reporting and Information Sharing*, Proposed Rule, 88 Fed. Reg. 68055 (Oct. 3, 2023), <https://www.federalregister.gov/documents/2023/10/03/2023-21328/federal-acquisition-regulation-cyber-threat-and-incident-reporting-and-information-sharing>; *Federal Acquisition Regulation: Standardizing Cybersecurity Requirements for Unclassified Federal Information Systems*, Proposed Rule, 88 Fed. Reg. 68402 (Oct. 3, 2023), <https://www.federalregister.gov/documents/2023/10/03/2023-21327/federal-acquisition-regulation-standardizing-cybersecurity-requirements-for-unclassified-federal>.

⁹ RFI at 4.

¹⁰ *Communications Sector*, CISA, <https://www.cisa.gov/topics/critical-infrastructure-security-and-resilience/critical-infrastructure-sectors/communications-sector> (last visited Oct. 19, 2023); *Communications Sector-Specific Plan: An Annex to the NIPP 2013*, DHS, at iv (2015), <https://www.cisa.gov/sites/default/files/publications/nipp-ssp-communications-2015-508.pdf> (“Communications Sector-Specific Plan”).

¹¹ See *Communications Sector*, CISA, <https://www.cisa.gov/topics/critical-infrastructure-security-and-resilience/critical-infrastructure-sectors/communications-sector> (last visited Oct. 19, 2023).

¹² See Cybersecurity and Infrastructure Security Agency Act of 2018, Pub. L. No. 115-278, 132 Stat. 4168, <https://www.congress.gov/115/plaws/publ278/PLAW-115publ278.pdf> (codified as amended at 6 U.S.C §§ 101 et seq.).

¹³ Comments of CTIA, Developing a Framework to Improve Critical Infrastructure Cybersecurity, Docket No. 130208119-3119-01 (Apr. 5, 2013), https://www.nist.gov/system/files/documents/2017/06/01/040513_ctia_the_wireless_association.pdf.

¹⁴ *Id.* at 11.

¹⁵ NIPP 2013: Partnering for Critical Infrastructure Security and Resilience, DHS (2013), <https://www.cisa.gov/sites/default/files/publications/national-infrastructure-protection-plan-2013-508.pdf>.

¹⁶ See generally Communications Sector-Specific Plan.

¹⁷ See *id.* at 2, 10-12.

¹⁸ See Letter from CTIA to Alaina Clark, Assistant Director for Stakeholder Engagement, CISA (Feb. 18, 2022) (“CTIA Letter Comments”); Comments of CTIA – The Wireless Association, NCTA – The Internet & Television Association, and USTelecom – The Broadband Association, Draft Common Baseline Version 2.0, Controls List June 2022 (Aug. 15, 2022), https://insidecybersecurity.com/sites/insidecybersecurity.com/files/documents/2022/aug/cs2022_0168.pdf (“Joint Comments”); Comments of CTIA, Cross-Sector Cybersecurity Performance Goals and Objectives, GitHub Submission (Feb. 15, 2023).

¹⁹ Comments of CTIA, Applying Zero Trust Principles to Enterprise Mobility (Apr. 20, 2022); Comments of CTIA, Draft Zero Trust Maturity Model, Pre-decisional Draft; v. 1.0, Cloud Security Technical Reference Architecture, v. 1.0 (Oct. 1, 2021); Comments of CTIA, Request for Information on the Cyber Incident Reporting for Critical Infrastructure Act of 2022, CISA-2022-0010 (Nov. 14, 2022).

²⁰ *About the CSCC*, CSCC, <https://www.comms-scc.org/about/> (last visited Oct. 19, 2023).

²¹ *Communications Security, Reliability, and Interoperability Council*, FCC, <https://www.fcc.gov/about-fcc/advisorycommittees/communications-security-reliability-and-interoperability-council-0> (last visited Oct. 19, 2023).

²² Cybersecurity Risk Management and Best Practices, Working Group 4, Final Report, FCC (Mar. 2015), https://www.atis.org/wp-content/uploads/01_legal/docs/CSRICIV/CSRIC_IV_WG4_Final_Report_031815.pdf.

²³ See *FCC Announces the Membership and First Meeting of the Communications Security, Reliability, and Interoperability Council VIII*, Public Notice, 36 FCC Rcd. 13544 (2021), <https://docs.fcc.gov/public/attachments/DA-21-1150A1.pdf>.

²⁴ *About the President’s NSTAC*, CISA <https://www.cisa.gov/about-presidents-nstac> (last visited Oct. 19, 2023).

²⁵ Press Release, CISA, DHS And Private Sector Partners Establish Information And Communications Technology Supply Chain Risk Management Task Force (Oct. 30, 2018), <https://www.cisa.gov/news/2018/10/30/dhs-and-private-sector-partners-establish-information-and-communications-technology>.

²⁶ 5G Security Test Bed, <https://5gsecuritytestbed.com/> (last visited Oct. 19, 2023); see also *CTIA Launches 5G Security Test Bed for Commercial 5G Networks*, PR Newswire (Jan. 12, 2022), <https://www.prnewswire.com/news-releases/ctia-launches-5g-security-test-bed-for-commercial-5g-networks-301459627.html>.

²⁷ See Cybersecurity Certification Test Plan for IoT Devices, Version 2.0, CTIA Certification (Dec. 2021), <https://ctiacertification.org/wp-content/uploads/2020/10/CTIA-Certification-Cybersecurity-Test-Plan-V2.0.pdf>.

²⁸ *Defining Zero Trust: Industry Approaches and Policy Frameworks for Strong Wireless Network Security*, CTIA (Jan. 9, 2023), <https://api.ctia.org/wp-content/uploads/2023/01/Defining-Zero-Trust-White-Paper-2023.pdf> (“White Paper”).

²⁹ See, e.g., Summary Report and Proposals from Cybersecurity Best Practices Work Completed by FG1B Between March 2002 and March 2003, Network Reliability and Interoperability Council (Mar. 14, 2003), <https://transition.fcc.gov/nric/nric-6/fg1b-rec-homeland-defense.doc>.

³⁰ *SA WG3 - Security and Privacy*, 3GPP, <https://www.3gpp.org/3gpp-groups/service-system-aspects-sa/sa-wg3> (last

visited Oct. 20, 2023).

³¹ See, e.g., ATIS Standard: 5G Network Assured Supply Chain, ATIS-I-0000090, ATIS (June 2022), https://access.atis.org/apps/group_public/download.php/66150/ATIS-I-0000090.pdf; Cybersecurity, ATIS, <https://www.atis.org/initiatives/cybersecurity/> (last visited Oct. 19, 2023); An Architectural Risk Analysis for Internet of Things (IoT) Services, ATIS (Mar. 2019), https://access.atis.org/apps/group_public/download.php/46163/ATIS-I-0000072.pdf; Collaborative DevSecOps in a Service Provider Environment, ATIS-I-0000082, ATIS (Mar. 2021), https://access.atis.org/apps/group_public/download.php/58287/ATIS-I-0000082.pdf.

³² ISO/IEC JTC 1/SC 27, ISO, <https://committee.iso.org/home/jtc1sc27> (last visited Oct. 20, 2023).

³³ ISO/IEC 27001:2022, Information security management systems, ISO (Oct. 2022), available at <https://www.iso.org/standard/27001>.

³⁴ *Active IETF working groups*, IETF Datatracker, <https://datatracker.ietf.org/wg/> (last visited Oct. 20, 2023).

³⁵ Tom Wheeler, Chairman, FCC Remarks to the American Enterprise Institute, at 4 (June 12, 2014), <https://docs.fcc.gov/public/attachments/DOC-327591A1.pdf>.

³⁶ *Id.* at 3.

³⁷ RFI Fact Sheet.

³⁸ *Cybersecurity Performance Goals: Sector-Specific Goals*, CISA (July 26, 2023), <https://www.cisa.gov/news-events/news/cybersecurity-performance-goals-sector-specific-goals>.

³⁹ See 2023 Global Threat Report, CrowdStrike, at 9 (2023), available at <https://www.crowdstrike.com/global-threat-report/> (“CrowdStrike Report”).

⁴⁰ See *id.* at 9.

⁴¹ Private Industry Notification: Cyber Criminal Actors Targeting the Food and Agriculture Sector with Ransomware Attacks, PIN No. 20210901-001, FBI, at 2 (Sept. 1, 2021), https://www.cisa.gov/sites/default/files/publications/PIN_20210901.pdf; FBI Flash: Increase in PYSA Ransomware Targeting Education Institutions, Alert No. CP-000142-MW, FBI, at 1 (Mar. 16, 2021), <https://www.cisa.gov/sites/default/files/PYSA%20Flash.pdf> (“FBI reporting has indicated a recent increase in PYSA ransomware targeting education institutions The unidentified cyber actors have specifically targeted higher education, K-12 schools, and seminaries. These actors use PYSA to exfiltrate data from victims prior to encrypting victim’s systems to use as leverage in eliciting ransom payments.”); Ransomware Activity Targeting the Healthcare and Public Health Sector, Alert Code AA20-302A, CISA (Nov. 2, 2020), <https://www.cisa.gov/news-events/cybersecurity-advisories/aa20-302a> (“CISA, FBI, and HHS have credible information of an increased and imminent cybercrime threat to U.S. hospitals and healthcare providers.”).

⁴² Digital Defense Report, Microsoft, at 35 (2022), <https://query.prod.cms.rt.microsoft.com/cms/api/am/binary/RE5bUvv?culture=en-us&country=us>.

⁴³ *Id.*

⁴⁴ *Id.*

⁴⁵ RFI Questions 6(a) and 6(b) ask about overlapping cybersecurity oversight and such oversight methods.

⁴⁶ See, e.g., N.Y. Comp. Codes R. & Regs. tit. 23, § 500.17(a)(1); Va. Code Ann. §§ 38.2-621, 38.2-625(A).

⁴⁷ See, e.g., Justin Wise, *Judge Questions if SEC Covington Client Demand Opens Floodgates*, Bloomberg Law (May 10, 2023), <https://news.bloomberglaw.com/business-and-practice/judge-questions-if-sec-covington-client-demand-opens-floodgates>.

⁴⁸ Draft Report to the CISA Director, Corporate Cyber Responsibility, CISA Cybersecurity Advisory Committee, at 4, 10 (Sept. 13, 2023), available at https://cyberscoop.com/wp-content/uploads/sites/3/2023/09/CSAC_September-Quarterly-Meeting_Draft-Recommendations_20230913.pdf.

⁴⁹ N.Y. Comp. Codes R. & Regs. tit. 23, § 500.17(a).

⁵⁰ See RFI at 16, explaining that the RFI is seeking “current best practices and approaches applicable to the above topics, as well as new and emerging solutions.”

⁵¹ RFI Question 1.

⁵² RFI Fact Sheet.

⁵³ While ONCD asks commenters to identify “redundant” regulatory requirements in the RFI, it needs to consider duplicative, burdensome, and redundant oversight burdens as well. RFI Question 1(e), n.5.

⁵⁴ NSTAC Report to the President: Strategy for Increasing Trust in the Information and Communications Technology and Services Ecosystem, NSTAC, at 8 (Feb. 21, 2023) https://www.cisa.gov/sites/default/files/2023-04/NSTAC_Strategy_for_Increasing_Trust_Report_%282-21-23%29_508_0.pdf (“NSTAC Report”).

⁵⁵ *Id.* at 8.

⁵⁶ See, e.g., Memorandum from Radhika Fox, Assistant Administrator, EPA, on Withdrawal of Cybersecurity Memorandum of March 3, 2023 to State Drinking Water Administrators, Water Division Directors in Regions I-X (Oct. 11, 2023), https://www.epa.gov/system/files/documents/2023-10/action-memo_rescinding-cyber-memo_october-2023.pdf. EPA withdrew its March 3, 2023 interpretive memorandum due to litigation by three state attorneys general alleging that the memo circumvented Congress and the Administrative Procedure Act. Similarly, TSA has issued several Security Directives without the notice and comment period provided by an NPRM. See, e.g., Security Directive 1580/82-2022-01A, Rail Cybersecurity Mitigation Actions and Testing, TSA (Oct. 23, 2023), https://www.tsa.gov/sites/default/files/sd-1580_1582-2022-01a-rail-cybersecurity-mitigation-actions-and-testing.pdf; Security Directive 1580-21-01B, Enhancing Rail Cybersecurity, TSA (Oct. 23, 2023), <https://www.tsa.gov/sites/default/files/sd-1580-21-01b-enhancing-rail-cybersecurity.pdf>; Security Directive 1582-21-01B, Enhancing Public Transportation and Passenger Railroad Cybersecurity, TSA (Oct. 23, 2023), <https://www.tsa.gov/sites/default/files/sd-1582-21-01b-enhancing-public-transportation-and-passenger-railroad-cybersecurity.pdf>.

⁵⁷ See Communications Act of 1934, 47 U.S.C. §§ 201(b), 222.

⁵⁸ 47 C.F.R. § 64.2011.

⁵⁹ *Data Breach Reporting Requirements*, Notice of Proposed Rulemaking, WC Docket No. 22-21, FCC 22-102 (rel. Jan. 6, 2023), <https://docs.fcc.gov/public/attachments/FCC-22-102A1.pdf>.

⁶⁰ *Amendment of Part 11 of the Commission’s Rules Regarding the Emergency Alert System, et al.*, Notice of Proposed Rulemaking, 37 FCC Rcd. 12932 (2022), <https://docs.fcc.gov/public/attachments/FCC-22-82A1.pdf>.

⁶¹ *Review of International Section 214 Authorizations to Assess Evolving National Security, Law Enforcement, Foreign Policy, and Trade Policy Risks, et al.*, Order and Notice of Proposed Rulemaking, IB Docket No. 23-119, MD Docket No. 23-134, FCC 23-28 (rel. Apr. 25, 2023), <https://docs.fcc.gov/public/attachments/FCC-23-28A1.pdf>.

⁶² *Id.* ¶¶ 99-100.

⁶³ *Connect America Fund, et al.*, Report and Order, Notice of Proposed Rulemaking, and Notice of Inquiry, WC Docket No. 10-90 et al., FCC 23-60 (rel. July 24, 2023), <https://docs.fcc.gov/public/attachments/FCC-23-60A1.pdf>.

⁶⁴ *Id.* ¶111.

⁶⁵ *Id.*

⁶⁶ *Establishing a 5G Fund for Rural America*, Further Notice of Proposed Rulemaking, GN Docket No. 20-32 FCC 23-74, ¶ 52 (rel. Sept. 22, 2023), <https://docs.fcc.gov/public/attachments/FCC-23-74A1.pdf>.

⁶⁷ Petition For Reconsideration and/or Clarification of NTCA–The Rural Broadband Association, WC Docket Nos. 10-90, 14-58, 09-197, 16-271, RM-11868 (Sept. 15, 2023), <https://www.fcc.gov/ecfs/document/1091575053949/1>.

⁶⁸ *Cybersecurity Labeling for Internet of Things*, Notice of Proposed Rulemaking, PS Docket No. 23-239, FCC 23-65 (rel. Aug. 10, 2023), <https://docs.fcc.gov/public/attachments/FCC-23-65A1.pdf>.

⁶⁹ *Safeguarding and Securing the Open Internet*, Notice of Proposed Rulemaking, WC Docket No. 23-320, FCC-23-83, at ¶ 32 (rel. Oct. 20, 2023), <https://docs.fcc.gov/public/attachments/FCC-23-83A1.pdf>.

⁷⁰ *Id.*

⁷¹ See, e.g., *id.* ¶ 31 (seeking comment on whether reclassification would provide the Commission with additional authority to address Border Gateway Protocol vulnerabilities); *id.* ¶ 32 (seeking comment on, among other things, “Could the Commission use Title II authority to require ISPs to block IP addresses that originate malicious software

and ransomware? Would reclassification allow the Commission to mandate the adoption of Communications Security, Reliability, and Interoperability Council (CSRIC) best practices directed to ISPs and audit or enforce the implementation? . . . Would reclassification give the Commission sufficient authority to establish cybersecurity requirements for other components that facilitate communications between end points, such as Internet exchange facilities and data centers that route communications and deliver applications? Could the Commission rely on authority in section 218 to require more comprehensive cyber incident reporting?”).

⁷² Broadband Equity, Access, and Deployment Program, Notice of Funding Opportunity, at 70 (May 2022), <https://broadbandusa.ntia.doc.gov/sites/default/files/2022-05/BEAD%20NOFO.pdf>.

⁷³ Public Wireless Supply Chain Innovation Fund Grant Program – Expanding Testing and Evaluation, Notice of Funding Opportunity, at 23-24 (June 2023), https://ntia.gov/sites/default/files/publications/pwscif_final_nofo.pdf.

⁷⁴ *Trade Regulation Rule on Commercial Surveillance and Data Security*, Advance Notice of Proposed Rulemaking, 87 Fed. Reg. 51273, 51283-84 (Aug. 22, 2022), <https://www.federalregister.gov/documents/2022/08/22/2022-17752/trade-regulation-rule-on-commercial-surveillance-and-data-security>.

⁷⁵ 16 C.F.R. § 314.3(a).

⁷⁶ *Id.* § 314.4.

⁷⁷ See, e.g., Alex Gaynor, *Security Principles: Addressing underlying causes of risk in complex systems*, FTC (Feb. 1, 2023), <https://www.ftc.gov/policy/advocacy-research/tech-at-ftc/2023/02/security-principles-addressing-underlying-causes-risk-complex-systems>.

⁷⁸ *Federal Acquisition Regulation: Cyber Threat and Incident Reporting and Information Sharing*, Proposed Rule, 88 Fed. Reg. 68055 (Oct. 3, 2023), <https://www.federalregister.gov/documents/2023/10/03/2023-21328/federal-acquisition-regulation-cyber-threat-and-incident-reporting-and-information-sharing>; *Federal Acquisition Regulation: Standardizing Cybersecurity Requirements for Unclassified Federal Information Systems*, Proposed Rule, 88 Fed. Reg. 68402 (Oct. 3, 2023), <https://www.federalregister.gov/documents/2023/10/03/2023-21327/federal-acquisition-regulation-standardizing-cybersecurity-requirements-for-unclassified-federal>.

⁷⁹ *Federal Acquisition Regulation: Cyber Threat and Incident Reporting and Information Sharing*, Proposed Rule, 88 Fed. Reg. 68055, 68055 (Oct. 5, 2023), <https://www.federalregister.gov/documents/2023/10/03/2023-21328/federal-acquisition-regulation-cyber-threat-and-incident-reporting-and-information-sharing> (“This proposed rule underscores that the compliance with information-sharing and incident-reporting requirements are material to eligibility and payment under Government contracts.”).

⁸⁰ *Cybersecurity Risk Management, Strategy, Governance, and Incident Disclosure*, Final Rule, 88 Fed. Reg. 51896, 51907 (Sept. 5, 2023), <https://www.federalregister.gov/documents/2023/08/04/2023-16194/cybersecurity-risk-management-strategy-governance-and-incident-disclosure>.

⁸¹ The SEC did, however, create a delay for reporting under its rules for CPNI. See *id.*

⁸² Letter from Senator Rob Portman to Vanessa Countryman, SEC (May 9, 2022), <https://www.sec.gov/comments/s7-09-22/s70922-20128391-291294.pdf>; Jacob Livesay, *Rep. Garbarino considers potential legislation to overturn controversial SEC rule*, InsideCybersecurity (Oct. 20, 2023), <https://insidecybersecurity.com/daily-news/rep-garbarino-considers-potential-legislation-overturn-controversial-sec-rule>.

⁸³ N.Y. Comp. Codes R. & Regs. tit. 23, § 500.17(a)(1); Va. Code Ann. §§ 38.2-621, 38.2-625(A); Ohio Rev. Code Ann. §§ 1354.01-.05.

⁸⁴ See, e.g., N.Y. Comp. Codes R. & Regs. tit. 23, § 500.5 (requiring “continuous monitoring or periodic penetration testing and vulnerability assessments”); Revised Proposed Second Amendment to 23 NYCRR 500: Cybersecurity Requirements for Financial Services Companies, NYDFS, at 500.4(d) (June 28, 2023), https://www.dfs.ny.gov/system/files/documents/2023/06/rev_rp_23a2_text_20230628.pdf (delineating cybersecurity risk management roles for an organization’s “senior governing body”).

⁸⁵ See Comments of CTIA, Proposed Second Amendment to Regulation 23 NYCRR 500, at 2 (filed Jan. 9, 2023) (“CTIA January 2023 NYDFS Comments”).

⁸⁶ Assessment of Public Comments on the Proposed Second Amendment to 23 NYCRR § 500, NYDFS, at 5 (June 28, 2023), https://www.dfs.ny.gov/system/files/documents/2023/06/rev_rp_23a2_apc_20230628.pdf.

⁸⁷ Eric Geller, *Biden tells governors to ‘take urgent action’ to protect infrastructure from Russian hackers*, Politico (Mar. 23, 2022), <https://www.politico.com/news/2022/03/23/biden-governors-infrastructure-russian-hackers-00019647>.

⁸⁸ See, e.g., Exec. Order No. 13873, 84 Fed. Reg. 22689 (May 17, 2019), <https://www.federalregister.gov/documents/2019/05/17/2019-10538/securing-the-information-and-communications-technology-and-services-supply-chain>; ICT Supply Chain Risk Management Task Force, CISA, <https://www.cisa.gov/resources-tools/groups/ict-supply-chain-risk-management-task-force> (last visited Oct. 20, 2023); *Protecting Against National Security Threats to the Communications Supply Chain through the Equipment Authorization Program*, *Protecting Against National Security Threats to the Communications Supply Chain through the Competitive Bidding Program*, Report and Order, Order, and Further Notice of Proposed Rulemaking, ET Docket No. 21-232, EA Docket No. 21-233, FCC 22-84 (rel. Nov. 25, 2022), <https://docs.fcc.gov/public/attachments/FCC-22-84A1.pdf>; Secure and Trusted Communications Networks Act of 2019, Pub. L. No. 116-124, 133 Stat. 158 (2020) (codified as amended at 47 U.S.C. §§ 1601–1609) (“SNA”); Secure Equipment Act of 2021, Pub. L. No. 117-55, 135 Stat. 423 (2021) (codified at 47 U.S.C. § 1601) (“SEA”); *Section 889 Policies*, Acquisition.gov, <https://www.acquisition.gov/Section-889-Policies> (last visited Oct. 20, 2023); Press Release, DOC, Commerce Department Further Restricts Huawei Access to U.S. Technology and Adds Another 38 Affiliates to the Entity List, (Aug. 17, 2020), <https://2017-2021.commerce.gov/news/press-releases/2020/08/commerce-department-further-restricts-huawei-access-us-technology-and.html>.

⁸⁹ See, e.g., *Request for Information; National Priorities for Artificial Intelligence*, Notice of Request for Information, 88 Fed. Reg. 34194 (May 26, 2023) (ONCD), <https://www.federalregister.gov/documents/2023/05/26/2023-11346/request-for-information-national-priorities-for-artificial-intelligence>; Artificial Intelligence Risk Management Framework (AI RMF 1.0), NIST (Jan. 2023), <https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.100-1.pdf>; *Trade Regulation Rule on Commercial Surveillance and Data Security*, Advance Notice of Proposed Rulemaking, 87 Fed. Reg. 51273, 51283-84 (Aug. 22, 2022), <https://www.federalregister.gov/documents/2022/08/22/2022-17752/trade-regulation-rule-on-commercial-surveillance-and-data-security> (FTC); *AI Accountability Policy Request for Comment*, Notice and Request for Comment, 88 Fed. Reg. 22433 (Apr. 14, 2023), <https://www.federalregister.gov/documents/2023/04/13/2023-07776/ai-accountability-policy-request-for-comment> (NTIA); *Request for Information and Comment on Financial Institutions’ Use of Artificial Intelligence, Including Machine Learning*, Request for Information and Comments, 86 Fed. Reg. 16837 (Mar. 31, 2021), <https://www.federalregister.gov/documents/2021/03/31/2021-06607/request-for-information-and-comment-on-financial-institutions-use-of-artificial-intelligence> (Board of Governors of the Federal Reserve System, the Consumer Financial Protection Bureau, the Federal Deposit Insurance Corporation, the National Credit Union Administration, and the Office of the Comptroller of the Currency); *Preliminary Rulemaking Activities on Cybersecurity Audits, Risk Assessments, and Automated Decisionmaking*, CPPA, https://cppa.ca.gov/regulations/pre_rulemaking_activities_pr_02-2023.html (last visited Oct. 20, 2023); A.B. 331, 2023-2024 Cal. Leg., Reg. Sess. (Cal. 2023); B25-0114, 2023-2024 Leg., 25th Council (D.C. 2023).

⁹⁰ See Joint Comments at 7-12.

⁹¹ Draft Report to the CISA Director, Corporate Cyber Responsibility, CISA Cybersecurity Advisory Committee, at 7, 9 (Sept. 13, 2023), available at https://cyberscoop.com/wp-content/uploads/sites/3/2023/09/CSAC_September-Quarterly-Meeting_Draft-Recommendations_20230913.pdf.

⁹² Cybersecurity Strategy at 8-9.

⁹³ See *Security Breach Notification Laws*, National Conference of State Legislatures (Jan. 17, 2022), <https://www.ncsl.org/research/telecommunications-and-information-technology/security-breach-notification-laws.aspx>.

⁹⁴ 45 C.F.R. §§ 164.400-414.

⁹⁵ 16 C.F.R. §§ 318.1-8.9.

⁹⁶ *Health Breach Notification Rule*, Notice of Proposed Rulemaking, 88 Fed. Reg. 37819, 37820 n.7 (June 9, 2023), <https://www.federalregister.gov/documents/2023/06/09/2023-12148/health-breach-notification-rule#footnote-7-p37820>.

⁹⁷ See generally CIRCIA.

⁹⁸ See RFI Questions 1(d), 1(f)-(h), 6(f), 7(c).

⁹⁹ See, e.g., Alex Gaynor, *Security Principles: Addressing underlying causes of risk in complex systems*, FTC (Feb. 1, 2023), <https://www.ftc.gov/policy/advocacy-research/tech-at-ftc/2023/02/security-principles-addressing-underlying-causes-risk-complex-systems>.

¹⁰⁰ See, e.g., Comments of U.S. Chamber of Commerce, Cybersecurity Risk Management, Strategy, Governance, and Incident Disclosure (File Number S7-09-22), at 7-8 (May 9, 2022), <https://www.sec.gov/comments/s7-09-22/s70922-20128398-291304.pdf>; Comments of Microsoft, Proposed SEC Cybersecurity Rules – (1) Regulation SCI (S7-07-23); (2) Proposed Rule 10 (S7-06-23); and (3) Regulation S-P (S7-05-23), at 1 (June 5, 2023), <https://www.sec.gov/comments/s7-07-23/s70723-199880-399982.pdf>.

¹⁰¹ Francesco Trebbi, et al., *The Cost of Regulatory Compliance in the United States*, USC Marshall School of Business Research Paper Sponsored by iORB, at 12-13 (Jan. 23, 2023), https://papers.ssrn.com/sol3/papers.cfm?abstract_id=4331146 (last revised July 11, 2023); see also Linda Gorman, Tracking the Cost of Complying with Government Regulation, The National Bureau of Economic Research: Digest, Issue, No. 2, (Feb. 2023), [https://www.nber.org/digest/20232/tracking-cost-complying-government-regulation#:~:text=The%20average%20US%20firm%20spends,\(NBER%20Working%20Paper%2030691\)](https://www.nber.org/digest/20232/tracking-cost-complying-government-regulation#:~:text=The%20average%20US%20firm%20spends,(NBER%20Working%20Paper%2030691)).

¹⁰² Bentley Coffey, et al., *The Cumulative Cost of Regulations*, at 8 (Mercatus Center at George Mason, Working Paper) (Apr. 2016), <https://www.mercatus.org/research/working-papers/cumulative-cost-regulations#:~:text=By%20altering%20investment%20decisions%20and,on%20American%20families%20and%20workers>.

¹⁰³ See, e.g., Standardized Regulatory Impact Assessment: California Consumer Privacy Act of 2018 Regulations, Attorney General's Office, California Department of Justice, at 11 (Aug. 2019), https://dof.ca.gov/wp-content/uploads/sites/352/Forecasting/Economics/Documents/CCPA_Regulations-SRIA-DOF.pdf.

¹⁰⁴ See Washington Legal Foundation's comment on CPPA Rulemaking, CPPA Public Comment at 35-100 (Aug. 18, 2022), https://cppa.ca.gov/regulations/pdf/comments_1_25.pdf#page=35; see also David Zetoony & Andrea Maciejewski, *California Proposed Privacy Regulations Would Impose Significant Compliance Costs On Business*, Washington Legal Foundation (Aug. 19, 2022), https://www.wlf.org/wp-content/uploads/2022/08/081922Zetoony_CA.pdf.

¹⁰⁵ Daniel Castro et al., *The Looming Cost of a Patchwork of State Privacy Laws*, Information Technology & Innovation Foundation (Jan. 24, 2022), <https://itif.org/publications/2022/01/24/looming-cost-patchwork-state-privacy-laws/>.

¹⁰⁶ *Cost of Compliance with CMMC and NIST-171*, HyperVigilance, <https://blog.hypervigilance.com/cost-of-cmmc-nist-compliance> (last visited Oct. 20, 2023) (explaining that companies largely compliant with NIST 800-171 can expect to spend \$35,000-\$100,000, and less mature organizations could spend \$40,000-\$130,000 in consulting and auditing plus \$100,000 in compliance remediation).

¹⁰⁷ *How much does it cost to get FedRAMP compliant and obtain an ATO?*, stackArmor, <https://stackarmor.com/how-much-does-it-cost-to-get-fedramp-compliant-and-obtain-an-ato/> (last updated 2023).

¹⁰⁸ See, e.g., Comments of CTIA, Draft NIST SP 800-171B, at 17-18 (Aug. 2, 2019), [https://csrc.nist.gov/CSRC/media/Projects/protecting-controlled-unclassified-information/documents/Comments-Draft-SP-800-171B-CTIA-2August2019\(1\).pdf](https://csrc.nist.gov/CSRC/media/Projects/protecting-controlled-unclassified-information/documents/Comments-Draft-SP-800-171B-CTIA-2August2019(1).pdf).

¹⁰⁹ See, e.g., Comments of Federally Funded Research and Development Centers InfoSec Collaborative, Draft NIST SP 800-171B, at 2 (Aug. 2, 2019), <https://csrc.nist.gov/CSRC/media/Projects/protecting-controlled-unclassified-information/documents/Comments-Draft-SP-800-171B-FFRDC-Navy-UARC-2August2019.pdf>; Comments of

University of California Los Angeles, Draft NIST SP 800-171B, at 2-3 (Aug. 2, 2019), <https://csrc.nist.gov/CSRC/media/Projects/protecting-controlled-unclassified-information/documents/Comments-Draft-SP-800-171B-UCLA-2August2019.pdf>; Comments of Council on Governmental Relations et al., Draft NIST SP 800-171B, at 4 (Aug. 2, 2019), <https://csrc.nist.gov/CSRC/media/Projects/protecting-controlled-unclassified-information/documents/Comments-Draft-SP-800-171B-ACE-AAU-APLU-COGR-EDU-2August2019.pdf>; *see generally* Comments of University of Southern California, Draft NIST SP 800-171B, at 4 (Aug. 2, 2019), <https://csrc.nist.gov/CSRC/media/Projects/protecting-controlled-unclassified-information/documents/Comments-Draft-SP-800-171B-USC-2August2019.pdf>.

¹¹⁰ *See supra* Section V.A.

¹¹¹ 6 U.S.C. § 1500(c)(1)(C)(v).

¹¹² Cybersecurity Information Sharing Act of 2015, Pub. L. No. 114-113, 129 Stat. 2936, <https://www.congress.gov/114/plaws/publ113/PLAW-114publ113.pdf> (codified at 6 U.S.C. §§ 1501-1510); *Information Sharing Groups*, Information Sharing and Analysis Organizations, <https://www.isao.org/information-sharing-groups/> (last visited Oct. 23, 2023).

¹¹³ NSTAC Report at 19.

¹¹⁴ *Id.*

¹¹⁵ *Id.*

¹¹⁶ *Id.*

¹¹⁷ *See id.* at 13.

¹¹⁸ Press Release, FCC, Chairwoman Rosenworcel to Lead Relaunched Federal Interagency Cybersecurity Forum (Feb. 3, 2022), <https://docs.fcc.gov/public/attachments/DOC-379926A1.pdf>; Jessica Rosenworcel, Chairwoman, FCC, Remarks to the Cybersecurity Forum of Independent and Executive Branch Regulators, at 2 (Apr. 8, 2022), <https://docs.fcc.gov/public/attachments/DOC-382215A1.pdf> (“Our chief objective now is to harmonize how private sector industries implement essential cybersecurity controls and how independent and executive branch regulatory agencies can ensure their work advances those efforts.”).

¹¹⁹ Implementation Plan at 12.

¹²⁰ *See* NSTAC Report at 24.

¹²¹ *See id.*

¹²² *See id.*

¹²³ *See id.*

¹²⁴ RFI Question 1(i), (j).

¹²⁵ *See, e.g.*, Comments of the Electronic Privacy Information Center (EPIC), FCC IB Docket No. 23-119, at 9 (Oct. 2, 2023), <https://www.fcc.gov/ecfs/document/10020478023650/1>.

¹²⁶ 6 U.S.C. § 1500(c)(1)(C)(v).

¹²⁷ *See* Memorandum from The White House on Renewing the National Security Council System (Feb. 4, 2021), <https://www.whitehouse.gov/briefing-room/statements-releases/2021/02/04/memorandum-renewing-the-national-security-council-system/>.

¹²⁸ Any policy conflict between departments and agencies could then be escalated through the Deputies and Principals Committee through the pre-existing NSM-2 process.

¹²⁹ Framework for Improving Critical Infrastructure Cybersecurity, Version 1.1, NIST, at 11 (Apr. 16, 2018), <https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.04162018.pdf> (“NIST CSF”).

¹³⁰ *Id.* at 3.

¹³¹ *Id.* at 6.

¹³² *Id.* at 14-15.

¹³³ NSTAC Report at 12.

¹³⁴ *Id.*

¹³⁵ *Id.*

¹³⁶ *Id.*

¹³⁷ *Id.*

¹³⁸ *Id.*

¹³⁹ See generally FFIEC, <https://www.ffiec.gov/> (last visited Oct. 23, 2023).

¹⁴⁰ *Id.*

¹⁴¹ *About the FFIEC*, FFIEC, <https://www.ffiec.gov/about.htm> (last visited Oct. 23, 2023) (“The Council is responsible for developing uniform reporting systems for federally supervised financial institutions, their holding companies, and the nonfinancial institution subsidiaries of those institutions and holding companies. It conducts schools for examiners employed by the five federal member agencies represented on the Council and makes those schools available to employees of state agencies that supervise financial institutions.”).

¹⁴² RFI Questions 3(a)(ii) and 3(c).

¹⁴³ National Technology Transfer and Advancement Act of 1995, Pub. L. No. 104-113, § 12(d)(1), 110 Stat. 775, 783 (1996), <https://www.govinfo.gov/content/pkg/PLAW-104publ113/pdf/PLAW-104publ113.pdf> (codified as amended at 15 U.S.C. § 272 note) (requiring agencies to use “technical standards that are developed or adopted by voluntary consensus standards bodies”) (“NTAA”); OMB Circular No. A-119, Federal Participation in the Development and Use of Voluntary Consensus Standards and in Conformity Assessment Activities, OMB, at 17 (2016), https://www.nist.gov/system/files/revised_circular_a-119_as_of_01-22-2016.pdf (“Consistent with Section 12 (d)(1) of the NTAA, all Federal agencies must use voluntary consensus standards in lieu of government-unique standards in their procurement and regulatory activities . . .”).

¹⁴⁴ See Emily S. Bremer, *Incorporation by Reference in an Open-Government Age*, 36 Harv. J.L. & Pub. Pol’y 131, 202 (2013), https://papers.ssrn.com/sol3/Delivery.cfm/SSRN_ID2205059_code926820.pdf?abstractid=2127288&mirid=1&type=2.

¹⁴⁵ *NIST Releases Cybersecurity Framework 2.0 Draft & Implementation Examples*, NIST (Aug. 8, 2023), <https://csrc.nist.gov/News/2023/nist-releases-cybersecurity-framework-2-0-draft>.

¹⁴⁶ CTIA has, however, in certain circumstances, supported requirement for cybersecurity plans to *reflect* the CSF, which is distinct from compliance generally.

¹⁴⁷ *Cybersecurity Performance Goals: Sector-Specific Goals*, CISA (July 26, 2023), <https://www.cisa.gov/news-events/news/cybersecurity-performance-goals-sector-specific-goals>.

¹⁴⁸ See, e.g., Comments of CTIA, NIST Cybersecurity Framework 2.0 Concept Paper: Potential Significant Updates to the Cybersecurity Framework (Mar. 6, 2023), https://www.nist.gov/system/files/documents/2023/04/04/2023-03-06%20CTIA_508_Redacted.pdf; Comments of CTIA, Discussion Draft of the NIST Cybersecurity Framework 2.0 Core (May 31, 2023), https://www.nist.gov/system/files/documents/2023/08/04/CTIA%20Comments%2005312023%20Discussion%20Draft_Redacted.pdf; CTIA Letter Comments; Joint Comments; Comments of CTIA, Cross-Sector Cybersecurity Performance Goals and Objectives, GitHub Submission (Feb. 15, 2023).

¹⁴⁹ Troy Fine, *Budgeting for SOC 2: How Much Does a SOC 2 Audit Cost?*, Drata (May 20, 2022), <https://drata.com/blog/soc-2-audit-cost> (“The audit alone for a small to midsize company for SOC 2 Type 2 reports costs an average of \$12,000 to \$20,000. For large organizations, total costs can range from \$30,000 to \$100,000.” and, “[m]any companies don’t consider the loss of productivity on other projects early on. The main reason is that it isn’t a readily apparent expenditure to account for. It’s hard to know exactly how much these costs will add up to, but being aware of this is key to not falling behind in other parts of the business.”).

¹⁵⁰ Mimi Pham, *How to Achieve ISO 27001: Everything You Need to Know to Pass the Audit*, Security Boulevard (June 7, 2023), <https://securityboulevard.com/2023/06/how-to-achieve-iso-27001-everything-you-need-to-know-to-pass-the-audit/>.

¹⁵¹ See e.g., Blake Curtis, *Technical competency gaps in 151,000 IT auditors in the audit industry*, Security Magazine

(Nov. 1, 2022), <https://www.securitymagazine.com/articles/98555-technical-competency-gaps-in-151-000-it-auditors-in-the-audit-industry>.

¹⁵² Draft Cybersecurity Audit Regulations for California Privacy Protection Agency September 8, 2023 Board Meeting, CPPA (Sept. 8, 2023), <https://cppa.ca.gov/meetings/materials/20230908item8.pdf>.

¹⁵³ See *id.* §§ 7001, 7120.

¹⁵⁴ Revised Proposed Second Amendment to 23 NYCRR 500, NYDFS, § 500.2(c) (June 28, 2023), https://www.dfs.ny.gov/system/files/documents/2023/06/rev_rp_23a2_text_20230628.pdf.

¹⁵⁵ See, e.g., Chegg, Inc., Decision and Order, Docket No. C-4782, §§ VI and VII (Jan. 25, 2023) (requiring Chegg to obtain biennial information security assessments by a third party),

https://www.ftc.gov/system/files/ftc_gov/pdf/Chegg-DecisionandOrder.pdf; Drizly, LLC, & James Cory Rellas, Decision and Order, Docket No. C-4780, Exhibit B, §§ V and VI (Jan. 9, 2023) (requiring same for Drizly),

https://www.ftc.gov/system/files/ftc_gov/pdf/2023185-drizly-combined-consent.pdf; Residual Pumpkin Entity, LLC & Planetart, LLC, Decision and Order, Docket No. C-4768, §§ III and IV (requiring same for Residual Pumpkin Entity, LLC) (June 23, 2022),

https://www.ftc.gov/system/files/ftc_gov/pdf/192%203209%20-%20CafePress%20combined%20package%20without%20signatures.pdf; Ascension Data & Analytics, LLC,

Decision and Order, Docket No. C-4758, §§ III and IV (requiring same) (Dec. 22, 2021),

<https://www.ftc.gov/system/files/documents/cases/1923126c4758ascensionorder.pdf>.

¹⁵⁶ The Options Clearing Corporation, Order Instituting Administrative and Cease-and-Desist Proceedings Pursuant to Sections 19(H) and 21c of the Securities Exchange Act of 1934, Making Findings, and Imposing Remedial Sanctions and a Cease-and-Desist Order, File No. 3-19416 (Sept. 4, 2019),

<https://www.sec.gov/files/litigation/admin/2019/34-86871.pdf>.

¹⁵⁷ Security Directive Pipeline-2-21-02D, Pipeline Cybersecurity Mitigation Actions, Contingency Planning, and Testing (July 27, 2023), [https://www.tsa.gov/sites/default/files/tsa-sd-pipeline-2021-02d-w-](https://www.tsa.gov/sites/default/files/tsa-sd-pipeline-2021-02d-w-memo_07_27_2023.pdf)

[memo_07_27_2023.pdf](https://www.tsa.gov/sites/default/files/sd-1580-21-01b-enhancing-rail-cybersecurity.pdf); Security Directive 1580-21-01B, Enhancing Rail Cybersecurity, TSA (Oct. 23, 2023), <https://www.tsa.gov/sites/default/files/sd-1580-21-01b-enhancing-rail-cybersecurity.pdf>.

¹⁵⁸ *The Uniendo a Puerto Rico Fund and the Connect USVI Fund; Connect America Fund*, Report and Order and Order on Review, WC Docket Nos. 18-143, 10-90, FCC 23-32, ¶¶ 33-34, § 54.1522 (rel. Apr. 19, 2023),

<https://docs.fcc.gov/public/attachments/FCC-23-32A1.pdf>.

¹⁵⁹ NIST CSF at 20-21.

¹⁶⁰ RFI Questions 2(g), 2(h).

¹⁶¹ RFI Question 8(a).

¹⁶² Ohio Rev. Code Ann. §§ 1354.01-.05.

¹⁶³ Utah Code Ann. §§ 78B-4-701 to 706.

¹⁶⁴ See, e.g., Va. Code Ann. § 18.2-186.6(B); Mass. Gen. Laws Ann. ch. 93H § 4.

¹⁶⁵ See, e.g., Va. Code Ann. § 18.2-186.6(B); Wash. Rev. Code Ann. § 19.255.010(8).

¹⁶⁶ RFI Question 6(c) asks, “To what extent, if any, are you aware that the agencies engaged in cybersecurity oversight of the same IT or OT infrastructure coordinate their oversight activities? Please describe.” RFI Question 6(i) asks, “Please provide examples of regulatory reciprocity between two or more Federal agencies with respect to cybersecurity, including the recognition or acceptance by one regulatory agency of another agency’s assessment, determination, finding, or conclusion with respect to the extent of a regulated entity’s compliance with certain IT or OT cybersecurity requirements.”

¹⁶⁷ FCC-FTC Consumer Protection Memorandum of Understanding (Nov. 2015),

<https://docs.fcc.gov/public/attachments/DOC-336405A1.pdf>; Restoring Internet Freedom FCC-FTC Consumer Protection Memorandum of Understanding (Dec. 2017), <https://docs.fcc.gov/public/attachments/DOC-348275A1.pdf>.

¹⁶⁸ RFI Question 6(h).

¹⁶⁹ Joint Comments at 17-21.

¹⁷⁰ RFI Question 8.

¹⁷¹ Cal. Civ. Code § 1798.91.04-06; see also Cal. Civ. Code §§ 1798.81.5, 1798.100.

¹⁷² N.Y. Comp. Codes R. & Regs. tit. 23, §§ 500.0-500.23; Revised Proposed Second Amendment to 23 NYCRR 500, NYDFS (June 28, 2023), https://www.dfs.ny.gov/system/files/documents/2023/06/rev_rp_23a2_text_20230628.pdf.

¹⁷³ Revised Proposed Second Amendment to 23 NYCRR 500, NYDFS, § 500.12(a) (June 28, 2023), https://www.dfs.ny.gov/system/files/documents/2023/06/rev_rp_23a2_text_20230628.pdf.

¹⁷⁴ *Id.* § 500.7(c)(1).

¹⁷⁵ *Id.* § 500.14(b).

¹⁷⁶ Assessment of Public Comments on the Proposed Second Amendment to 23 NYCRR § 500, NYDFS, at 9-10 (June 28, 2023), https://www.dfs.ny.gov/system/files/documents/2023/06/rev_rp_23a2_apc_20230628.pdf.

Commenters argued that DFS should “explicitly exclude information systems that do not process or hold information related to financial products or limit the scope of Part 500 to the portion of the business related to an activity regulated by the Department,” and that DFS “is creating requirements that are unique to New York for an issue that extends beyond the borders of New York State.”

¹⁷⁷ CTIA January 2023 NYDFS Comments, at 26.

¹⁷⁸ NYDFS, Consent Order, In the Matter of Carnival Corporation d/b/a Carnival Cruise Line, (June 23, 2022), https://www.dfs.ny.gov/system/files/documents/2022/06/ea20220623_carnival_co.pdf (imposing a fine and surrender of licenses for four security incidents that involved phishing and ransomware, and compromised some customer data).

¹⁷⁹ See, e.g., *Ickes v. FAA*, 299 F.3d 260, 263 (3d Cir. 2002) (“It is beyond dispute that Congress’s power over interstate commerce includes the power to regulate use of the nation’s navigable airspace, which is a channel of interstate commerce.”); *Fed. Radio Comm’n v. Nelson Bros. Bond & Mortg. Co.*, 289 U.S. 266, 279 (1933) (“No question is presented as to the power of the Congress, in its regulation of interstate commerce, to regulate radio communications. No state lines divide the radio waves, and national regulation is not only appropriate but essential to the efficient use of radio facilities.”).

¹⁸⁰ U.S. Constitution, Article VI, § 2.

¹⁸¹ See, e.g., *Geier v. American Honda Motor Co.*, 529 U.S. 861 (2000).

¹⁸² For instance, the Federal Communications Commission frequently identifies where state and local regulations would be preempted. See, e.g., 47 C.F.R. §§ 25.104 (state and local regulations that impact the installation of certain satellite earth stations and that fail to meet certain enumerated policy objectives); 1.4000 (state and local regulations that impair the installation or use of a consumer-end antenna).

¹⁸³ What We Urge You To Do To Protect Against The Threat of Ransomware, The White House (June 2, 2021), [Memo-What-We-Urge-You-To-Do-To-Protect-Against-The-Threat-of-Ransomware.pdf](https://www.whitehouse.gov/wp-content/uploads/2021/06/What-We-Urge-You-To-Do-To-Protect-Against-The-Threat-of-Ransomware.pdf) ([whitehouse.gov](https://www.whitehouse.gov)).

¹⁸⁴ United States Government National Standards Strategy for Critical and Emerging Technology, The White House (May 2023), <https://www.whitehouse.gov/wp-content/uploads/2023/05/US-Gov-National-Standards-Strategy-2023.pdf#:~:text=This%20strategy%20outlines%20how%20the%20U.S.%20Government%20will,consensus%2C%20effectiveness%20and%20relevance%2C%20coherence%2C%20and%20broad%20participation> (“National Standards Strategy”).

¹⁸⁵ NSTAC Report at 8.

¹⁸⁶ *Id.* (citing Microsoft Digital Defense Report 2022, Microsoft, at 59, <https://query.prod.cms.rt.microsoft.com/cms/api/am/binary/RE5bUvv?culture=en-us&country=us> (last updated June 2022)). The countries comprising the EU are counted as one jurisdiction for this figure because their inclusion was primarily based on the EU’s efforts while updating its Network and Information Security (“NIS”) Directive during the timeframe.

¹⁸⁷ See generally National Standards Strategy.

¹⁸⁸ *Id.* at 6-7.

¹⁸⁹ For the purposes of Appendix D, a compliance offering can be a certification, attestation, law, regulation,

standard or framework. NSTAC Report at 11.

¹⁹⁰ APEC, <https://www.apec.org/> (last visited Oct. 24, 2023).

¹⁹¹ ASEAN, <https://asean.org/> (last visited Oct. 24, 2023).

¹⁹² U.S.-E.U. Trade and Technology Council (TTC), Office of the U.S. Trade Representative, <https://ustr.gov/useuttc> (last visited Oct. 24, 2023).

¹⁹³ Press Release, CISA, U.S. and International Cybersecurity Partners Warn Organizations of Routinely Exploited Vulnerabilities (Aug. 3, 2023), <https://www.cisa.gov/news-events/news/us-and-international-cybersecurity-partners-warn-organizations-routinely-exploited-vulnerabilities>.

¹⁹⁴ *How we work*, OECD, <https://www.oecd.org/about/how-we-work/> (last visited Oct. 23, 2023).

¹⁹⁵ *The Global Forum on Digital Security for Prosperity, Past Events*, OECD, <https://www.oecd.org/digital/global-forum-digital-security/events/> (last visited Oct. 23, 2023).

¹⁹⁶ *From raising awareness to changing policies: The OECD's digital security recommendations explained*, OECD, <https://www.oecd.org/digital/digital-security/> (last visited Oct. 23, 2023).

¹⁹⁷ *Open-ended Working Group*, U.N. Office of Disarmament Affairs, <https://disarmament.unoda.org/open-ended-working-group/> (last visited Oct. 23, 2023).

¹⁹⁸ *See About the GFCE*, GFCE, <https://thegfce.org/about-the-gfce/> (last visited Oct. 23, 2023).

¹⁹⁹ About SG17, ITU, <https://www.itu.int/en/ITU-T/about/groups/2022-2024/Pages/sg17.aspx> (last visited Oct. 24, 2023).

²⁰⁰ See Cynthia Brumfield, *Why NIST is so popular in Japan*, CyberScoop (Nov. 8, 2018), <https://cyberscoop.com/nist-japan-workforce/>; *Success Story: Japanese Cross-Sector Forum*, NIST (Oct. 15, 2018), <https://www.nist.gov/cyberframework/success-stories/japanese-cross-sector-forum> (last updated Dec. 8, 2021); Mihoko Matsubara, *Japanese Cross-Sector Industry Forum Is Shaping Cybersecurity Talent Development Strategy*, New America (June 27, 2019), <https://www.newamerica.org/cybersecurity-initiative/c2b/c2b-log/japanese-cross-sector-industry-forum-shaping-cybersecurity-talent-development-strategy/>.

²⁰¹ RFI Question 7(a) asks, “Please provide specific examples of conflicting, mutually exclusive, or inconsistent cybersecurity regulatory requirements that are passed along by contract to third-party service providers.” RFI Question 7(d) asks, “Describe any two or more conflicting, mutually exclusive, or inconsistent regulation, one of which permits the use of cloud, while another does not. How does this impact your sector? Explain if these requirements also restrict the use of Managed Security Service Providers (MSSPs) and security tools that utilize the cloud.”

²⁰² DFARS 239.7602.1(b)(1).

²⁰³ DFARS 239.76; DFARS 252.239-7010.

²⁰⁴ *Program Basics*, FedRAMP, <https://www.fedramp.gov/program-basics/> (last visited Oct. 24, 2023).

²⁰⁵ Billy Mitchell, *CMMC final rulemaking process kicks off with submission to OMB for review*, DefenseScoop (July 25, 2023), <https://defensescoop.com/2023/07/25/cmmc-final-rulemaking-process-kicks-off-with-submission-to-omb-for-review/>.

²⁰⁶ Solicitation for Public Comments on the Business Practices of Cloud Computing Providers, Docket No. FTC-2023-0028-0001 (Mar. 22, 2023), <https://www.regulations.gov/document/FTC-2023-0028-0001>.

²⁰⁷ See, e.g., Cal. Civ. Code § 1798.100(d); Va. Code Ann. § 59.1-579; Colo. Rev. Stat. § 6-1-1305; Utah § 13-61-301; Conn. Gen. Stat. § 42-521; S.F. 262, 90th Gen. Assemb., Reg. Sess. § 5 (Iowa 2023) (effective Jan. 1, 2023); S.B. 5, 123rd Gen. Assemb., 1st Reg. Sess. ch. 5 (Ind. 2023) (effective date Jan. 1, 2026); H.B. 1181, 113th Gen. Assemb., Reg. Sess., § 47-18-3205 (Tenn. 2023) (effective July 1, 2025); H.B. 0384, 68th Leg., Reg. Sess., § 8 (Mont. 2023) (effective date Oct. 2024); Tex. Bus. & Com. Code Ann. § 542.104 (effective July 1, 2024); S.B. 619, 82 Leg. Assemb., Reg. Sess., § 6 (Or. 2023) (effective Jan. 1, 2024).

Appendix A: RFI Questions Answered in CTIA Comments

RFI Question		CTIA Answer
1	1.a.	CTIA responds generally to Question 1 at Section III.B.
	1.b.	
	1.c.	
	1.d.	CTIA responds to this question at Section III.C.
	1.e.	CTIA responds to this question at Section III.B.
	1.f.	CTIA responds to this question at Section III.C.
	1.g.	CTIA responds to this question at Section III.C.
	1.h.	CTIA responds to this question at Section III.C.
	1.i.	CTIA responds to this question at Section III.E.
	1.j.	CTIA responds to this question at Section III.E.
2	2.a.	CTIA responds generally to Question 2 at Section IV.B.
	2.b.	
	2.c.	
	2.d.	
	2.e.	
	2.f.	
	2.g.	CTIA responds to this question at Section V.C.
	2.h.	CTIA responds to this question at Section V.C.
3	3.a.	CTIA responds generally to Question 3 at Section IV.A.1.
	3.a.i.	
	3.a.ii.	CTIA responds to this question at Section V.A.
	3.b.	CTIA responds to this question at Section V.B.
	3.c.	CTIA responds to this question at Sections V.A.
4	4.a.	CTIA responds generally to Question 4 at Section IV.A.1.
	4.b.	
5	5.a.	CTIA responds to this question at Section V.D.
	5.b.	CTIA responds to this question at Section V.D.
6	6.a.	CTIA responds to this question at Section III.A.
	6.b.	CTIA responds to this question at Section III.A.
	6.c.	CTIA responds to this question at Section VI.B.
	6.d.	
	6.d.i.	
	6.d.ii.	
	6.d.iii.	
	6.e.	
	6.f.	CTIA responds to this question at Section III.C.
	6.g.	CTIA responds to this question at Section V.B.
	6.h.	CTIA responds to this question at Section VI.C.
	6.i.	CTIA responds to this question at Section VI.B.
	6.j.	
	6.k.	
	6.l.	CTIA responds to this question at Section V.C.

	6.l.i	
	6.l.ii.	
7	7.a.	CTIA responds to this question at Section IX.
	7.b.	
	7.c.	CTIA responds to this question at Section III.C.
	7.d.	CTIA responds to this question at Section IX.
	7.e.	CTIA responds to this question at Section VIII.
	7.f.	
	7.g.	CTIA responds to this question at Section III.B.
8	8.a.	CTIA responds generally to Question 8 at Section VII. CTIA responds to this question at Section VI.A.
	8.b.	
	8.c.	
	8.d.	
9	9.a.	
	9.b.	CTIA responds to this question at Section VIII.
	9.c.	CTIA responds to this question at Section VIII.
	9.d.	CTIA responds to this question at Section VIII.
	9.e.	

Appendix B: Wireless Provider Cybersecurity Practices

CTIA members already utilize best-practice standards and third-party frameworks, such as the NIST CSF, in their cybersecurity policies and practices. For example, among other cybersecurity practices:

AT&T:

- AT&T's Security Policy and Requirements "is a comprehensive set of security control standards based, in part, on leading industry standards such as ISO/IEC 27001:2013."¹ AT&T regularly re-evaluates and modifies the content of the policy "as industry standards evolve and as circumstances require."²
- AT&T has implemented a comprehensive security program derived from ISO 27001 and other industry best practices.³
- "AT&T scientists and engineers conduct research in a variety of areas, including IP networking, advanced network design and architecture, network and cyber security, network operations support systems and data analytics."⁴

T-Mobile:

- T-Mobile incorporates "core functions from the widely recognized National Institute of Standards and Technology (NIST) Cybersecurity Framework into [its cybersecurity] program."⁵
- T-Mobile regularly assesses cybersecurity risks and processes, including independent testing and monitoring of cybersecurity systems, and conducting external assessments and certifications required for compliance.⁶
- T-Mobile has commenced a substantial multi-year investment, working with leading external cybersecurity experts to enhance its cybersecurity capabilities and transform its approach to cybersecurity.⁷

UScellular:

- UScellular commits in its Privacy Principles "to protecting the privacy and security of [customer] information."⁸

¹ *Network & Data Security*, AT&T, <https://about.att.com/csr/home/reporting/issue-brief/network-data-security.html> (last visited Oct. 20, 2023).

² *Id.*

³ ESG Summary: March 2022, AT&T, at 10 (Mar. 2022), <https://about.att.com/ecms/dam/csr/2019/library/corporate-responsibility/ATT-ESG-Summary-March-2022.pdf>.

⁴ Annual Report on Form 10-K of AT&T Inc., at 4 (filed Feb. 13, 2023), <https://otp.tools.investis.com/clients/us/atnt2/sec/sec-show.aspx?FilingId=16393783&Cik=0000732717&Type=PDF&hasPdf=1>.

⁵ Connecting with Purpose: 2022 Corporate Responsibility Report, T-Mobile, at 19 (2023), https://www.t-mobile.com/content/dam/digx/tmobile/us/en/non-dynamic-media/pdf/T-Mobile-2022-Corporate-Responsibility-Report.pdf?icid=MGPO_TMO_U_TMOCPSOCRS_7UL48HP17ITX58D5Q3455.

⁶ *Id.*

⁷ Annual Report on Form 10-K of T-Mobile US, Inc., at 31 (filed Feb. 14, 2023), <https://d18rn0p25nwr6d.cloudfront.net/CIK-0001283699/ccabcf9-20c2-4528-8955-8aaf7dc6d2c2.pdf>.

⁸ Privacy Center: Our Privacy Principles, UScellular, <https://www.uscellular.com/privacy> (last visited Oct. 20, 2023).

- UScellular’s security safeguards are based on the Center for Internet Security's Critical Security Controls to protect against such risks as loss, unauthorized access, destruction, use, modification, or disclosure of information. UScellular uses a variety of commercially reasonable and appropriate safeguards to protect information residing on its systems including, without limitation, server firewalls and physical facility security.⁹
- In 2022, UScellular’s full board of directors was included in a tabletop exercise aimed at testing the preparedness of the organization for a large-scale cyber event.¹⁰

Verizon:

- Verizon issues a yearly Data Breach Investigations Report to help organizations protect themselves from security threats.¹¹
- Verizon’s Corporate Information Security Program implements “administrative, technical and physical safeguards that help to protect the confidentiality, integrity and availability of systems, networks, and information.”¹²
- Verizon’s enterprise-wide Information Security Policy is aligned with the NIST CSF.¹³
- Annually, Verizon is assessed by an external Qualified Security Assessor across the broad Payment Card Industry data security standard requirements. Verizon’s Global Network Management Cybersecurity Center is ISO 9001:2015 and ISO 27001:2013 certified and is subject to yearly audits by a third-party assessor. Every two years, Verizon engages “in an enterprise-wide NIST CSF maturity assessment conducted by an independent third-party assessor, the results of which are presented to its Board of Directors.”¹⁴

CTIA members are leaders in implementing a variety of cybersecurity control-based standards while assessing risks and substantially investing in preventative measures to protect privacy and the security of their customers’ information.

⁹ 2023 Proxy Statement at 17, UScellular (Apr. 4, 2023), https://s24.q4cdn.com/321867585/files/doc_financials/2022/ar/2023-Final-USM-Proxy.pdf.

¹⁰ *Id.*

¹¹ Data Breach Investigations Report 2023, Verizon, available at <https://www.verizon.com/business/resources/reports/dbir/>.

¹² *Verizon Security Summary*, Verizon, <https://www.verizon.com/about/privacy/verizon-internal-systems-information-security-exhibit> (last visited Oct. 20, 2023).

¹³ Environmental, Social, and Governance (ESG) Report 2022, Verizon, at 57 (2022), <https://www.verizon.com/about/sites/default/files/Verizon-2022-ESG-Report.pdf>.

¹⁴ *Id.* at 58.

APPENDIX C: BURGEONING CYBERSECURITY OBGLIGATIONS AND OVERSIGHT AFFECTING ORGANIZATIONS IN THE UNITED STATES

This chart highlights notable domestic and international efforts to govern, regulate, or otherwise establish requirements or best practices for cybersecurity. It is not comprehensive but illustrative.

Federal Departments or Agencies			
Federal Department or Agency	Focus	Activity (e.g., regulations, standards, best practices, reports)	Cited Authority for Creation or Operation ¹
Department of Commerce (DoC)/National Institute of Standards and Technology (NIST)	NIST is a non-regulatory federal agency within the U.S. Department of Commerce. NIST’s mission is to promote U.S. innovation and industrial competitiveness by advancing measurement science, standards, and technology in ways that enhance economic security and improve quality of life.	General Cybersecurity Risk Management Guidance and Controls: - Cybersecurity Framework 1.1 (Apr. 16, 2018), https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.04162018.pdf - Draft Cybersecurity Framework 2.0 (NIST CSWP 29), Initial Public Draft (published: Aug. 8, 2023; comments due: Nov. 4, 2023), https://csrc.nist.gov/pubs/cswp/29/the-nist-cybersecurity-framework-20/ipd - Security and Privacy Controls for Information Systems and Organizations, NIST SP 800-53, Revision 5 (Sept. 2020), https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r5.pdf - Initial Working Draft, Performance Measurement Guide for Information Security, NIST SP 800-55 Rev. 2 (Nov. 14, 2022), https://csrc.nist.gov/pubs/sp/800/55/r2/iwd Cybersecurity Supply Chain Risk Management: - NISTIR 8276, Key Practices in Cyber Supply Chain Risk Management (C-SCRM): Observations from Industry (Feb. 2021), https://nvlpubs.nist.gov/nistpubs/ir/2021/NIST.IR.8276.pdf - NIST SP 800-161 Rev. 1, Cybersecurity Supply Chain Risk Management Practices for Systems and Organizations (May 2022), https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-161r1.pdf IoT Cybersecurity: - NISTIR 8259 Series: NISTIR 8259, Recommendations for IoT Device Manufacturers: Foundational Activities (May 29, 2020), https://nvlpubs.nist.gov/nistpubs/ir/2020/NIST.IR.8259.pdf; NISTIR 8259A, Core Device Cybersecurity Capability Baseline (May 29, 2020), https://nvlpubs.nist.gov/nistpubs/ir/2020/NIST.IR.8259A.pdf; NISTIR 8259B, IoT Non-Technical Supporting Capability Core Baseline (Aug. 25, 2021), https://nvlpubs.nist.gov/nistpubs/ir/2021/NIST.IR.8259B.pdf - NISTIR 8425, Profile of the IoT Core Baseline for Consumer IoT Products (Sept. 2022), https://nvlpubs.nist.gov/nistpubs/ir/2022/NIST.IR.8425.pdf - Preliminary Drafts: Trusted IoT Device Network-Layer Onboarding and Lifecycle Management, NIST SP 1800-36 series (May 2023), https://www.nccoe.nist.gov/projects/trusted-iot-device-network-layer-onboarding-and-lifecycle-management Zero Trust: - Preliminary Drafts: Implementing a Zero Trust Architecture, SP 1800-35 series (Dec. 2022), https://www.nccoe.nist.gov/projects/implementing-zero-trust-architecture Trustworthy AI Risk Management: - AI Risk Management Framework, NIST AI 100-1, (Jan. 2023), https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.100-1.pdf Digital Identities/Authentication: - Digital Identity Guidelines, NIST SP 800-63, Revision 3 series (June 2017), https://pages.nist.gov/800-63-3/; - Digital Identity Guidelines, Draft Revision 4, NIST SP 800-63-4 (released Dec. 16, 2022), https://csrc.nist.gov/pubs/sp/800/63/4/ipd	National Institute of Standards and Technology, 15 U.S.C. ch. 7 Cybersecurity Enhancement Act of 2014, Pub. L. 113-274 (2014) (relevant parts codified at 15 U.S.C. § 272(e)(1)(A)(i)) EO 13800, Strengthening the Cybersecurity of Federal Networks and Critical Infrastructure (May 11, 2017), https://www.federalregister.gov/documents/2017/05/16/2017-10004/strengthening-the-cybersecurity-of-federal-networks-and-critical-infrastructure EO 13636, Improving Critical Infrastructure Cybersecurity (Feb. 12, 2013), https://obamawhitehouse.archives.gov/the-press-office/2013/02/12/executive-order-improving-critical-infrastructure-cybersecurity

¹ Inclusion here of a statute does not suggest that the statute authorizes or governs the activities described. Many agencies are engaged in novel activities, some under claimed emergency authorities or otherwise promoting cyber policy goals that may or may not be within their traditional expertise and authorizations.

Federal Departments or Agencies			
Federal Department or Agency	Focus	Activity (e.g., regulations, standards, best practices, reports)	Cited Authority for Creation or Operation ¹
		ICT and Communications Sector-Specific Risk Management: - Draft 5G Cybersecurity, NIST SP 1800-33 series (Feb. 2021), https://www.nccoe.nist.gov/5g-cybersecurity - Second Draft: Mobile Device Security: Bring Your Own Device (BYOD), NIST SP 1800-22 series (Nov. 2022), https://www.nccoe.nist.gov/mobile-device-security/bring-your-own-device - Initial Public Draft, NIST SP 800-221, Enterprise Impacts of Information and Communications Technology Risk: Governing and Managing ICT Risk Programs Within an Enterprise Risk Portfolio (July 20, 2022), https://csrc.nist.gov/pubs/sp/800/221/ipd; Initial Public Draft, Information and Communications Technology (ICT) Risk Outcomes: Integrating ICT Risk Management Programs with the Enterprise Risk Portfolio (July 20, 2022), https://csrc.nist.gov/pubs/sp/800/221/a/ipd Other/Reports: - Automation Support for Security Control Assessments, NISTIR 8011 series (June 2017), https://csrc.nist.gov/pubs/ir/8011/v1/final - NIST Privacy Framework: A Tool for Improving Privacy through Enterprise Risk Management, Version 1.0 (Jan. 2020), https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.01162020.pdf - Protecting Controlled Unclassified Information in Nonfederal Systems and Organizations, NIST SP 800-171 Rev. 2 (Feb. 2020), https://csrc.nist.gov/pubs/sp/800/171/r2/upd1/final; - Initial Public Draft, NIST SP 800-171 Rev. 3 (May 10, 2023), https://csrc.nist.gov/pubs/sp/800/171/r3/ipd - Foundational PNT Profile: Applying the Cybersecurity Framework for the Responsible Use of Positioning, Navigation, and Timing (PNT) Services, NISTIR 8323 Rev. 1 (Jan. 2023), https://nvlpubs.nist.gov/nistpubs/ir/2023/NIST.IR.8323r1.pdf - Recommendations for Federal Vulnerability Disclosure Guidelines, NIST SP 800-216 (May 2023), https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-216.pdf - FY 2022 Cybersecurity and Privacy Annual Report, NIST SP 800-225 (May 2023), https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-225.pdf - NIST’s Post-Quantum Cryptography Project, https://csrc.nist.gov/projects/post-quantum-cryptography	
DoC/National Telecommunications and Information Administration (NTIA)	NTIA was formed by combining the Office of Telecommunications Policy of the Executive Office of the President and the Office of Telecommunications of the Department of Commerce to form a new agency reporting to the Secretary of Commerce. The agency is principally responsible for advising the President on telecommunications and information policy issues. NTIA is responsible for fostering national safety and security, economic prosperity, and the delivery of critical social services through telecommunications. NTIA advises the President on telecommunications and information policy issues. The		Reorganization Plan No. 1 of 1978, (5 U.S.C. app) EO 12046, Relating to the Transfer of Telecommunications Functions (March 26, 1978), https://www.archives.gov/federal-register/codification/executive-order/12046.html National Telecommunications and Information Administration Organization Act, Telecommunications Authorization Act of 1992, Pub. L. 102-538, 106 Stat. 3533 (October 27, 1992) (codified at 47 U.S.C. 901)

Federal Departments or Agencies			
Federal Department or Agency	Focus	Activity (e.g., regulations, standards, best practices, reports)	Cited Authority for Creation or Operation ¹
	agency also manages federal use of spectrum and administers grant programs.		
	NTIA has promulgated several cybersecurity requirements in recent Notices of Funding Opportunity (NOFOs).	Broadband Equity, Access, and Deployment Program Notice of Funding Opportunity, at 70 (May 2022), https://broadbandusa.ntia.doc.gov/sites/default/files/2022-05/BEAD%20NOFO.pdf Wireless Innovation Fund Notice of Funding Opportunity, at 23-24 (June 2023), https://ntia.gov/sites/default/files/publications/pwscif_final_nofo.pdf	
Department of Defense (DoD)	DoD is the largest government agency and coordinates activities related to national security and the U.S. Armed Forces.		10 U.S.C. § 101, et seq.
	DoD’s Defense Federal Acquisition Regulation Supplement (DFARS) supplements the Federal Acquisition Regulation (FAR), which governs the acquisition processes for the agency. DFARS contains provisions that govern the use of certain types of information handling by contractors.	DFARS 252.204-7012 (https://www.acquisition.gov/dfars/252.204-7012-safeguarding-covered-defense-information-and-cyber-incident-reporting) - Requires compliance with NIST SP 800-171; cyber incident reporting within 72 hours DFARS 252.204-7019 (https://www.acquisition.gov/dfars/252.204-7019-notice-nistsp-800-171-dod-assessment-requirements) - Notice of NIST SP 800-171 DoD Assessment Requirements. If the Offeror is required to implement NIST SP 800-171, the Offeror shall have a current assessment (i.e., not more than 3 years old unless a lesser time is specified in the solicitation) (see 252.204-7020) for each covered contractor information system that is relevant to the offer, contract, task order, or delivery order. DFARS 252.204-7020 (https://www.acquisition.gov/dfars/252.204-7020-nist-sp-800-171-dod-assessment-requirements); DoD 8570.01-M, https://www.cool.osd.mil/usn/ia_documents/DoD_8570.01M.pdf - NIST SP 800-171 DoD Assessment Requirements. The Contractor shall provide access to its facilities, systems, and personnel necessary for the Government to conduct a Medium or High NIST SP 800-171 DoD Assessment, as described in NIST SP 800-171 DoD Assessment Methodology at https://www.acq.osd.mil/asda/dpc/cp/cyber/safeguarding.html#nistSP800171, if necessary. - Summary level scores for all assessments will be posted in the Supplier Performance Risk System (SPRS) to provide DoD Components visibility into the summary level scores of strategic assessments. DFARS 252.239-7001 (https://www.acquisition.gov/dfars/252.239-7001-information-assurance-contractor-training-and-certification) - Information Assurance Contractor Training and Certification (a) The Contractor shall ensure that personnel accessing information systems have the proper and current information assurance certification to perform information assurance functions in accordance with DoD 8570.01-M, Information Assurance Workforce Improvement Program. The Contractor shall meet the applicable information assurance certification requirements, including— (1) DoD-approved information assurance workforce certifications appropriate for each category and level as listed in the current version of DoD 8570.01-M; and (2) Appropriate operating system certification for information assurance technical positions as required by DoD 8570.01-M. DFARS 252.239-7999 (https://www.acq.osd.mil/dpap/policy/policyvault/USA001321-15-DPAP.pdf) - Class Deviation 2015-O0011 - Contracting for Cloud Services: The Contractor shall adopt and maintain administrative, technical, and physical safeguards and controls that are required for the security level and services being provided, in accordance with the Cloud Computing Security Requirements Guide (SRG) (version in effect at the time of contract award), available at https://public.cyber.mil/dccs/dccs-documents/ Cybersecurity Maturity Model Certification (CMMC) 2.0 (<i>rulemaking pending</i>) (https://dodcio.defense.gov/CMMC/)	

Federal Departments or Agencies			
Federal Department or Agency	Focus	Activity (e.g., regulations, standards, best practices, reports)	Cited Authority for Creation or Operation ¹
		The implementing rule for CMMC 2.0 is expected in Fall 2023. CMMC is expected to build on existing regulations (e.g., DFARS 252.204-7012) by adding a verification component for cybersecurity requirements.	
Department of Education (DoED)	DoED is a federal agency that focuses on: establishing policies on federal financial aid for education; distributing as well as monitoring those funds; collecting data on America’s schools and disseminating research; focusing national attention on key educational issues; and prohibiting discrimination and ensuring equal access to education.	Bidder’s Security Package: Security Requirements for Contractors Doing Business with the Department of Education, http://www.ed.gov/fund/contract/about/bsp.html Departmental Directive OM:5-101, Contractor Employee Personnel Security Screenings, https://www2.ed.gov/policy/gen/leg/foia/acsom5101.pdf	Department of Education Organization Act, Pub. L. 96-88 (Oct. 17, 1979) https://www.govinfo.gov/content/pkg/STATUTE-93/pdf/STATUTE-93-Pg668.pdf
	DoED has a set of acquisition regulations for all acquisition activities within the agency.	EDAR 3452.239-72, Department security requirements (https://www.acquisition.gov/edar/3452.239-72-department-security-requirements) - The contractor and its subcontractors shall comply with Department security policy requirements. All contractor employees must undergo personnel security screening if they will be employed for 30 days or more. ED Information Security and Privacy Requirements (May 4, 2023) (https://www2.ed.gov/fund/contract/about/acs/departement-information-security-and-privacy-requirements-version-2-3.pdf) - The contractor shall: - Protect Government information and information systems to ensure confidentiality, integrity, and availability. - Provide security for any Contractor systems, and information contained therein, connected to an ED network or operated by the Contractor on behalf of ED regardless of location. - Adopt and implement policies, procedures, controls, and standards required by the ED Information Security Program to ensure the confidentiality, integrity, and availability of government information and government information systems for which the Contractor is responsible under this contract or to which the Contractor may otherwise have access under this contract. - Requirements for GOCO and COCO information systems: - Agency ATO required (if providing cloud services, FedRAMP ATO required) - Third party assessment required ED Directive ACSD-OCIO-004 (https://www2.ed.gov/fund/contract/about/acs/2023-cybersecurity-policy.pdf) - The responsibilities of users include but are not limited to the following: a) Comply with all cybersecurity training and awareness requirements by the required due date, and role based training commensurate with their roles and responsibilities as needed; Report any observed or suspected security issues to their supervisor, the ISSO, ED Security Operations Center (EDSOC), Contracting Officer (CO) and Contracting Officer’s Representative (COR) if applicable; and c) Conduct their daily operational tasks and work with proper security diligence and adhere to all applicable guidance disseminated under the ISP.	
Department of Homeland Security (DHS)	DHS was created after the terrorist attacks on September 11, 2001, to coordinate and unify national homeland security efforts.	DHS Sensitive System Policy Publication, 4300A (Version 13.1, July 27, 2017), https://www.dhs.gov/sites/default/files/publications/Sensitive%20Systems%20Policy%20Directive%204300A.pdf DHS 4300A Sensitive Systems Attachments, available at https://www.dhs.gov/publication/dhs-4300a-sensitive-systems-handbook	Homeland Security Act of 2002, Pub. L.107-296 (Nov. 25, 2002), as amended https://www.dhs.gov/sites/default/files/publications/hr_50_05_enr.pdf
	DHS has a set of acquisition regulations for all acquisition activities within the agency.	HSAR 3052.204-70 (https://www.acquisition.gov/hsar/3052.204-70-security-requirements-unclassified-information-technology-resources) Contractors responsible for Information Technology (IT) security for all systems connected to a DHS network or operated by the Contractor for DHS must submit written proof of IT Security accreditation to DHS for approval by the DHS Contracting Officer.	

Federal Departments or Agencies			
Federal Department or Agency	Focus	Activity (e.g., regulations, standards, best practices, reports)	Cited Authority for Creation or Operation ¹
		Accreditation will proceed according to the criteria of the DHS Sensitive System Policy Publication, 4300A or any replacement publication. HSAR 3052.204–71 (https://www.federalregister.gov/documents/2023/06/21/2023-11270/homeland-security-acquisition-regulation-safeguarding-of-controlled-unclassified-information) - Requirements for contractor employee access to DHS information resources. HSAR 3025.204-72 (https://www.federalregister.gov/documents/2023/06/21/2023-11270/homeland-security-acquisition-regulation-safeguarding-of-controlled-unclassified-information) - Requirements for safeguarding controlled unclassified information.	
DHS Science and Technology Directorate (S&T)	S&T is the science advisor to the Secretary and serves as the research and development arm of DHS.	Cybersecurity Program Fact Sheet (June 2023), https://www.dhs.gov/sites/default/files/2023-06/23_0627_st_cybersecurity_factsheet_may2023.pdf 5G: The Telecommunications Horizon and Homeland Security Report (Dec. 2021), https://www.dhs.gov/sites/default/files/2022-02/22_0224_st_5G_6G_Horizon%20Scanning%20Report_final_508.pdf Secure and Resilient Mobile Network Infrastructure & Emergency Communications Program R&D Guidebook (July 2021), https://www.dhs.gov/publication/secure-resilient-mobile-network-infrastructure-emergency-comm-rd-guidebook Evaluating Mobile App Vetting Integration with Enterprise Mobility Management in the Enterprise (June 2019), https://www.dhs.gov/sites/default/files/publications/4681_evaluatingmobileappvettingintegrationwithemm-clean-r4-508c.pdf Study on Mobile Device Security (Apr. 2017), https://www.dhs.gov/sites/default/files/publications/DHS%20Study%20on%20Mobile%20Device%20Security%20-%20April%202017-FINAL.pdf Automating National Information Assurance Partnership Requirements Testing for Mobile Apps (June 2020), https://www.dhs.gov/publication/st-automating-national-information-assurance-partnership-requirements-testing-mobile-apps	Title III of the Homeland Security Act of 2002, as amended (codified at 6 U.S.C. §§ 181-195d) SAFETY Act of 2002 and implementing regulations (codified at 6 U.S.C. §§ 441-444) Regulations to Support Anti-Terrorism by Fostering Effective Technologies, 6 C.F.R. part 25 (June 8, 2006), https://www.ecfr.gov/current/title-6/chapter-I/part-25
DHS/Cybersecurity and Infrastructure Security Agency (CISA)	CISA serves as America’s cyber defense agency.	DHS/CISA has the authority to develop and oversee implementation of binding operational directives to other agencies, in coordination with OMB policies and practices, to administer the implementation of information security policies across federal civilian agencies. The Federal Information Security Modernization Act (FISMA) directs the Secretary to consult with and consider guidance developed by NIST to ensure that operational directives do not conflict with NIST information security standards. FISMA also requires agencies to report major information security incidents as well as data breaches to Congress as they occur and annually.	Cybersecurity and Infrastructure Security Agency Act of 2018, Pub. L. 115-278 (codified at 6 U.S.C.§ 652) The Federal Information Security Modernization Act of 2014 (FISMA 2014), https://www.congress.gov/bill/113th-congress/senate-bill/2521
	CISA and DHS are currently engaged in harmonizing cyber incident reporting requirements under CIRCIA.	Harmonization of Cyber Incident Reporting to the Federal Government, DHS (Sept. 19, 2023), https://www.dhs.gov/sites/default/files/2023-09/DHS%20Congressional%20Report%20-%20Harmonization%20of%20Cyber%20Incident%20Reporting%20to%20the%20Federal%20Government.pdf	Cyber Incident Reporting for Critical Infrastructure Act of 2022 (CIRCIA), Pub. L. 117-103 (codified at 6 U.S.C. § 681-681g)
	CISA has released Cross-Sector Cybersecurity Performance Goals and is currently working to promulgate Sector-Specific Goals.	CISA, Cross-Sector Cybersecurity Performance Goals, https://www.cisa.gov/cross-sector-cybersecurity-performance-goals CISA, Cybersecurity Performance Goals: Sector-Specific Goals, (July 26, 2023), https://www.cisa.gov/news-events/news/cybersecurity-performance-goals-sector-specific-goals	National Security Memorandum on Improving Cybersecurity for Critical Infrastructure Control Systems (NSM-5), The White House (July 28, 2021), https://www.whitehouse.gov/briefing-room/statements-releases/2021/07/28/national-security-memorandum-on-improving-cybersecurity-for-critical-infrastructure-control-systems/

Federal Departments or Agencies			
Federal Department or Agency	Focus	Activity (e.g., regulations, standards, best practices, reports)	Cited Authority for Creation or Operation ¹
	DHS/CISA has issued several documents related to protection of critical infrastructure, including the Communications Sector.	National Infrastructure Protection Plan 2013, DHS (2013), https://www.cisa.gov/sites/default/files/publications/national-infrastructure-protection-plan-2013-508.pdf Communications Sector-Specific Plan: An Annex to the NIPP, DHS (2015), https://www.cisa.gov/sites/default/files/publications/nipp-ssp-communications-2015-508.pdf Communications Sector Risk Management Agency Fact Sheet, CISA, (Aug. 5, 2021), https://www.cisa.gov/sites/default/files/publications/Communications%2520SRMA%2520Fact%2520Sheet_508.pdf Zero Trust Maturity Model (Apr. 2023), https://www.cisa.gov/sites/default/files/2023-04/zero_trust_maturity_model_v2_508.pdf Potential Threat Vectors to 5G Infrastructure (2021), https://www.cisa.gov/sites/default/files/publications/potential-threat-vectors-5G-infrastructure_508_v2_0%2520%25281%2529.pdf	The National Defense Authorization Act for Fiscal Year 2021, Pub. L. 116-283, https://www.congress.gov/bill/116thcongress/house-bill/6395/text
DHS/CISA Cybersecurity Advisory Committee	The CISA Cybersecurity Advisory Committee provides independent, strategic, and actionable consensus recommendations to the CISA Director on a range of cybersecurity issues, topics, and challenges, including but not limited to: information exchange; critical infrastructure; risk management; and public and private partnerships. The CISA Cybersecurity Advisory Committee meets at least twice per year to discuss its activities.	2022 CSAC Report and Recommendations (March 2023), https://www.cisa.gov/resources-tools/resources/cybersecurity-advisory-committee-csac-reports-and-recommendations	The National Defense Authorization Act for Fiscal Year 2021, Pub. L. 116-283, § 1718 (https://www.congress.gov/bill/116thcongress/house-bill/6395/text) (codified at 6 U.S.C. § 665e)
DHS/CISA ICT Supply Chain Risk Management Task Force	The ICT Supply Chain Risk Management Task Force is a public-private partnership charged with identifying challenges and developing actionable solutions to enhance global ICT supply chain resilience.	Executive Order 13873 Response: Methodology for Assessing the Most Critical Information and Communications Technologies and Services (April 2020), https://www.cisa.gov/sites/default/files/2023-01/eo-response-methodology-for-assessing-ict_v2_508_0.pdf	DHS created the ICT Supply Chain Risk Management Task Force in 2018. EO 13873, Securing the Information and Communications Technology and Services Supply Chain (May 15, 2019), https://www.federalregister.gov/documents/2019/05/17/2019-10538/securing-the-information-and-communications-technology-and-services-supply-chain
DHS/ Transportation Security Administration (TSA)	TSA is a DHS agency that protects the nation’s transportation systems, and it has issued security directives.	Security Directive 1580/82-2022-01A, Rail Cybersecurity Mitigation Actions and Testing, TSA (Oct. 23, 2023), https://www.tsa.gov/sites/default/files/sd-1580_1582-2022-01a-rail-cybersecurity-mitigation-actions-and-testing.pdf Security Directive 1580-21-01B, Enhancing Rail Cybersecurity, TSA (Oct. 23, 2023), https://www.tsa.gov/sites/default/files/sd-1580-21-01b-enhancing-rail-cybersecurity.pdf; Security Directive 1582-21-01B, Enhancing Public Transportation and Passenger Railroad Cybersecurity, TSA (Oct. 23, 2023), https://www.tsa.gov/sites/default/files/sd-1582-21-01b-enhancing-public-transportation-and-passenger-railroad-cybersecurity.pdf.	Aviation and Transportation Security Act, Pub. L. 107-71 (Nov. 19, 2021), (codified at 49 U.S.C. § 114)

Federal Departments or Agencies			
Federal Department or Agency	Focus	Activity (e.g., regulations, standards, best practices, reports)	Cited Authority for Creation or Operation ¹
		Security Directive Pipeline-2-21-02D, Pipeline Cybersecurity Mitigation Actions, Contingency Planning, and Testing (July 27, 2023), https://www.tsa.gov/sites/default/files/tsa-sd-pipeline-2021-02d-w-memo_07_27_2023.pdf	
Department of Justice (DOJ)/Team Telecom	The Committee for the Assessment of Foreign Participation in the United States Telecommunications Services Sector (usually called “Team Telecom”) can impose requirements to mitigate national security concerns, which can create conditions on cloud and other data uses and storage, in National Security Agreements that become binding through the FCC licensing process.	See, e.g., Press Release, DOJ, Team Telecom Recommends FCC Grant Google and Meta Licenses for Undersea Cable (Dec. 17, 2021), https://www.justice.gov/opa/pr/team-telecom-recommends-fcc-grant-google-and-meta-licenses-undersea-cable ; Press Release, DOJ, Executive Branch Agencies Recommend the FCC Revoke and Terminate China Telecom’s Authorizations to Provide International Telecommunications Services in the United States (Apr. 9, 2020), https://www.justice.gov/opa/pr/executive-branch-agencies-recommend-fcc-revoke-and-terminate-china-telecom-s-authorizations	EO 13913, Establishing the Committee for the Assessment of Foreign Participation in the United States Telecommunications Services Sector (Apr. 8, 2020), https://www.federalregister.gov/documents/2020/04/08/2020-07530/establishing-the-committee-for-the-assessment-of-foreign-participation-in-the-united-states
Department of Transportation (DOT)	DOT is a federal agency with the mission to deliver the world’s leading transportation system, serving the American people and economy through the safe, efficient, sustainable, and equitable movement of people and goods. DOT has a set of acquisition regulations for all acquisition activities within the agency.	TAR 1252.239-70 (https://www.acquisition.gov/tar/1252.239-70-security-requirements-unclassified-information-technology-resources) Includes Security Requirements for Unclassified Information Technology Resources, such as a system security plan	Department of Transportation Act, Pub. L. 89-670 (Oct. 15, 1966), https://www.gpo.gov/fdsys/pkg/STATUTE-80/pdf/STATUTE-80-Pg931.pdf
Department of Treasury (Treasury)	Treasury’s Office of Cybersecurity and Critical Infrastructure Protection coordinates the Department’s efforts to enhance the security and resilience of financial services sector critical infrastructure and reduce operational risk. The office works closely with financial sector companies, industry groups, and government partners to share information about cybersecurity and physical threats and vulnerabilities, encourage the use of baseline protections and best practices, and respond to and recover from significant incidents.	G7 Fundamental Elements of Cyber Exercise Programs (Nov. 2020), https://home.treasury.gov/system/files/216/G7-Fundamental-Elements-of-Cyber-Exercise-Programs-November-2020-Published.pdf	1789 Act of Congress Establishing the Treasury Department, https://home.treasury.gov/history/act-of-congress-establishing-the-treasury-department

Federal Departments or Agencies			
Federal Department or Agency	Focus	Activity (e.g., regulations, standards, best practices, reports)	Cited Authority for Creation or Operation ¹
	Treasury is the Sector Risk Management Agency for the Financial Services Sector.		
Department of Veterans Affairs (VA)	VA runs programs benefiting veterans and members of their families. VA has cybersecurity-related directives that govern use of IT by the agency and contractors.	VA Information Security Program; Information System Hosting, Operation, Maintenance, or USEA Directive (https://www.va.gov/vapubs/Search_action.cfm?FormNo=6500) - Security and privacy requirements for providers of external system services VA Information System Design and Development (https://www.acquisition.gov/vaar/852.239-72-information-system-design-and-development) - Information systems that are designed or developed for or on behalf of VA at non-VA facilities shall comply with all VA directives developed in accordance with FISMA, HIPAA, NIST, and related VA security and privacy control requirements for Federal information systems. - Vendor shall notify VA within 24 hours of the discovery or disclosure of successful exploits of the vulnerability which can compromise the security of the Systems.	Department of Veterans Affairs Act, Pub. L. 100-527 (Oct. 25, 1988), https://www.congress.gov/100/statute/STATUTE-102/STATUTE-102-Pg2635.pdf
DOT/National Highway Traffic Safety Administration (NHTSA)	The NHTSA is a federal agency focused on transportation safety and has promulgated cybersecurity best practices.	NHTSA, A Summary of Cybersecurity Best Practices, DOT HS 812075 (Oct. 2014), available at https://www.hsdl.org/?view&did=806518	Highway Safety Act of 1970, Pub. L. No. 91-605, 84 Stat. 1739, 1739-40, https://www.govinfo.gov/content/pkg/STATUTE-84/pdf/STATUTE-84-Pg1713.pdf
Federal Acquisition Regulatory Council (FAR Council)	The FARC was established to assist in the direction and coordination of Government-wide procurement policy and Government-wide procurement regulatory activities in the Federal Government.		Office of Federal Procurement Policy (OFPP) Act, Pub. L. 93-400 §1(a), 88 Stat. 796 (Aug. 30, 1974), as amended; (codified at 41 U.S.C. § 1301-1304)
	Several FAR clauses address cybersecurity and control of information.	FAR 39.105 (https://www.acquisition.gov/far/39.105) - Agencies shall ensure that contracts for information technology address protection of privacy in accordance with the Privacy Act (5 U.S.C.552a) and part 24. FAR 52.204-2 (https://www.acquisition.gov/far/52.204-2) - Contractor must comply with the security agreement and any revisions. FAR 52.204-21 (https://www.acquisition.gov/far/52.204-21) - Contractor shall apply 15 basic safeguarding requirements and procedures to protect covered contractor information systems. FAR 52.239-1 (https://www.acquisition.gov/far/52.239-1) - Privacy or Security Safeguards (a) The Contractor shall not publish or disclose in any manner, without the Contracting Officer’s written consent, the details of any safeguards either designed or developed by the Contractor under this contract or otherwise provided by the Government.	

Federal Departments or Agencies			
Federal Department or Agency	Focus	Activity (e.g., regulations, standards, best practices, reports)	Cited Authority for Creation or Operation ¹
		(b) To the extent required to carry out a program of inspection to safeguard against threats and hazards to the security, integrity, and confidentiality of Government data, the Contractor shall afford the Government access to the Contractor’s facilities, installations, technical capabilities, operations, documentation, records, and databases. (c) If new or unanticipated threats or hazards are discovered by either the Government or the Contractor, or if existing safeguards have ceased to function, the discoverer shall immediately bring the situation to the attention of the other party. <i>Federal Acquisition Regulation: Standardizing Cybersecurity Requirements for Unclassified Federal Information Systems</i>, Proposed Rule, 88 Fed. Reg. 68402 (Oct. 3, 2023), https://www.federalregister.gov/documents/2023/10/03/2023-21327/federal-acquisition-regulation-standardizing-cybersecurity-requirements-for-unclassified-federal <i>Federal Acquisition Regulation: Cyber Threat and Incident Reporting and Information Sharing</i>, Proposed Rule, 88 Fed. Reg. 68055 (Oct. 3, 2023), https://www.federalregister.gov/documents/2023/10/03/2023-21328/federal-acquisition-regulation-cyber-threat-and-incident-reporting-and-information-sharing	
Federal Communications Commission (FCC)	The FCC regulates non-federal communications by radio, television, wire, satellite, and cable.	Customer Proprietary Network Information (CPNI) Rules (codified at 47 CFR §§ 64.2001 et seq.) <i>Data Breach Reporting Requirements</i>, Notice of Proposed Rulemaking, WC Docket No. 22-21, FCC 22-102 (rel. Jan. 6, 2023), https://docs.fcc.gov/public/attachments/FCC-22-102A1.pdf <i>Connect America Fund, et al.</i>, Report and Order, Notice of Proposed Rulemaking, and Notice of Inquiry, WC Docket No. 10-90 et al., FCC 23-60 (rel. July 24, 2023), https://docs.fcc.gov/public/attachments/FCC-23-60A1.pdf <i>Amendment of Part 11 of the Commission’s Rules Regarding the Emergency Alert System, et al.</i>, Notice of Proposed Rulemaking, PS Docket No. 15-94 et al., FCC 22-82 (rel. Oct. 27, 2022), https://docs.fcc.gov/public/attachments/FCC-22-82A1.pdf <i>Review of International Section 214 Authorizations to Assess Evolving National Security, Law Enforcement, Foreign Policy, and Trade Policy Risks, et al.</i>, Order and Notice of Proposed Rulemaking, IB Docket No. 23-119, FCC 23-28 (rel. Apr. 25, 2023), https://docs.fcc.gov/public/attachments/FCC-23-28A1.pdf <i>Safeguarding and Securing the Open Internet</i>, Notice of Proposed Rulemaking, WC Docket No. 23-320, FCC-23-83 (rel. Oct. 20, 2023), https://docs.fcc.gov/public/attachments/FCC-23-83A1.pdf <i>Cybersecurity Labeling for Internet of Things</i>, Notice of Proposed Rulemaking, PS Docket No. 23-239, FCC 23-65 (rel. Aug. 10, 2023), https://docs.fcc.gov/public/attachments/FCC-23-65A1.pdf <i>Protecting Consumers from SIM Swap and Port-Out Fraud</i>, Notice of Proposed Rulemaking, 36 FCC Rcd 14120 (2021), https://docs.fcc.gov/public/attachments/FCC-21-102A1.pdf. Additionally, the Commission is likely to release an Order on SIM swapping in the near future. <i>See Protecting Consumers from SIM Swap and Port-Out Fraud</i>, Draft Report and Order and Further Notice of Proposed Rulemaking, WC Docket No. 21-341, FCC-CIRC2311-04 (Oct. 25, 2023), https://docs.fcc.gov/public/attachments/DOC-397990A1.pdf <i>The Uniendo a Puerto Rico Fund and the Connect USVI Fund, Connect America Fund</i>, Report and Order and Order on Review, WC Docket Nos. 18-142, 10-90, FCC 23-32, ¶ 34 (rel. Apr. 9, 2023), https://docs.fcc.gov/public/attachments/FCC-23-32A1.pdf <i>Public Safety and Homeland Security Bureau Requests Comment on Implementation of Diameter Protocol Security Best Practices</i>, Public Notice, PS Docket No. 18-99 (Feb. 10, 2020), https://docs.fcc.gov/public/attachments/DA-20-141A1.pdf <i>Public Safety and Homeland Security Bureau Requests Comment on Implementation of Signaling System 7 Security Best Practices</i>, Public Notice, PS Docket 18-99 (Apr. 3, 2018), https://docs.fcc.gov/public/attachments/DA-18-333A1.pdf	Communications Act of 1934, Pub. L. 73-416 (June 19, 1934) (codified at 47 U.S.C. § 151) Communications Act of 1934, 47 U.S.C. §§ 201(b) and 222 (giving the FCC authority over customer proprietary network information (CPNI))

Federal Departments or Agencies			
Federal Department or Agency	Focus	Activity (e.g., regulations, standards, best practices, reports)	Cited Authority for Creation or Operation ¹
	The FCC also has taken a higher profile on cybersecurity through enforcement work, task forces, and councils.	FCC Chairwoman Jessica Rosenworcel serves as Chair of the relaunched Cybersecurity Forum for Independent and Executive Branch Regulators. Press Release, FCC, Chairwoman Rosenworcel to Lead Relaunched Federal Interagency Cybersecurity Forum (Feb. 3, 2022), https://docs.fcc.gov/public/attachments/DOC-379926A1.pdf In 2023, the FCC created its Privacy and Security Task Force. The Task Force focuses on data breaches, vulnerabilities involving third-party vendors, and oversight of customer location data and vendors’ retention and protection of sensitive data. Press Release, FCC, Chairwoman Rosenworcel Launches New ‘Privacy and Data Protection Task Force’ (June 14, 2023), https://docs.fcc.gov/public/attachments/DOC-394384A1.pdf; FCC, <i>Privacy and Data Protection Task Force</i>, https://www.fcc.gov/privacy-and-data-protection-task-force Enforcement and investigative work generate substantial burdens on regulated entities and third parties, and has yielded consent decrees and NALs that the agency asserts should shape private behavior and standards of care. <i>See, e.g., In the Matter of TerraCom, Inc. and YourTel America, Inc.</i>, Notice of Apparent Liability for Forfeiture, 29 FCC Rcd 13325, ¶ 14 (2014), https://docs.fcc.gov/public/attachments/FCC-14-173A1.pdf (adopting a sweeping and novel interpretation of the undefined Communications Act term “proprietary information”); <i>TerraCom, Inc., and YourTel America, Inc.</i>, Order and Consent Decree, 30 FCC Rcd 7075 (2015), https://docs.fcc.gov/public/attachments/DA-15-776A1.pdf; <i>AT&T Services, Inc.</i>, Order and Consent Decree, 30 FCC Rcd 2808 (2015), https://docs.fcc.gov/public/attachments/DA-15-399A1.pdf; <i>Cox Communications, Inc.</i>, Order and Consent Decree, 30 FCC Rcd 12302 (2015), https://docs.fcc.gov/public/attachments/DA-15-1241A1.pdf	
Federal Financial Institutions Examination Council (FFIEC)	The FFIEC is a formal interagency body empowered to prescribe uniform principles, standards, report forms for the federal examination of financial institutions by the Board of Governors of the Federal Reserve System (FRB), the Federal Deposit Insurance Corporation (FDIC), the National Credit Union Administration (NCUA), the Office of the Comptroller of the Currency (OCC), and the Consumer Financial Protection Bureau (CFPB), and to make recommendations to promote uniformity in the supervision of financial institutions. In June 2013, the FFIEC announced the creation of the Cybersecurity and Critical Infrastructure Working Group to enhance communication among the FFIEC member agencies and build on existing efforts to strengthen the activities of other interagency and private sector groups.	Interagency Guidelines Establishing Information Security Standards, 12 C.F.R. Appendix B to Part 364 FFIEC, Cybersecurity Assessment Tool, https://www.ffiec.gov/cyberassessmenttool.htm IT Examination Handbook InfoBase, https://ithandbook.ffiec.gov/	Financial Institutions Regulatory and Interest Rate Control Act of 1978 (FIRA), Pub. L. 95-630 (codified at 12 U.S.C. § 3301)
Federal Trade Commission (FTC)	The FTC has for years touted its investigative program,	FTC Safeguards Rule, 16 CFR §§ 314 et seq.	Federal Trade Commission Act of 1914, 38 Stat. 717, as amended (codified at 15 U.S.C. §§ 41-58)

Federal Departments or Agencies			
Federal Department or Agency	Focus	Activity (e.g., regulations, standards, best practices, reports)	Cited Authority for Creation or Operation ¹
	enforcement actions, and varied guidance documents on cyber and data security.	<i>Trade Regulation Rule on Commercial Surveillance and Data Security</i>, Advanced Notice of Proposed Rulemaking, 87 Fed. Reg. 51,273 (Aug. 22, 2022), https://www.federalregister.gov/documents/2022/08/22/2022-17752/trade-regulation-rule-on-commercial-surveillance-and-data-security Solicitation for Public Comments on the Business Practices of Cloud Computing Providers (Mar. 22, 2023), https://www.regulations.gov/document/FTC-2023-0028-0001 Health Breach Notification Rule, 16 C.F.R. §§ 318.1-9 Health Breach Notification Rule, Notice of Proposed Rulemaking, 88 Fed. Reg. 3789 (June 9, 2023), https://www.federalregister.gov/documents/2023/06/09/2023-12148/health-breach-notification-rule Statement of Chair Lina M. Khan Regarding the Presentation on Data Security At the December 2022 Open Commission Meeting, FTC (Dec. 14, 2022), https://www.ftc.gov/system/files/ftc_gov/pdf/12142022OCMKhanRemarksDataSecurityPresentation.pdf	
	The FTC takes an active role in privacy and data security measures, issuing consent decrees and orders for rule violations as well as guidance.	The FTC has greatly expanded the scope of its Health Breach Data Notification Rule in policy statements, enforcement actions, and other guidance. <i>See, e.g.</i>, FTC, Statement of the Commission on Breaches by Health Apps and Other Connected Devices (Sept. 15, 2021), https://www.ftc.gov/system/files/documents/public_statements/1596364/statement_of_the_commission_on_breaches_by_health_apps_and_othe_r_connected_devices.pdf; GoodRX Holdings, Inc., Stipulated Order for Permanent Injunction, Civil Penalty Judgment, and Other Relief, Case No. 3:23-cv-460 (Feb. 17, 2023), https://www.ftc.gov/system/files/ftc_gov/pdf/goodrxfinalstipulatedorder.pdf; Easy Healthcare Corporation, Stipulated Order for Permanent Injunction, Civil Penalty Judgment, and Other Relief, Case No. 1:23-cv-3107 (June 22, 2023), https://www.ftc.gov/system/files/ftc_gov/pdf/2023.06.22_easy_healthcare_signed_order_2023.pdf; FTC, Complying with FTC’s Health Breach Notification Rule (Jan. 2022), https://www.ftc.gov/business-guidance/resources/complying-ftcs-health-breach-notification-rule-0 Several FTC enforcement matters have required third party security assessments. <i>See, e.g.</i>, Chegg, Inc., Decision and Order, Docket No. C-4782, §§ VI and VII (Jan. 25, 2023) (requiring Chegg to obtain biennial information security assessments by a third party), https://www.ftc.gov/system/files/ftc_gov/pdf/Chegg-DecisionandOrder.pdf; Drizly, LLC, & James Cory Rellas, Decision and Order, Docket No. C-4780, Exhibit B, §§ V and VI (Jan. 9, 2023) (requiring same for Drizly), https://www.ftc.gov/system/files/ftc_gov/pdf/2023185-drizly-combined-consent.pdf; Residual Pumpkin Entity, LLC & Planetart, LLC, Decision and Order, Docket No. C-4768, §§ III and IV (requiring same for Residual Pumpkin Entity, LLC) (June 23, 2022), https://www.ftc.gov/system/files/ftc_gov/pdf/192_3209_-_CafePress_combined_package_without_signatures.pdf; Ascension Data & Analytics, LLC, Decision and Order, Docket No. C-4758, §§ III and IV (requiring same) (Dec. 22, 2021), https://www.ftc.gov/system/files/documents/cases/1923126c4758ascensionorder.pdf. The FTC has also issued guidance on data privacy and security practices. <i>See, e.g.</i>, Alex Gaynor, <i>Security Principles: Addressing underlying causes of risk in complex systems</i>, FTC (Feb. 1, 2023), https://www.ftc.gov/policy/advocacy-research/tech-at-ftc/2023/02/security-principles-addressing-underlying-causes-risk-complex-systems; FTC, <i>FTC Safeguards Rule: What Your Business Needs to Know</i> (May 2022), https://www.ftc.gov/business-guidance/resources/ftc-safeguards-rule-what-your-business-needs-know; FTC, <i>Start with Security: A Guide for Business</i> (June 2015), https://www.ftc.gov/business-guidance/resources/start-security-guide-business; FTC, <i>Careful Connections: Keeping the Internet of Things Secure</i> (Sept. 2020), https://www.ftc.gov/business-guidance/resources/careful-connections-keeping-internet-things-secure; FTC, <i>Data Breach Response: A Guide for Business</i> (Feb. 2021), https://www.ftc.gov/business-guidance/resources/data-breach-response-guide-business; FTC, <i>FTC Safeguards Rule: What Your Business Needs to Know</i> (May 2022), https://www.ftc.gov/business-guidance/resources/ftc-safeguards-rule-what-your-business-needs-know	
General Services Administration (GSA)	GSA’s FedRAMP is the authoritative standardized approach to security assessment and authorization for cloud computing products and services that process unclassified federal information.	The FedRAMP Authorization Act was signed as part of the FY23 NDAA. <i>See also</i> FISMA; OMB Circular A-130 (July 2016), (https://www.cio.gov/policies-and-priorities/circular-a-130/)	Federal Property and Administrative Services Act of 1949, as amended, Pub. L. 152, Ch. 288, 63 Stat. 377, (codified in scattered sections of 40 U.S.C. and 41 U.S.C.) Presidential Transition Act of 1963, Pub. L. 88-277, 78 Stat. 153 (March 7, 1964), as amended (codified at 3 U.S.C. 102 note)

Federal Departments or Agencies			
Federal Department or Agency	Focus	Activity (e.g., regulations, standards, best practices, reports)	Cited Authority for Creation or Operation ¹
	FedRAMP leverages NIST standards and guidelines to provide standardized security requirements for cloud services; a conformity assessment program; standardized authorization packages and contract language; and a repository for authorization packages.		Federal Risk and Authorization Management Program (FedRAMP) (https://www.fedramp.gov/)
Internal Revenue Service (IRS)	The IRS is a federal agency responsible for collecting federal taxes and administering the Internal Revenue Code. The IRS has several policies that govern acquisition within the agency.	IRS 1052.224-9000 (https://www.irs.gov/pub/irs-pdf/p5488.pdf) - Safeguards Against Unauthorized Disclosure of Sensitive but Unclassified Information IRS 1052.224-9001 (https://www.irs.gov/pub/irs-pdf/p5488.pdf) - Mandatory IRS Security & Privacy Training for Information Systems, Information Protection and Facilities Physical Access IRS Information Technology Security Policy and Guidance, Internal Revenue Manual (IRM), https://www.irs.gov/irm/part10; IRS Publication 4812 Contractor Security & Privacy Controls, https://www.irs.gov/pub/irs-pdf/p4812.pdf; IRS 1052.239-9007 (https://www.irs.gov/pub/irs-pdf/p5488.pdf); IRS 1052.239-9008 (same) - Requires compliance with IRS information technology security policy and guidance documents, including 10.8.1 Policy and Guidance, 10.8.2 IT Security Roles and Responsibilities and IRS Publication 4812 Contractor Security & Privacy Controls.	Established in the Department of the Treasury by Treasury Department (TD) Order 150-29 (July 9, 1953), https://www.archives.gov/research/guide-fed-records/groups/058.html
Office of Management and Budget (OMB)	OMB coordinates and provides guidance on federal department and agency cybersecurity investment priorities.	M-23-18, Memorandum for the Heads of Executive Branch Departments and Agencies, “Administration Cybersecurity Priorities for the FY 2025 Budget” (June 27, 2023), https://www.whitehouse.gov/wp-content/uploads/2023/06/M-23-18-Administration-Cybersecurity-Priorities-for-the-FY-2025-Budget-s.pdf M-22-09, Memorandum for the Heads of Executive Departments and Agencies, “Moving the U.S. Government Toward Zero Trust Cybersecurity Principles” (Jan. 26, 2022), https://www.whitehouse.gov/wp-content/uploads/2022/01/M-22-09.pdf OMB Circular No. A-130, Managing Information as a Strategic Resource (July 28, 2016) https://www.whitehouse.gov/wp-content/uploads/legacy_drupal_files/omb/circulars/A130/a130revised.pdf	31 U.S.C. §§ 501-07 National Cybersecurity Strategy, The White House (March 2023), https://www.whitehouse.gov/wp-content/uploads/2023/03/National-Cybersecurity-Strategy-2023.pdf Executive Order 14028, Improving the Nation’s Cybersecurity, 86 Fed. Reg. 26633 (May 17, 2021), https://www.federalregister.gov/documents/2021/05/17/2021-10460/improving-the-nations-cybersecurity National Security Memorandum 8, Improving the Cybersecurity of National Security, Department of Defense, and Intelligence Community Systems (Jan. 19, 2022), https://www.whitehouse.gov/briefing-room/presidential-actions/2022/01/19/memorandum-on-improving-the-cybersecurity-of-national-security-department-of-defense-and-intelligence-community-systems/ Federal Information Security Modernization Act of 2014 (FISMA), Pub. L. 113–283, §2(d), 128 Stat. 3085 (Dec. 18, 2014), https://www.congress.gov/113/plaws/publ283/PLAW-113publ283.pdf

Federal Departments or Agencies			
Federal Department or Agency	Focus	Activity (e.g., regulations, standards, best practices, reports)	Cited Authority for Creation or Operation ¹
			Federal Information Technology Acquisition Reform Act (FITARA), Pub. L. 113-291, the Carl Levin and Howard P. “Buck” McKeon National Defense Authorization Act for Fiscal Year 2015, Div. A, Tit. VIII, Subtitle D, “Federal Information Technology Acquisition Reform,” 128 Stat. 3292, at 3438, https://www.govinfo.gov/content/pkg/PLAW-113publ291/pdf/PLAW-113publ291.pdf
The White House Office of the National Cyber Director (ONCD)	ONCD advises the President on cybersecurity policy and strategy coordination.	National Cybersecurity Strategy, ONCD (March 2023), https://www.whitehouse.gov/wp-content/uploads/2023/03/National-Cybersecurity-Strategy-2023.pdf National Cybersecurity Strategy Implementation Plan, ONCD (July 2023), https://www.whitehouse.gov/wp-content/uploads/2023/07/National-Cybersecurity-Strategy-Implementation-Plan-WH.gov_.pdf	6 U.S.C. § 1500
Securities and Exchange Commission (SEC)	The SEC has broad authority over the securities industry including the power to register, regulate, and oversee brokerage firms, transfer agents, and clearing agencies as well as the nation’s securities self-regulatory organizations.	<i>Cybersecurity Risk Management, Strategy, Governance, and Incident Disclosure</i> , Final Rule, 88 Fed. Reg. 51896, 51907 (Sept. 5, 2023), https://www.federalregister.gov/documents/2023/08/04/2023-16194/cybersecurity-risk-management-strategy-governance-and-incident-disclosure . Requires the disclosure of material cybersecurity incidents within four business days of the determination that there has been an incident, as well as cybersecurity risk management, strategy, and governance by public companies, including foreign private issuers. Commission Statement and Guidance on Public Company Cybersecurity Disclosures, Release No. 33-10459, 34-82746, 83 FR 8166 (Feb. 21, 2018), https://www.sec.gov/files/rules/interp/2018/33-10459.pdf	Securities Act of 1933 , codified at 15 U.S.C. § 77a, <i>et seq</i> ; 17 CFR, part 230 Securities Exchange Act of 1934 , 15 U.S.C. § 78a, <i>et seq</i> ; 17 CFR, part 240 Trust Indenture Act of 1939 , 17 CFR, part 260 Investment Company Act of 1940 , codified at 15 U.S.C. § 80-1, <i>et seq</i> ; 17 CFR, part 270 Investment Advisers Act of 1940 , codified at 15 U.S.C. § 80b-1, <i>et seq</i> ; 17 CFR, part 275 Securities Investor Protection Act of 1970 (Rules of SIPC), 15 U.S.C. § 78aaa, <i>et seq</i> ; 17 CFR, part 300 Public Company Accounting Reform and Corporate Responsibility Act of 2002 (Sarbanes-Oxley Act of 2002), Pub. L. 107-204 Wall Street Reform and Consumer Protection Act of 2010 (Dodd-Frank Act of 2010), Pub. L. 111-203

State Cyber Regulations, in Addition to Data Breach and Privacy Laws that Contain Security Obligations			
State	Focus	Activity (e.g., rules, regulations, proposals)	Cited Authority for Creation or Operation
Alabama	Alabama requires certain entities to implement and maintain reasonable security measures to protect sensitive personally identifying information against a breach of security.	Codified at AL Code § 8-38-3 (available at https://casetext.com/statute/code-of-alabama/title-8-commercial-law-and-consumer-protection/chapter-38-data-breach-	2018 AL SB 318

		notification-act-of-2018/section-8-38-3-reasonable-security-measures-assessment#:~:text=September%201%2C%202023.-.Section%208%2D38%2D3%20%2D%20Reasonable%20security%20measures%3B%20assessment,against%20a%20breach%20of%20security)	
California	California requires manufacturers of IoT devices to provide “reasonable security features” designed to protect users’ privacy. The ‘features’ largely focus on password requirements, requiring manufacturers to give a unique, pre-programmed password for each device, or require users to establish a new means of authentication before the device can be operated for the first time.	Codified at California Civil Code § 1798.91.04-06 (available at https://leginfo.ca.gov/faces/codes_displaySection.xhtml?sectionNum=1798.91.04.&lawCode=CIV)	CA SB-327 and AB 2392
	California requires a business that owns, licenses, or maintains personal information about a California resident to implement and maintain reasonable security procedures and practices appropriate to the nature of the information, to protect the personal information from unauthorized access, destruction, use, modification, or disclosure.	Codified at California Civil Code § 1798.81.5 (available at https://leginfo.ca.gov/faces/codes_displaySection.xhtml?lawCode=CIV&sectionNum=1798.81.5)	2004 AB 1950
	California requires covered businesses collecting consumers’ personal information to “implement reasonable security procedures and practices appropriate to the nature of the personal information to protect the [personal information] from unauthorized or illegal access, destruction, use, modification, or disclosure.”	Codified at California Civil Code § 1798.100 (available at https://cppa.ca.gov/regulations/pdf/cppa_act.pdf)	2020 California Privacy Rights Act
	California Privacy Protection Agency (CPPA) has released draft risk assessment and cybersecurity audit regulations. The draft cybersecurity audit regulations propose requiring businesses to conduct detailed annual cybersecurity audits when the business processes consumers’ PI and meets one of the “significant risk” factors. The proposed “significant risk factors” include: businesses that (1) generate more than fifty percent of their annual revenue from selling or sharing PI, (2) process personal information of a to-be-determined number of consumers and have annual gross revenues in excess of \$25 million annually, (3) exceed the to-be-determined threshold for gross annual revenue, or (4) have more than the to-be-determined number of employees.	Draft Cybersecurity Audit Regulations for California Privacy Protection Agency September 8, 2023 Board Meeting, CPPA, https://cppa.ca.gov/meetings/materials/20230908item8.pdf	2020 California Privacy Rights Act
Colorado	Colorado requires certain entities that maintain, own, or license personal identifying information to develop written policies for the proper disposal of personal information once such information is no longer needed. Colorado also requires that such entities implement and maintain reasonable security practices and procedures to protect personal identifying information from unauthorized access.	Codified at Colo. Rev. Stat. § 6-1-713 to -713.5 (available at https://casetext.com/statute/colorado-revised-statutes/title-6-consumer-and-commercial-affairs/fair-trade-and-restraint-of-trade/article-1-colorado-consumer-protection-act/part-7-specific-provisions/section-6-1-7135-protection-of-personal-identifying-information-definition)	HB18-1128
	Colorado requires covered businesses to take “reasonable measures” to secure personal information “during both storage and use from unauthorized acquisition. The data security practices must be appropriate to the volume, scope, and nature of the [personal information] processed and the nature of the business.”	Codified at Colo. Rev. Stat. § 6-1-1308 (available at https://casetext.com/statute/colorado-revised-statutes/title-6-consumer-and-commercial-affairs/fair-trade-and-restraint-of-trade/article-1-colorado-consumer-protection-act/part-13-colorado-privacy-act/section-6-1-1308-duties-of-controllers)	2021 Colorado Privacy Act
Connecticut	Connecticut has created a safe harbor for causes of action alleging failure to implement reasonable security controls resulting in a data breach concerning personal information or restricted information. To qualify, a covered entity must create, maintain, and comply with a written cybersecurity program that conforms to an industry recognized cybersecurity framework, among other requirements. Such a framework can be the current version of the NIST CSF, NIST SP 800-171, NIST SPs 800-53 and 800-53a, FedRAMP, CIS Critical Security Controls, or the ISO 27000 family.	Codified at Conn. Gen. Stat. § 42-901 (available at https://casetext.com/statute/general-statutes-of-connecticut/title-42-business-selling-trading-and-collection-practices/chapter-747-miscellaneous-provisions/section-42-901-adoption-of-cybersecurity-controls-by-businesses-exemption-from-punitive-damages)	Public Act 21-119
	Connecticut requires covered businesses to “establish, implement and maintain reasonable administrative, technical and physical data security practices to protect the confidentiality, integrity and accessibility of [personal information] appropriate to the volume and nature of the [personal information] at issue.”	Codified at Conn. Gen. Stat. § 42-520(a)(3) (available at https://casetext.com/statute/general-statutes-of-connecticut/title-42-business-selling-trading-and-collection-practices/chapter-743jj-consumer-data-privacy-and-online-monitoring/section-42-520-effective-1012023-duties-of-controller)	2022 Connecticut Data Privacy Act, Public Act 22-15
Delaware	Delaware requires any person who conducts business in this State and owns, licenses, or maintains personal information to implement and maintain reasonable procedures and practices to prevent the unauthorized acquisition, use, modification, disclosure, or	Codified at Del. Code § 12B-100 (available at https://delcode.delaware.gov/title6/c012b/index.html)	2017 HS 1 for HB 180

	destruction of personal information collected or maintained in the regular course of business.		
Illinois	Illinois requires a data collector that owns or licenses, or maintains or stores but does not own or license, records that contain personal information concerning an Illinois resident to implement and maintain reasonable security measures to protect those records from unauthorized access, acquisition, destruction, use, modification, or disclosure.	Codified at 815 ILCS 530 (available at https://www.ilga.gov/legislation/ilcs/ilcs3.asp?ActID=2702&ChapterID=67)	Public Act 099-0503
Indiana	Indiana requires covered businesses to establish, implement, and maintain reasonable administrative, technical, and physical data security practices to protect the confidentiality, integrity, and accessibility of personal data. The data security practices required under this subdivision must be appropriate to the volume and nature of the personal data at issue.	To be codified at Ind. Code § 24-15 (available at https://iga.in.gov/pdf-documents/123/2023/senate/bills/SB0005/SB0005.05.ENRH.pdf)	Indiana Consumer Data Protection Act of 2023
Iowa	Iowa requires covered businesses to “establish, implement, and maintain reasonable administrative, technical, and physical data security practices to protect the confidentiality, integrity, and accessibility of personal data.” It also requires that the practices be appropriate to the volume and nature of the personal data at issue.	To be codified at Iowa Code § 715D.1-9 (available at https://www.legis.iowa.gov/docs/publications/LGE/90/SF262.pdf)	S.F. 262, 89th Gen. Assemb., Reg. Sess. (Iowa 2023)
Kansas	Kansas requires holders of personal information to implement and maintain reasonable procedures and practices appropriate to the nature of the information, and exercise reasonable care to protect the personal information from unauthorized access, use, modification, or disclosure.	Codified at K.S. § 50-6,139b (available at http://ksrevisor.org/statutes/chapters/ch50/050_006_0139b.html)	2016 H.B. No. 2460
Louisiana	Louisiana requires that any person that conducts business in the state or that owns or licenses computerized data that includes personal information, or any agency that owns or licenses computerized data that includes personal information, to implement and maintain reasonable security procedures and practices appropriate to the nature of the information to protect the personal information from unauthorized access, destruction, use, modification, or disclosure.	Codified at La. Rev. Stat. § 3074 (available at http://legis.la.gov/legis/Law.aspx?d=322030)	2018 SB 361
Maryland	Maryland requires a business that owns, maintains, or licenses personal information of an individual residing in the State to implement and maintain reasonable security procedures and practices that are appropriate to the nature of the personal information owned, maintained, or licensed and the nature and size of the business and its operations.	Codified at Md. Code Com Law § 14-3503 (available at https://govt.westlaw.com/mdc/Document/N0725C870092511ED_A362DD7D145DC16C?viewType=FullText&originationContext=documenttoc&transitionType=CategoryPageItem&contextData=(sc.Default)&bhcp=1)	2007 S.B. 194
Massachusetts	Massachusetts requires every person that owns or licenses personal information about a resident of the Commonwealth to develop, implement, and maintain a written comprehensive information security program that meets several requirements.	Codified at Mass. Gen. Laws Ch. 93H § 2(a) (available at https://malegislature.gov/Laws/GeneralLaws/PartI/TitleXV/Chapter93H/Section2) 201 Mass. Code of Regs. 17.00-17.04 (available at https://www.mass.gov/doc/201-cmr-17-standards-for-the-protection-of-personal-information-of-residents-of-the-commonwealth/download)	2007 H.B. No. 4144
Minnesota	Minnesota requires Internet service providers to take reasonable steps to maintain the security and privacy of a consumer’s personally identifiable information.	Codified at Minn. Stat. § 325M.05 (available at https://www.revisor.mn.gov/statutes/cite/325M.05)	2002 SF 2908
Montana	Montana requires covered businesses to “establish, implement, and maintain reasonable administrative, technical, and physical data security practices to protect the confidentiality, integrity, and accessibility of personal data appropriate to the volume and nature of the personal data at issue.”	To be codified at Mont. Code Ann. § 30-14 (available at https://leg.mt.gov/bills/2023/billpdf/SB0384.pdf)	Montana Consumer Data Privacy Act of 2023
Nebraska	Nebraska requires any individual or commercial entity that conducts business in Nebraska and owns, licenses, or maintains computerized data that includes personal information about a resident of Nebraska to implement and maintain reasonable security procedures and practices that are appropriate to the nature and sensitivity of the personal information owned, licensed, or maintained and the nature and size of, and the resources available to, the business and its operations, including safeguards that protect the personal information when the individual or commercial entity disposes of the personal information.	Codified at Neb. Rev. Stat. § 87-808 (available at https://nebraskalegislature.gov/laws/statutes.php?statute=87-808)	2018 LB 757
New Mexico	New Mexico requires a person that owns or licenses personal identifying information of a New Mexico resident to implement and maintain reasonable security procedures and	Codified at N.M. Stat. § 57-12C-4 (available at https://nmonesource.com/nmos/nmsa/en/item/4423/index.do#!fragment/zoupio-	2017 H.B. 15

	practices appropriate to the nature of the information to protect the personal identifying information from unauthorized access, destruction, use, modification or disclosure.	_Toc146016632/BQCwhgziBcwMYgK4DsDWszIQewE4BUBTADwBdoAvbRABwEtsBaAfX2zgEYAWANgAYOPHgGYATAEoANMmylCEAIqJCuAJ7QA5BskRCYXAiUr1WnXoMgAynllAhdQCUAogBknANQCCAOQDCTyVlwACNoUnZxcSA)	
New York	The New York Department of Financial Service (NYDFS) has established cybersecurity requirements for financial service companies. These requirements include reporting cybersecurity incidents to NYDFS, implementing and maintaining a cybersecurity program and written cybersecurity policies, adopting mandatory technical controls and capabilities, and conducting periodic risk assessments, among other requirements.	23 NYCRR Part 500 (available at https://govt.westlaw.com/nycrr/Browse/Home/NewYork/NewYorkCodesRulesandRegulations?guid=I5be30d2007f811e79d43a037eefd0011&originationContext=documenttoc&transitionType=Default&contextData=(sc.Default)&bhcp=1)	NY Fin. Serv. Law §§ 102 , 201 , 202 , 301 , 302 , 408
	NYDFS is in the process of updating its cybersecurity requirements and has issued a Proposed Second Amendment to its current regulations. The proposed regulations would require: certain companies to conduct annual independent audits of cybersecurity programs, new cybersecurity oversight duties for governing bodies of covered entities, risk assessments to be reviewed and updated annually, new certification of compliance requirements, as well as further revisions to the existing cybersecurity program, policy, and risk assessment requirements.	New York State Department of Financial Services Revised Proposed Second Amendment to 23 NYCRR 500 (June 28, 2023), https://www.dfs.ny.gov/system/files/documents/2023/06/rev_rp_23a2_text_20230628.pdf	
Ohio	Ohio has created a safe harbor from causes of actions alleging failure to implement reasonable security controls resulting in a data breach. To qualify for the defense, entities must create, maintain, and comply with a written cybersecurity program that reasonably conforms to an “industry recognized cybersecurity framework.” Such a framework can conform to the current version of the NIST CSF, NIST SP 800-171, NIST SPs 800-53 and 800-53a, FedRAMP, CIS Critical Security Controls, or the ISO 27000 family, among other standards.	Codified at Ohio Rev. Stat. §§ 1354.02-1354.05 (available at https://codes.ohio.gov/ohio-revised-code/section-1354.02)	2018 S.B. 220
Oregon	Oregon requires covered businesses to “[e]stablish, implement and maintain for personal data the same safeguards described in ORS 646A.622 that are required for protecting personal information, as defined in ORS 646A.602, such that the controller’s safeguards protect the confidentiality, integrity and accessibility of the personal data to the extent appropriate for the volume and nature of the personal data.”	Not yet codified; (available at https://olis.oregonlegislature.gov/liz/2023R1/Measures/Overview/SB619)	2023 Oregon Consumer Privacy Act
Tennessee	Tennessee requires covered businesses to “[e]stablish, implement, and maintain reasonable administrative, technical, and physical data security practices, as described in § 47-18-3213, to protect the confidentiality, integrity, and accessibility of personal information. The data security practices must be appropriate to the volume and nature of the personal information at issue.”	To be codified at Tenn. Code Ann. § 47-18-3204(a)(3) (available at https://www.capitol.tn.gov/Bills/113/Bill/HB1181.pdf)	Tennessee Information Protection Act of 2023
Texas	Texas requires covered businesses to “for purposes of protecting the confidentiality, integrity, and accessibility of personal data, [to] establish, implement, and maintain reasonable administrative, technical, and physical data security practices that are appropriate to the volume and nature of the personal data at issue.”	Not yet codified, (available at https://capitol.texas.gov/tlodocs/88R/billtext/pdf/HB00004E.pdf)	2023 Texas Data Privacy and Security Act
Utah	Utah has created a safe harbor from systems security breaches. To qualify, persons must create, maintain, and reasonably comply with a written cybersecurity program that must meet several requirements, including reasonable conformance to the current version of NIST SP 800-171, NIST SPs 800-53 and 800-53a, FedRAMP, CIS Critical Security Controls, or the ISO 27000 family.	Codified at Utah Code Ann. §§ 78B-4-701 to 706 (available at https://le.utah.gov/xcode/Title78B/Chapter4/78B-4-S701.html)	2021 HB 80
	Utah requires covered businesses to “establish, implement, and maintain reasonable administrative, technical, and physical data security practices designed to: (i) protect the confidentiality and integrity of [personal information]; and (ii) reduce reasonably foreseeable risks of harm to consumers relating to the processing of [personal information].” It also requires businesses to adopt practices appropriate for the business’s “size, scope, and type,” as well as the “volume and nature of the [personal information] at issue.”	Codified at Utah Code Ann. § 13-61-302(2)(b) (available at https://le.utah.gov/xcode/Title13/Chapter61/13-61-S302.html?v=C13-61-S302_2022050420231231)	HB 1334 2022 Utah Consumer Privacy Act
Vermont	Vermont requires data brokers to develop, implement, and maintain a comprehensive information security program that is written in one or more readily accessible parts and contains administrative, technical, and physical safeguards that meet certain requirements.	Codified at 9 V.S.A. § 2447 (available at https://legislature.vermont.gov/statutes/chapter/09/062)	2018 HB 764
Virginia	Virginia has established data security requirements applicable to persons licensed under Virginia’s insurance laws. Specifically, the law requires licensees to maintain the	Codified at VA. Code Ann. §§ 38.2-621, 38.2-625(A) (available at	VA Code §§ 12.1-13 and 38.2-223

	security of information systems and nonpublic information, investigate cybersecurity events, and to notify individuals and the Commissioner of Insurance. Virginia passed regulations on June 1, 2021, which include (i) rules for reporting cybersecurity events; (ii) risk assessment requirements that must be implemented by July 1, 2022; and (iii) additional security measures that must be implemented by July 1, 2022. Notably, Virginia requires any person “licensed, authorized to operate, or registered, or required to be licensed, authorized, or registered pursuant to [Virginia] insurance laws” to provide notification of any cybersecurity event if any such licensee is “required under federal law or the laws of another state to provide notice of the cybersecurity event to any government body, self-regulatory agency, or other supervisory body.”	https://law.lis.virginia.gov/vacode/title38.2/chapter6/section38.2-621/ Codified at VA Admin. Code § 14-5-430-50 (available at https://law.lis.virginia.gov/admincode/title14/agency5/chapter430/section50/)	
	Virginia requires that covered businesses “[e]stablish, implement, and maintain reasonable administrative, technical, and physical data security practices to protect the confidentiality, integrity, and accessibility of [personal information].” It also requires that these data security practices be “appropriate to the volume and nature of the [personal information] at issue.”	Codified at VA Admin. Code § 59.1-578(A)(3) (available at https://law.lis.virginia.gov/vacode/title59.1/chapter53/section59.1-578/)	2021 Virginia Consumer Data Protection Act
FFIEC State Liaison Committee (SLC)	The FFIEC SLC’s members “serve as an important conduit to their state colleagues and represent state supervisory interests before the Council. The SLC consists of five representatives from state regulatory agencies that supervise financial institutions.”		

Public-Private Partnerships and Third-Party Guidance			
Entity	Focus	Activity (e.g., reports)	Cited Authority for Creation or Operation
Communications Sector Coordinating Council (CCSC)	Originally formed in 2005, the CCSC is a nonprofit organization that aims to foster and facilitate the coordination of sector-wide policy and planning activities and initiatives designed to improve both physical and cyber security of the Communications Sector. The CCSC is the primary communications sector liaison for interactions with the U.S. government and coordinates policy planning and execution developments with other industry and critical infrastructure sectors.	CSCC Emerging Technologies Committee Impact Report on Post Quantum Cryptography (July 2023), https://www.comms-scc.org/wp-content/uploads/2023/07/The-Engineer-Who-Cried-Quantum.pdf CSCC 2023 Annual Report, https://www.comms-scc.org/2023/02/07/2023-cscc-annual-report/ CSCC 2021 Annual Report, https://www.comms-scc.org/2022/06/02/cscc-2021-annual-report/ CSCC Botnet Briefing (July 2017), https://www.comms-scc.org/2017/07/26/botnet-briefing/ CSCC Industry Technical White Paper (July 2017), https://www.comms-scc.org/2017/07/17/industry-botnet-white-paper/	NIPP 2013: Partnering for Critical Infrastructure Security and Resilience, DHS (2013), https://www.cisa.gov/sites/default/files/publications/national-infrastructure-protection-plan-2013-508.pdf Presidential Policy Directive (PPD) 21: Critical Infrastructure Security and Resilience, The White House (Feb. 12, 2013), https://www.cisa.gov/sites/default/files/2023-01/ppd-21-critical-infrastructure-and-resilience-508_0.pdf Operating Charter of the Communications Sector Coordinating Council (Jan. 2019), https://www.cisa.gov/sites/default/files/publications/CSCC%20Operating%20Charter%20APPROVED%2001192019%20SUBMITTED%2009112019_508.pdf Amended and Restated Operating Charter of the Communications Sector Coordinating Council (Feb. 2021), https://www.comms-scc.org/charter/
Communications Security, Reliability, and Interoperability Council (CSRIC)	CSRIC provides recommendations to the FCC regarding ways the FCC can help to ensure security, reliability, and interoperability of communications systems.	CSRIC IV Working Group 4, Cybersecurity Risk Management and Best Practices, Final Report (Mar. 2015), https://www.atis.org/wp-content/uploads/01_legal/docs/CSRICIV/CSRIC_IV_WG4_Final_Report_031815.pdf CSRIC V Working Group 10, Legacy Risk Reductions, Final Report (Mar. 2017), https://www.fcc.gov/sites/default/files/CSRIC5-WG10-FinalReport031517.pdf	Federal Advisory Committee Act, Pub. L. 92-463, 86 Stat. 770 (1972) (codified at 5 U.S.C. Ch. 10)

Public-Private Partnerships and Third-Party Guidance			
Entity	Focus	Activity (e.g., reports)	Cited Authority for Creation or Operation
		CSRIC VII Working Group 2, Report on Risk to 5G from Legacy Vulnerabilities and Best Practices for Mitigation (June 2020), https://www.fcc.gov/file/18918/download	
The President’s National Security Telecommunications Advisory Committee (NSTAC)	NSTAC brings together industry chief executives from “major telecommunications [companies], network service provider[s], information technology, finance, and aerospace companies” to provide the President with “collaborative advice and expertise, as well as robust reviews and recommendations.”	NSTAC Report to the President on Strategy for Increasing Trust in the Information and Communications Technology and Services Ecosystem (Feb. 21, 2023), https://www.cisa.gov/sites/default/files/2023-04/NSTAC_Strategy_for_Increasing_Trust_Report_%282-21-23%29_508_0.pdf	Executive Order 12382, https://www.archives.gov/federal-register/codification/executive-order/12382.html

International Standards Organizations			
Organization	Focus	Activity (e.g., standards and reports)	Cited Authority for Creation or Operation
Alliance for Telecommunications Industry Solutions (ATIS)	ATIS is a technology and solutions development organization that provides, among other things, standards, solutions, and frameworks for mitigating cybersecurity risks.	Press Release, ATIS Analysis Helps Industry Progress Zero Trust Architecture in 5G Systems, ATIS (Aug. 1, 2023), https://www.atis.org/press-releases/atis-analysis-helps-industry-progress-zero-trust-architecture-in-5g-systems/ ATIS Standard: 5G Network Assured Supply Chain, ATIS-I-0000090 (June 2022), https://access.atis.org/apps/group_public/download.php/66150/ATIS-I-0000090.pdf ATIS, An Architectural Risk Analysis for Internet of Things (IoT) Services (Mar. 2019), https://access.atis.org/apps/group_public/download.php/46163/ATIS-I-0000072.pdf ATIS, Collaborative DevSecOps in a Service Provider Environment, ATIS-I-0000082 (Mar. 2021), https://access.atis.org/apps/group_public/download.php/58287/ATIS-I-0000082.pdf	N/A
3rd Generation Partnership Project (3GPP)	3GPP unites seven telecommunications standard development organizations (ARIB, ATIS, CCSA, ETSI, TSDSI, TTA, TTC), known as “Organizational Partners,” to provide their members with a stable environment to produce the Reports and Specifications that define 3GPP technologies. 3GPP specifications cover cellular telecommunications technologies, including radio access, core network and service capabilities, which provide a complete system description for mobile telecommunications. The 3GPP specifications also provide hooks for non-radio access to the core network, and for interworking with non-3GPP networks.	SA WG3 - Security and Privacy, https://www.3gpp.org/3gpp-groups/service-system-aspects-sa/sa-wg3	N/A

International Standards Organizations			
Organization	Focus	Activity (e.g., standards and reports)	Cited Authority for Creation or Operation
	3GPP’s Service & System Aspects (SA) Working Group 3 (WG3) focuses on 5G standards for privacy and security.		
Center for Internet Security (CIS)	CIS creates best practices for securing IT systems and data, which are adopted through “the consensus-based effort of cybersecurity experts globally.”² CIS’s main goals is to “develop[], validat[e], and promot[e] timely best practice solutions that help people, businesses, and governments protect themselves against pervasive cyber threats.”³	• CIS Benchmarks: These are “[c]onsensus-developed secure configuration guidelines for hardening operating systems, servers, cloud environments, and more.”⁴ • CIS Controls	N/A
Cloud Security Alliance (CSA)	CSA is an organization dedicated to establishing best practices to create a secure cloud computing environment. CSA collaborates with stakeholders and leaders from industries, academia, and government across the world to develop its best practices.⁵ CSA primarily focuses on best practices for cloud computing technologies and businesses.	• CSA Security, Trust, Assurance, and Risk (STAR) Registry • CSA STAR Self-Assessment	N/A
Institute of Electrical and Electronics Engineers Standards Association (IEEE-SA)	IEEE is “the world’s largest technical professional organization dedicated to advancing technology for the benefit of humanity.”⁶ Members or interested parties may submit requests for new standards to be developed through the IEEE Standards Committee. New standards are adopted by consensus and must reach at least 75% approval to be officially adopted.⁷ IEEE primarily provides cybersecurity standards relating to electric power systems. IEEE’s main focus areas include autonomous intelligent systems (AIS); connectivity & telecom; energy; foundational technologies; government engagement; life sciences and healthcare; and mobility.	• IEEE 1547.3: Guide for Cybersecurity of Distributed Energy Resources Interconnected with Electric Power Systems • Draft IEEE 1686: Draft Standard for Intelligent Electronic Devices Cyber Security Capabilities • IEEE P2658: Guide for Cybersecurity Testing in Electric Power Systems • IEEE P2808: Standard for Function Designations used in Electrical Power Systems for Cyber Services and Cybersecurity • IEEE P9274.4.2: Recommended Practice for Cybersecurity in the Implementation of the Experience Application Programming Interface	N/A
International Organization for Standardization (ISO) & International Electrotechnical Commission (IEC)	ISO’s membership is comprised of the national standards institutes of more than 150 countries. ISO handles all international standards except for electrical and electronic engineering, which is overseen by IEC. ISO and IEC have a joint technical committee (JTC1) for IT standards development.	• ISO/IEC 9001: Standards for Quality management and quality assurance (QA) • ISO/IEC 15408: Common criteria for certification of IT products • ISO/IEC 18043: Standards for selection, deployment, and operation of intrusion detection systems • ISO/IEC 20000: Standards for IT service management and associated service management systems (SMS) • ISO/IEC 22301:2012: Standards for Business continuity management systems • ISO/IEC 27000 Family: Standards relating to information security management systems (ISMS), including ISO/IEC 27001, ISO/IEC 27002, ISO/IEC 27003, ISO/IEC 27004, ISO/IEC 27005, ISO/IEC 27006, and ISO/IEC 27007 • ISO/IEC 27017: Cloud controls for cloud service providers	N/A

² Center for Internet Security [CIS], *About us*, <https://www.cisecurity.org/about-us> (last visited Sept. 5, 2023).

³ *Id.*

⁴ CIS, *Mapping and Compliance*, <https://www.cisecurity.org/cybersecurity-tools/mapping-compliance> (last visited Sept. 5, 2023).

⁵ Cloud Security Alliance, *Overview*, <https://cloudsecurityalliance.org/about/> (last visited Sept. 5, 2023).

⁶ *See* Institute of Electrical and Electronics Engineers, *IEEE Standards Development Principles*, 3 (2020) <http://globalpolicy.ieee.org/wp-content/uploads/2020/08/IEEE20014.pdf>.

⁷ *Id.*

International Standards Organizations			
Organization	Focus	Activity (e.g., standards and reports)	Cited Authority for Creation or Operation
		• ISO/IEC 27018: Code of practice for personally identifiable information (PII) on cloud servers • ISO/IEC 27037: Guidelines for the identification, collection, acquisition, and preservation of digital evidence • ISO/IEC 27400: Standards for Internet of Things (IoT) solutions • ISO/IEC 28000: Standards for security management systems for the supply chain • ISO/IEC 29147: Vulnerability disclosure in IT products and services • ISO/IEC 30111: Management and remediation of vulnerabilities in IT products	
International Telecommunication Union Telecommunication Standardization Sector (ITU-T)	The ITU-T is a branch of the International Telecommunication Union, which is a specialized agency within the United Nations (UN). The ITU-T is empowered to develop standards on information and communication technologies. Like other processes at the ITU, standards are most often developed and adopted using a consensus-based approach.⁸ ITU-T produces standards for telecommunication networks using study groups (SG), including SG17 (relating to security, languages, and telecommunications software). ITU-T coordinates with other standard development organizations, including ISO, IEC, and IEEE to ensure that ITU recommendations are generally consistent with other standards.	ITU-T X Series : Provides standards on cybersecurity information exchange, general cybersecurity, cloud computing security, data security, etc. for the telecommunications industry.	N/A
Internet Engineering Task Force (IETF)	The IETF does not have a set membership; standards are developed by volunteers who sit on working groups and attend IETF meetings.⁹ The “IETF makes voluntary standards that are often adopted by Internet users, network operators, and equipment vendors, and it thus helps shape the trajectory of the development of the Internet.”¹⁰	Transport Layer Security protocol, TLS 1.3	N/A
O-RAN Alliance	The O-RAN Alliance’s WG11: Security Working Group develops specifications for security requirements and protocols in open radio access networks (“Open RAN”).	Specifications	N/A
UL Solutions	UL Solutions helps companies to demonstrate safety, enhance sustainability, strengthen security, deliver quality, manage risk and achieve regulatory compliance. UL Solutions has created cybersecurity-related standards and also maintains 5G and IoT device testing offerings.	• UL 1376 - Methodology for Marketing Claim Verification: Security Capabilities • UL 2900 - Software Cybersecurity for Network-Connectable Products series • 5G Compliance Testing • UL Verified IoT Device Security Rating	N/A

⁸ Int’l Telecomm. Union [ITU], *ITU-T in Brief* <https://www.itu.int/en/ITU-T/about/Pages/default.aspx> (last visited Sept. 5, 2023); ITU, *ITU Cybersecurity Activities*, <https://www.itu.int/en/action/cybersecurity/Pages/default.aspx> (last visited Sept. 5, 2023).

⁹ See Internet Engineering Task Force, *Introduction to the IETF*, <https://www.ietf.org/about/introduction/> (last visited Sept. 4, 2023).

¹⁰ See *id.*

Appendix D: Compliance Offerings of Cloud Service Providers¹

Global	U.S. Government	Industry	Regional
• CIS Benchmark • CIS STAR Attestation • CSA STAR Certification • CSA STAR Self-Assessment • CyberGRX • CyberVadis • ISO 20000-1 • ISO 22301 • ISO 27001 • ISO 27017 • ISO 27018 • ISO 27701 • ISO 9001 • SOC 1 • SOC 2 • SOC 3 • WCAG 2.0 (ISO 40500)	• CJIS • CMMC • CNSSI 1253 • DFARS • DoD CC SRG • DoD IL2 • DoD IL4 • DoD IL5 • DoD IL6 • DoE 10 CFR Part 810 • EAR • FedRAMP • FISMA • FIPS 140-2 • ICD 503 • IRS 1075 • ITAR • JSIG • NIST 800-161 • NIST 800-171 • NIST 800-53 • NIST 800-63 • NIST CSF • Section 508 VPATs	Automotive • TISAX (Germany) Education • FERPA (US) Energy • NERC (US) Financial Services • 23 NYCRR 600 (US) • AFM + DNB (Netherlands) • AMF + ACPR (France) • APRA (Australia) • BaFin (Germany) • CFTC 1.31 (US) • CSSF (Luxembourg) • EBA (EU) • FCA + PRA (UK) • FFIEC (US) • FINMA (Switzerland) • FINTECH (Japan) • FINRA 4511 (US) • FISC (Japan) • FSA (Denmark) • GLBA (US) • KNF (Poland) • MAS + ABS (Singapore) • NBB + FSMA (Belgium) • OSFI (Canada) • OSPAR (Singapore) • PCI 3DS • PCI DSS Level 1 • RBI + IRDAI (India) • SEC 17a-4 (US) • SEC Regulation SCI (US) • Shared Assessments (US) • SOX (US) • TruSight Healthcare and Life Sciences • ASIP HDS (France) • GxP (FDA 21 CFR Part 11) • HIA (Canada, Alberta) • HIPAA (US) • HITRUST • MARS-E (US) • Medical Information Guidelines (Japan) • NEN 7510 (Netherlands) Media and Entertainment • CDSA • DPP (UK) • FACT (UK) • MPA Telecommunications • GSMA	Americas • Argentina PDPA • Brazil LGDP • Canada CCCS Assessment • Canada Privacy Laws • Canada Protected B • US CCPA Asia Pacific • Australia DTA HCF • Australia IRAP • Australia PDPA • China GB 18030:2005 • China DJCP (MLPS) • China ISO 20000 • China ISO 27001 • China ISO 27018 • China TRUCS/CCCPFF • China TCS • India MeitY • Japan APPI • Japan ISMAP • Japan CS Mark Gold • Japan My Number Act • Korea K-ISMS • Korea PIPA • Malaysia PDPA • New Zealand ISPS • New Zealand PDPA • Philippines PDPA • Singapore MTCS Level 3 • Singapore PDPA • Taiwan PDPA • Thailand PDPA Europe and Middle East • EU CISPE Code • EU EN 301 549 • EU ENISA IAF • EU GDPR • EU Model Clauses • EU-US Privacy Shield • Finland PiTuKri • Germany C5 • Germany IT-Grundschutz Workbook • Netherlands BIR 2012 • Portugal GNS • Spain ENS High • Spain LOPD • Spain CCN SPSTIC • UK NCSC Cloud Security Principles • UK Cyber Essentials Plus • UK G-Cloud • UK PASF Middle East and Africa • South Africa POPI • Qatar NIA • UAE DESC

¹ NSTAC Report to the President: Strategy for Increasing Trust in the Information and Communications Technology and Services Ecosystem, NSTAC, at 11 (Feb. 21, 2023) https://www.cisa.gov/sites/default/files/2023-04/NSTAC_Strategy_for_Increasing_Trust_Report_%282-21-23%29_508_0.pdf.